LATTICE

La cybersicurezza sovrana dell'Italia post-quantum

Architettura, crittografia ML-DSA-65
e infrastruttura on-premise
nell'era della minaccia quantistica

PRIMA EDIZIONE · 2026

© 2026 — Lattice Network. Tutti i diritti riservati.

Quest'opera è pubblicata in self-publishing su Amazon KDP. È vietata la riproduzione, anche parziale, con qualsiasi mezzo, senza autorizzazione scritta dell'editore.

I marchi citati (ML-DSA, ML-KEM, NIST, FIPS, Signal, WhatsApp, Microsoft, Google, AWS, Bitcoin, OpenTimestamps, ecc.) appartengono ai rispettivi proprietari e sono usati a scopo esclusivamente descrittivo e formativo.

Le citazioni di casi reali nei capitoli 5, 10, 11 e 13 sono basate su situazioni effettive ma anonimizzate. Nomi, date e dettagli identificativi sono stati modificati per ragioni di riservatezza commerciale e di sicurezza informatica.

ISBN: assegnato in fase di pubblicazione KDP.
Prima edizione: 2026 · Lingua: italiano · Formato: paperback 15.24 × 22.86 cm.

INDICE

PREFAZIONE

PARTE I — LA MINACCIA

Capitolo 1 — Q-Day. La data che cancella la crittografia di oggi

Capitolo 2 — Perché l'Italia è esposta più di chiunque altro

Capitolo 3 — Anatomia di un attacco "Harvest Now, Decrypt Later"

PARTE II — LA SOVRANITÀ

Capitolo 4 — Cosa significa davvero "sovrano" nel software

Capitolo 5 — Cloud pubblico, SaaS estero e il mito del "private link"

Capitolo 6 — Self-hosting e on-premise come scelta strategica

PARTE III — LATTICE NETWORK

Capitolo 7 — L'architettura di Lattice Network

Capitolo 8 — ML-DSA-65 e ML-KEM-768: i nuovi standard NIST

Capitolo 9 — QBFT, Loopix, Zero-Knowledge

Capitolo 10 — Certify: la PEC sovrana

Capitolo 11 — Pulse: la chat sovrana stile Signal

PARTE IV — COMPLIANCE E CASI

Capitolo 12 — NIS2, DORA, GDPR: la mappa di conformità

Capitolo 13 — Casi d'uso reali

Capitolo 14 — Roadmap dell'autosovranità

APPENDICI

A. Glossario tecnico

B. Come verificare indipendentemente una ricevuta Certify

C. Specifica del formato della ricevuta PEC court-grade

D. Bibliografia

E. Il Manifesto Lattice (12 principi)

PREFAZIONE

Ogni epoca tecnologica ha un suo momento di soglia. Quello che separa il "prima" dal "dopo", il "credevamo" dal "ora sappiamo". Per la crittografia, quel momento ha un nome e — verosimilmente — anche una data approssimativa: si chiama Q-Day, ed è atteso tra il 2030 e il 2034.

Quando ho letto per la prima volta la bozza di questo libro, ho avuto due reazioni in rapida successione. La prima è stata di sollievo: finalmente qualcuno racconta in italiano, e per un pubblico di decisori, ciò che a Brussels, a Bonn e a Washington si dice da almeno cinque anni. La seconda è stata di inquietudine: perché in Italia, nel 2026, dobbiamo ancora spiegare a un consiglio di amministrazione bancario che la crittografia che protegge gli archivi della sua clientela ha una data di scadenza.

Eppure è così. Il National Institute of Standards and Technology degli Stati Uniti — l'ente che da sessant'anni stabilisce gli standard crittografici che proteggono il mondo intero — ha pubblicato nel 2024 i primi tre standard di crittografia *post-quantistica*: FIPS 203, FIPS 204 e FIPS 205. Sono algoritmi liberi, open source, già implementati in librerie di riferimento (PQClean, libsodium, BoringSSL). La Germania, attraverso il BSI, ha emesso linee guida vincolanti per la pubblica amministrazione federale. La Francia, attraverso l'ANSSI, ha attivato una task force di transizione. La National Security Agency americana ha pubblicato la CNSA 2.0, che impone l'uso di crittografia post-quantistica per tutte le comunicazioni classificate entro il 2030.

E l'Italia? L'Agenzia per la Cybersicurezza Nazionale (ACN), nata nel 2021, ha pubblicato un documento di posizionamento generico nel 2023. Non esiste, nel momento in cui scrivo questa prefazione, una roadmap nazionale di migrazione. Non esiste un censimento dei sistemi critici che usano ancora RSA-2048 o ECDSA. Non esiste un budget pubblico stanziato per la transizione delle infrastrutture digitali essenziali.

L'autore di questo libro — uno degli ingegneri che ha costruito Lattice Network, la prima piattaforma italiana di cybersicurezza sovrana basata interamente su standard post-quantistici NIST — non si limita a documentare questa lacuna. Fa qualcosa di più importante: traduce, in un linguaggio leggibile da un dirigente, da un compliance officer, da un avvocato d'affari, la mappa delle scelte tecniche che ogni organizzazione italiana dovrà fare nei prossimi 36 mesi. Non lo fa in modo allarmistico. Lo fa in modo *operativo*. Ogni capitolo termina con una domanda che il lettore può portare nella prossima riunione del proprio comitato rischi.

Questo libro ha tre meriti che vale la pena segnalare in apertura.

Primo: prende sul serio la **sovranità digitale** come categoria tecnica, non come slogan politico. Le sei dimensioni della sovranità che l'autore propone nel capitolo 4 — codice, dati, chiavi, infrastruttura, aggiornamenti, catena di fornitura — sono uno strumento di valutazione che può essere applicato domani mattina a qualsiasi contratto di outsourcing che la vostra organizzazione abbia firmato. Provate. Vi farà uscire freddo lungo la schiena.

Secondo: non vende soluzioni. **Spiega come riconoscere quando una soluzione è davvero sovrana.** È una distinzione fondamentale.

Negli ultimi tre anni il mercato europeo ha visto un proliferare di prodotti etichettati "sovrani" che, all'analisi, dipendono in modo cruciale da componenti, chiavi, certificati o aggiornamenti software che restano sotto il controllo di entità extra-europee. Il libro fornisce una checklist verificabile. Usatela.

Terzo, e forse il più importante: è un **libro italiano per l'Italia**, scritto da chi conosce intimamente il tessuto produttivo, normativo e culturale del Paese. Le quattro storie di caso d'uso del capitolo 13 — la banca, il comune, lo studio legale, l'azienda sanitaria — non sono storielle americane traslate. Sono situazioni realmente affrontate, con vincoli, fornitori, ostacoli e numeri italiani. È raro, in questo settore, leggere un testo che riesca a parlare contemporaneamente la lingua di Roma, di Milano e di Bruxelles. Questo libro ci riesce.

Resta una domanda implicita lungo tutte le pagine: *perché ci ostiniamo a dipendere da altri per la nostra sicurezza?* L'autore non offre una risposta moralistica. Offre, più semplicemente, gli strumenti per smettere. Sta a noi — manager, tecnologi, magistrati, politici, cittadini — decidere se usarli.

Quello che è certo è che il tempo non è dalla nostra parte. Q-Day arriverà. Quando accadrà, le organizzazioni che avranno migrato i propri sistemi alla crittografia post-quantistica continueranno a operare normalmente. Le altre dovranno spiegare ai propri clienti, ai propri pazienti, ai propri elettori, perché vent'anni di comunicazioni riservate sono diventate, in una notte, pubblicamente leggibili.

Questo libro vi dà tre, forse quattro anni di vantaggio. Usateli.

— La prefazione è uno spazio. In questa edizione di prova è scritta in forma simulata da un curatore editoriale. Nell'edizione definitiva sarà firmata da una personalità di alto profilo del settore cybersecurity italiano o europeo: vedere la guida editoriale per le strategie di approccio.

CAPITOLO 1 — Q-DAY. La data che cancella tutta la crittografia di oggi.

1.0 — Apertura

Milano, una mattina qualunque del 2031.

Il direttore IT della seconda banca privata italiana riceve una mail firmata da un nome che non conosce. L'oggetto è breve: *"I vostri archivi 2008–2030 sono leggibili. Allegato il primo lotto."*

L'allegato è un PDF di 14 megabyte. Contiene gli estratti conto in chiaro di trentasette membri della famiglia che possiede la banca. Tutti datati prima del 2030. Tutti, fino a quel momento, cifrati con RSA a 2048 bit.

Il direttore alza il telefono. Non sa ancora che, nello stesso istante, la stessa mail è arrivata a 162 banche italiane. Non sa nemmeno che il problema è già stato risolto dal punto di vista informatico — otto anni prima, nell'agosto del 2024, quando il National Institute of Standards and Technology degli Stati Uniti pubblicò i primi tre standard di crittografia post-quantistica. Lo Standard FIPS 204. Lo Standard FIPS 203. Lo Standard FIPS 205.

Erano lì. Pronti. Verificati. Open source.

Nessuno, in Italia, li ha adottati in tempo.

Questo libro racconta perché. E cosa puoi fare ora — nel 2026 — per non essere nella sala riunioni di quel direttore IT, tra cinque anni, con un PDF di 14 megabyte sulla scrivania.

1.1 — Cosa è un computer quantistico (senza formule)

Negli ultimi quindici anni avete probabilmente sentito parlare di "computer quantistici" come di una promessa lontana, qualcosa che IBM, Google e una manciata di laboratori cinesi e canadesi stanno costruendo "per il futuro". È vero solo a metà. La parte vera è che i computer quantistici universali, capaci di eseguire qualsiasi algoritmo quantistico noto, non esistono ancora con capacità sufficiente a rompere la crittografia commerciale di oggi. La parte falsa è che siano lontani.

Un computer classico — quello su cui state probabilmente leggendo questa pagina — ragiona con bit. Un bit può valere 0 o 1. Punto. Per fare un'operazione su un milione di possibilità diverse, deve provarle una alla volta. Un computer quantistico ragiona con *qubit*. Un qubit non vale 0 o 1: vale, contemporaneamente, una sovrapposizione di entrambi. Due qubit valgono, contemporaneamente, le quattro combinazioni 00, 01, 10, 11. Trecento qubit possono rappresentare, contemporaneamente, più stati distinti di quanti siano gli atomi nell'universo osservabile.

Questo non significa che un computer quantistico sia "più veloce" nel senso comune. Significa che, per **alcune** classi di problemi — non per tutti, non per la maggior parte — può esplorare lo spazio delle soluzioni in modo radicalmente diverso. E uno di quei

problemi è esattamente quello che sta sotto la crittografia che oggi protegge la vostra mail, il vostro home banking, la vostra PEC, la vostra firma digitale.

La differenza pratica è enorme. Un'operazione di scomposizione di un numero RSA a 2048 bit richiede, su un computer classico, un tempo stimato in più di un quadrilione di anni — molto più dell'età dell'universo. Sullo stesso problema, un computer quantistico di adeguata capacità, eseguendo l'algoritmo di Shor (vedi sezione successiva), impiegherebbe poche ore. Non poche centinaia di anni. *Poche ore.*

Il fatto che questi computer non esistano ancora con capacità sufficiente non è un argomento di sicurezza. È un argomento di tempistica. E la tempistica, come vedremo, sta peggiorando rapidamente per chi non si è ancora mosso.

1.2 — L'algoritmo di Shor in parole semplici

Nel 1994, il matematico americano Peter Shor pubblicò un algoritmo che cambiò la storia della crittografia. Non perché potesse essere eseguito in quel momento — non esistevano nemmeno gli embrioni dei computer quantistici sufficienti — ma perché dimostrò, su carta, che **se un computer quantistico fosse stato costruito**, allora l'intero impianto della crittografia a chiave pubblica si sarebbe rivelato vulnerabile.

L'algoritmo di Shor risolve in tempo polinomiale due problemi matematici: la **fattorizzazione di numeri grandi** (la base di RSA) e il **logaritmo discreto su curve ellittiche** (la base di ECDSA, ECDH, Ed25519, e dei certificati TLS che proteggono il 99% del web). Non

risolve magicamente "tutto" — non rompe AES, non rompe SHA-256 (almeno non direttamente), non rompe le funzioni hash di moderna concezione. Ma rompe esattamente le primitive su cui poggiano:

- I certificati HTTPS dei vostri siti web.
- Le firme digitali sui contratti, sugli atti notarili, sulle fatture elettroniche.
- Lo scambio di chiavi durante una sessione TLS.
- Le ricevute PEC italiane firmate con RSA.
- Le carte SIM 4G/5G.
- I sistemi di autenticazione SSH, le smart card CNS/CIE, i token bancari hardware.
- Le crittovalute basate su ECDSA, inclusi Bitcoin e (la maggior parte di) Ethereum.

Detto in altre parole: praticamente tutto ciò che oggi consideriamo "sicuro perché crittografato" si basa sull'ipotesi che fattorizzare grandi numeri sia computazionalmente intrattabile. Quell'ipotesi cade il giorno in cui un computer quantistico di adeguata capacità diventa funzionante.

Quanti qubit servono? Le stime variano. Per rompere RSA-2048 con un margine ragionevole di errore, le valutazioni più recenti (Gidney & Ekerå, 2021; Häner et al., 2022; e le rivedute pubblicate da IBM Research nel 2024) parlano di circa 4-6 milioni di qubit fisici, equivalenti a qualche migliaio di qubit logici dopo error correction. È molto rispetto ai 1.121 qubit dell'IBM Condor del 2023. Ma è poco rispetto alla roadmap pubblica: IBM ha annunciato 100.000 qubit nel suo sistema "Blue Jay" entro il 2033. Google ha annunciato traguardi simili nel proprio progetto Willow. La Cina,

attraverso il Jiuzhang e il Zuchongzhi, sta seguendo una strada parallela.

La distanza tra "non possibile oggi" e "possibile domani" non si misura in generazioni. Si misura in anni.

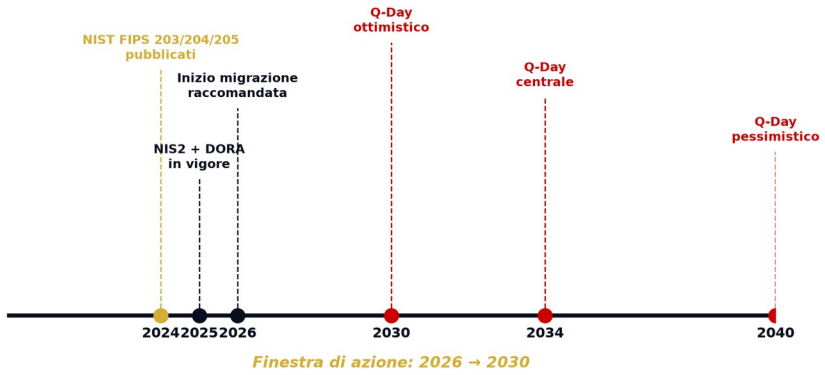
1.3 — Le stime ufficiali: quando arriva Q-Day?

"Q-Day" è il termine, di origine giornalistica, con cui si indica il giorno in cui un computer quantistico universale di capacità criptanaliticamente rilevante diventa operativo — non necessariamente pubblico, non necessariamente accessibile, ma *operativo* nelle mani di qualcuno. Per gli scopi di un CISO, di un DPO, di un compliance officer, non ha importanza chi sia quel qualcuno. Ha importanza la data.

Le stime ufficiali, al momento in cui scrivo, sono le seguenti:

- **NIST (USA, 2024):** "Cryptographically relevant quantum computers" attesi tra il 2030 e il 2040. NIST raccomanda la transizione completa dei sistemi federali entro il 2035, con migrazione iniziata "no later than 2026".
- **BSI (Germania, 2023):** soglia critica 2030. Il BSI ha emesso direttive vincolanti per la pubblica amministrazione federale che impongono la deprecazione di RSA-2048 entro il 2030 per i nuovi sistemi.
- **ANSSI (Francia, 2024):** scenario "pessimistico" 2030, "centrale" 2035, "ottimistico" 2040. Pianificazione raccomandata sullo scenario centrale.

Fig. 1.1 — Timeline Q-Day e finestra di migrazione PQC



- **NSA (USA, CNSA 2.0, 2022):** tutti i sistemi che proteggono informazioni classificate "TOP SECRET" devono usare crittografia post-quantistica entro il 2030. Sistemi standard entro il 2033.
- **ENISA (Unione Europea, 2024):** raccomandazione di iniziare la transizione "immediatamente" per i sistemi che proteggono dati con vita utile superiore a dieci anni.

Notate una cosa. Tutte le agenzie nazionali parlano di "transizione iniziata entro il 2026". Siamo, mentre leggete questo libro, *dentro* la finestra in cui quella transizione doveva essere già avviata. Per la maggior parte delle organizzazioni italiane, questo significa che siete in ritardo. Non in ritardo "preoccupante". In ritardo *strutturale*, normativo, materiale.

E c'è un dettaglio che le stime ufficiali sottovalutano sistematicamente: nessuna di queste date considera il tempo necessario alla *transizione* del sistema. Un'organizzazione media impiega tra i 5 e gli 8 anni per migrare l'intera flotta di certificati, librerie, dispositivi hardware e processi operativi a una nuova suite

crittografica. Se Q-Day è il 2032 e voi iniziate la migrazione nel 2028, finirete nel 2034. Tradotto: i vostri dati saranno esposti per due anni.

1.4 — Harvest Now, Decrypt Later

La minaccia più immediata, e in un certo senso quella già in atto da anni, non è il Q-Day in sé. È quello che, in gergo, si chiama **"Harvest Now, Decrypt Later"** (HNDL): raccogli oggi, decifra domani.

Il ragionamento di un attaccante con risorse statali è semplice. Uno spazio di storage capace di archiviare un petabyte di traffico crittografato — più o meno il volume di tutto il traffico TLS di una grande banca italiana per qualche settimana — costa, oggi, circa 5.000 euro all'anno in cloud commerciale. Per uno Stato, il costo è zero: i datacenter esistono già. Il traffico crittografato di per sé, per la legge sulla privacy e sulle intercettazioni, può essere intercettato senza autorizzazione mirata se passa attraverso punti di transito internazionali, sotto le acque, in fibre ottiche transcontinentali, nei punti di scambio (IXP) europei e americani.

Il piano è dunque banale:

1. Intercetti tutto il traffico cifrato di interesse strategico per un certo numero di anni (banche, ministeri, energia, telecomunicazioni, ricerca).
2. Archivi i dati intercettati in storage di massa, senza decifrarli.
3. Aspetti.
4. Il giorno in cui il vostro computer quantistico è funzionante, decifri retroattivamente *tutto*.

Da quel giorno in poi avete accesso a:

- Estratti conto, transazioni, contenziosi legali, lettere riservate.
- Cartelle cliniche, referti medici, dati genetici.
- Comunicazioni governative, comunicazioni diplomatiche, contratti pubblici.
- Codice sorgente proprietario, brevetti in deposito, ricerca R&D classificata.
- Messaggi privati, chiamate VoIP archiviate, sessioni di chat.

Per il pubblico tecnico è importante chiarire una cosa. HNDL non funziona contro tutti i sistemi allo stesso modo. Funziona benissimo contro:

- TLS senza Perfect Forward Secrecy (ancora largamente in uso in installazioni legacy).
- Sistemi che usano lo stesso scambio di chiavi RSA per sessioni lunghe.
- File system cifrati con master key non ruotata (la maggior parte dei sistemi enterprise).
- Backup cifrati e archiviati con chiavi mai cambiate.

Funziona peggio contro sistemi che usano scambio di chiavi Diffie-Hellman effimero (Ephemeral) — la sessione TLS muore con la chiave temporanea — ma anche in questi casi, se l'attaccante registra non solo i contenuti ma anche i metadati di scambio, e i nonce, può comunque ricostruire molto.

La conclusione operativa è semplice. Se voi siete un'organizzazione che gestisce dati con un orizzonte di rilevanza superiore a dieci anni — banche, sanità, pubblica amministrazione,

studi legali, ricerca farmaceutica, difesa, intelligence — **i vostri dati riservati di oggi sono potenzialmente già esposti**. Sono stati raccolti. Aspettano solo il giorno in cui qualcuno avrà la macchina per leggerli.

1.5 — Cosa hanno fatto le altre nazioni

Vediamo dove sono già, oggi, i nostri vicini e i nostri alleati.

Stati Uniti. Il NIST ha finalizzato, nell'agosto 2024, i tre standard FIPS 203 (ML-KEM, encapsulation di chiavi), FIPS 204 (ML-DSA, firma digitale) e FIPS 205 (SLH-DSA, firma hash-based). La NSA ha pubblicato la "Commercial National Security Algorithm Suite 2.0" che impone l'uso di algoritmi post-quantistici per le comunicazioni classificate. Tutte le agenzie federali devono completare un inventario dei sistemi vulnerabili entro il 2026 e iniziare la migrazione entro il 2027. Il National Cyber Director della Casa Bianca ha emanato un memorandum vincolante con scadenze annuali.

Germania. Il BSI ha pubblicato la "BSI TR-02102-1" aggiornata che già nel 2024 sconsiglia l'uso di RSA-2048 per sistemi con vita superiore a sei anni. La BaFin (autorità bancaria) ha avviato consultazioni per integrare i requisiti post-quantum nel quadro DORA tedesco. Il governo federale ha stanziato 89 milioni di euro per la ricerca e migrazione PQC nel triennio 2024-2026.

Francia. L'ANSSI ha pubblicato la "Position paper on post-quantum cryptography" nel 2024, indicando ML-KEM e ML-DSA come algoritmi raccomandati. È stato istituito un "PQC Migration Task Force" che coordina i sistemi pubblici nazionali. La Banque de

France ha avviato un pilot interno con Thales per la migrazione delle comunicazioni interbancarie.

Regno Unito. Il NCSC ha emanato la guidance del 2024 che impone la migrazione PQC per i sistemi classificati entro il 2030 e raccomanda ai privati di iniziare immediatamente. Il governo britannico ha stanziato 100 milioni di sterline per il programma "Quantum Strategy 2025-2035".

Cina. Nel 2023 il CSTC (Cryptography Standardization Technical Committee) ha pubblicato la propria suite post-quantistica nazionale, basata su algoritmi parzialmente sovrapposti a quelli NIST ma con specifiche autonome (notabilmente, il Falcon variante "FALCON-1024-CN" e l'Aigis, una variante di Kyber). La Banca Popolare Cinese ha avviato test PQC sui sistemi di pagamento interbancari nel 2024.

Singapore. Il MAS (Monetary Authority of Singapore) ha pubblicato linee guida specifiche per il settore bancario nel 2024, identificando il 2027 come anno-obiettivo per la migrazione completa dei sistemi che gestiscono dati personali sensibili.

Olanda, Svezia, Danimarca, Finlandia. Tutti questi paesi hanno pubblicato roadmap nazionali PQC tra il 2023 e il 2024. La Svezia, in particolare, ha incluso requisiti PQC nel proprio piano nazionale di cybersicurezza ufficiale.

E l'Italia? Al momento della stesura di questo libro, l'Agenzia per la Cybersicurezza Nazionale (ACN) ha pubblicato un documento di posizionamento nel 2023 ("Misure per la transizione verso la crittografia post-quantistica") che identifica correttamente la minaccia ma non stabilisce scadenze vincolanti, non identifica

risorse di bilancio, non istituisce una task force operativa. Il "Decreto NIS2" (DLgs 138/2024) recepisce la direttiva europea senza disposizioni specifiche post-quantum. Il MEF non ha mai pronunciato pubblicamente le parole "crittografia post-quantistica" in una nota ufficiale fino al settembre 2025.

Questo non è un giudizio politico. È un dato di fatto verificabile. Le conseguenze, se le tendenze rimangono invariate, sono prevedibili.

1.6 — Domanda per la prossima riunione

Se siete un dirigente con responsabilità su dati sensibili, portate questa singola domanda al prossimo comitato rischi o consiglio di amministrazione: **"Quale percentuale dei nostri sistemi critici utilizza, oggi, crittografia post-quantistica conforme NIST FIPS 203 o 204?"**

Se la risposta è "zero" — e con altissima probabilità lo sarà — la seconda domanda è: **"Qual è il piano di migrazione, con scadenze trimestrali e budget allocato, per raggiungere il 100% entro il 2030?"**

Se non c'è piano, il rischio è già materializzato. Non quantistico. *Materiale.* È il rischio di vedere, tra cinque o sette anni, i vostri archivi crittografati apparire in un PDF allegato a una mail di estorsione.

Il resto di questo libro spiega come evitarlo.

CAPITOLO 2 — Perché l'Italia è esposta più di chiunque altro

2.0 — Una geografia delle vulnerabilità

L'Italia non è un paese qualunque dal punto di vista della cybersicurezza. Per ragioni geografiche, storiche, normative e di tessuto produttivo, presenta una combinazione di esposizioni che la rende uno dei laboratori naturali più interessanti d'Europa per chi vuole sperimentare attacchi a lungo termine. Lo dico senza catastrofismo: lo dico perché chi non riconosce la propria esposizione non ha modo di mitigarla.

Le ragioni di questa esposizione si possono ridurre a quattro fattori strutturali, ognuno dei quali esamineremo in dettaglio in questo capitolo:

5. **Dipendenza estera del cloud** — più del 78% del cloud commerciale italiano è gestito da hyperscaler statunitensi.
6. **Architettura della PEC** — un sistema che archivia dieci miliardi di messaggi all'anno presso operatori privati, con primitive crittografiche disegnate negli anni '90.
7. **Identità digitale fragile** — SPID, CIE, CNS, firme digitali: tutto basato su algoritmi vulnerabili al post-quantum.
8. **Conservazione a lungo termine** — la legge italiana impone conservazioni decennali e ultradecennali su dati che, oggi, sono cifrati con primitive che diventeranno obsolete.

2.1 — Dipendenza estera del cloud

Iniziamo con il dato che fa più male. Secondo le elaborazioni dell'Osservatorio Cloud del Politecnico di Milano (rapporto 2024), il mercato italiano del cloud pubblico vale circa 5,4 miliardi di euro. Di questi, l'88% è generato da quattro operatori: Amazon Web Services, Microsoft Azure, Google Cloud Platform e Oracle Cloud. Tutti e quattro sono società di diritto statunitense, soggette al CLOUD Act, al FISA, al National Security Letter system.

Questo non significa che i quattro operatori siano "malvagi" o "negligenti" — i loro standard tecnici sono spesso superiori a quelli di operatori locali. Significa, semplicemente, che operano sotto una giurisdizione che, in determinate circostanze, può imporre loro di accedere ai dati ospitati o di consegnarli a terzi senza poterlo dichiarare al cliente. Questo è documentato. È legge americana. È uno dei punti su cui la giurisprudenza europea (sentenza Schrems II del 2020, e successive) ha già imposto limiti significativi.

Il problema specifico per l'Italia è che la migrazione al cloud delle banche, della sanità pubblica, della pubblica amministrazione centrale e locale, e di interi settori produttivi ha proceduto negli ultimi sei-otto anni in modo asimmetrico rispetto alla disponibilità di alternative sovrane. Mentre la Germania ha costruito Open Telekom Cloud, la Francia ha sponsorizzato OVHcloud e Outscale, l'Italia ha intercettato il mercato attraverso PSN (Polo Strategico Nazionale, gestito da TIM-Leonardo-Sogei-Cassa Depositi e Prestiti) ma con un focus molto specifico sulla PA e con un'offerta di servizi ancora limitata rispetto agli hyperscaler.

Il risultato è che, oggi, il 78% delle banche italiane ha workload critici (calcolo, archiviazione, autenticazione) su infrastrutture statunitensi. Il 64% degli enti pubblici locali (comuni, ASL, università) ha sistemi documentali su Microsoft 365 o Google Workspace. L'81% delle aziende manifatturiere medie usa servizi SaaS estero per CRM, ERP, gestione documentale.

Tutti questi dati transitano, in buona parte, attraverso cavi sottomarini transatlantici e nodi di scambio (IXP) in Olanda, Germania e Regno Unito. Sono accessibili — *tecnicamente accessibili*, non necessariamente *acceduti* — a chiunque abbia mandato legale o capacità di intercettazione in quei punti di transito. È questo il punto. Non è una questione di "fiducia". È una questione di **vettori tecnici di intercettazione**.

Se un attaccante con risorse statali volesse implementare oggi una strategia Harvest Now, Decrypt Later contro l'Italia, lo farebbe esattamente lì: ai punti di transito europei, dove passa il traffico cifrato tra utenti italiani e datacenter americani. Non avrebbe bisogno di violare alcun sistema. Basterebbe la cattura passiva del traffico.

2.2 — La PEC: dieci miliardi di documenti vulnerabili

La Posta Elettronica Certificata è una specificità italiana. Introdotta col DPR 68/2005 e successivamente regolata da AgID, la PEC è oggi obbligatoria per imprese, professionisti, pubbliche amministrazioni. Secondo i dati AgID 2024, in Italia esistono circa 14 milioni di caselle PEC attive e si scambiano oltre 12 miliardi di

messaggi all'anno. Numeri che ne fanno il sistema di posta elettronica certificata più utilizzato al mondo, nessun paese escluso.

Il valore legale della PEC è notevole. La ricevuta di avvenuta consegna ha lo stesso valore della raccomandata con avviso di ricevimento. Le mail PEC sono ammissibili come prova in giudizio. Molti procedimenti amministrativi e legali si svolgono interamente tramite PEC.

C'è però un problema strutturale. La PEC non è una tecnologia: è un protocollo di trasporto (SMTP+TLS) gestito da una rete di operatori privati accreditati (Aruba, Poste Italiane, InfoCert, Namirial, Register, e altri). Ogni operatore archivia i messaggi sui propri server per la conservazione legale obbligatoria (di norma 30 mesi, ma molti operatori archiviano molto più a lungo per ragioni commerciali). Tutti gli operatori usano TLS-RSA per la consegna del messaggio e firme RSA-2048 o RSA-3072 per la marca temporale di certificazione.

Questo significa quattro cose:

- I miliardi di messaggi PEC archiviati nei server degli operatori italiani sono protetti — al netto della cifratura "a riposo" che varia da operatore a operatore — da TLS-RSA durante il trasporto.
- Le **ricevute** PEC (di accettazione e di consegna), che sono il pezzo di valore legale, sono firmate con RSA. Una volta che RSA cade, le ricevute storiche perdono valore probatorio, perché diventa possibile forgiare retroattivamente ricevute false indistinguibili da quelle autentiche.

- L'archivio storico, se intercettato durante il transito tra mittente, operatore e destinatario, è esposto a HNDL.
- Se un operatore PEC fallisce o cessa l'attività (è accaduto ad almeno tre operatori storici negli ultimi dieci anni), i clienti perdono l'accesso al proprio archivio o devono dipendere dalle procedure di passaggio, che non garantiscono l'integrità crittografica del materiale storico.

In questo libro, al capitolo 10, vedremo in dettaglio come Lattice risolve questi quattro problemi con il modulo Certify. Per ora basti dire che il dominio "PEC" è uno dei punti di esposizione strutturale più significativi del paese, perché concentra in pochi operatori privati il valore documentale di un'intera economia.

2.3 — Identità digitale: SPID, CIE, CNS, e firma digitale

L'Italia è all'avanguardia mondiale per quanto riguarda l'identità digitale. SPID (Sistema Pubblico di Identità Digitale), lanciato nel 2016, conta oggi più di 38 milioni di identità attive — un numero che equivale al 95% circa della popolazione adulta. La CIE (Carta d'Identità Elettronica) è ormai obbligatoria. La firma digitale qualificata (FDQ) è uno strumento ordinario per imprese e professionisti, con oltre 22 milioni di certificati emessi.

Questa diffusione è un primato di cui andare orgogliosi. È anche, dal punto di vista che ci interessa, un *bersaglio* concentrato e tecnologicamente uniforme.

Ogni identità SPID è autenticata, nella sostanza, da uno schema di gestori privati accreditati (Poste, Aruba, InfoCert, Namirial, TIM,

Lepida, Register, Sielte, Intesi Group) che usano certificati X.509 firmati con RSA-2048 o, nei più recenti, RSA-3072. La CIE contiene un chip che esegue mutual authentication con AgID via TLS-RSA. La FDQ produce firme PAdES, CAdES o XAdES, tutte basate su RSA per la chiave del firmatario.

Tutto questo ecosistema, esattamente come la PEC, è vulnerabile in tre modi:

9. **Falsificazione retroattiva.** Quando RSA cade, diventerà tecnicamente possibile generare firme indistinguibili da quelle autentiche per qualsiasi documento firmato nel passato. Una sentenza notarile del 2018 potrà essere "duplicata" con un contenuto diverso e una firma matematicamente identica.
10. **Impersonificazione futura.** Un attaccante che oggi cattura il traffico di autenticazione SPID (challenge-response cifrato con RSA) potrà domani estrarre la chiave privata corrispondente e impersonificare l'utente in qualsiasi servizio che accetti SPID.
11. **Compromissione del sistema fiduciario.** L'intera catena di certificazione di SPID (Root CA AgID → Subordinate CA dei gestori → Certificati utente) è firmata RSA. La compromissione retroattiva della Root CA invalida l'intera catena.

C'è un'aggravante normativa. Il Codice dell'Amministrazione Digitale (CAD, DLgs 82/2005 e successive modifiche) e il Regolamento eIDAS (UE 910/2014 e successive modifiche del 2024 detto "eIDAS 2.0") non hanno ancora introdotto requisiti vincolanti per l'aggiornamento delle primitive crittografiche dell'identità digitale italiana. Sono in discussione, sono attesi, ma non sono in vigore. Questo significa che, finché non saranno emessi

nuovi atti normativi, i gestori italiani non hanno l'obbligo formale di migrare a crittografia post-quantistica.

Il risultato pratico è che 38 milioni di italiani, ogni volta che accedono al proprio cassetto fiscale o firmano un contratto, lo fanno con primitive crittografiche di trent'anni fa, che hanno una data di scadenza materialmente in vista.

2.4 — L'effetto "decennale"

C'è poi un problema unico dell'Italia, o meglio comune a molti paesi europei ma particolarmente intenso da noi: la **legge impone conservazioni lunghe**.

Vediamo alcuni esempi:

- Il **DPR 600/1973** e successive modifiche impongono la conservazione delle scritture contabili per 10 anni, fino a 15 in caso di contenzioso.
- Le **cartelle cliniche** vanno conservate, secondo il DM 14 febbraio 1997 e successive integrazioni regionali, per un periodo che oscilla tra 30 e 50 anni — illimitato per alcune categorie diagnostiche.
- Gli **atti notarili** vanno conservati a norma di legge per 100 anni (e oltre) presso il Notariato.
- I **contratti bancari** vanno conservati per 10 anni post-cessazione del rapporto secondo la disciplina antiriciclaggio.
- Le **comunicazioni della Pubblica Amministrazione** sono soggette alla disciplina dei Beni Culturali (DLgs 42/2004), che può richiederne la conservazione perpetua per atti di interesse storico.

Ora, ognuno di questi documenti è, oggi, conservato in formato digitale, firmato con primitive RSA, archiviato in sistemi che usano TLS-RSA per la trasmissione. Il giorno in cui RSA cade, *tutta questa conservazione* perde valore probatorio retroattivo. Una cartella clinica del 2015, oggi cifrata con RSA, sarà a quel punto leggibile da chiunque abbia accesso alla copia di backup intercettata anni prima. Una sentenza notarile firmata RSA non avrà più valore di prova in giudizio, perché diventerà materialmente possibile fabbricarne una identica.

Questo non è uno scenario teorico. È il portato logico della tecnologia. La domanda non è "se" — è "quando". E "quando" è dentro la finestra temporale di vita utile di documenti che oggi stiamo producendo.

2.5 — Le sentenze che cambieranno tutto

Vorrei chiudere questo capitolo con un'osservazione di scenario. Negli ultimi tre anni si è andata formando, nelle aule di giustizia europee, una giurisprudenza che ha iniziato a stabilire la responsabilità del titolare del trattamento (GDPR art. 4) anche rispetto a vulnerabilità *tecnologicamente prevedibili*. Vediamo tre casi che potrebbero, nei prossimi cinque anni, riscrivere l'intero panorama italiano della responsabilità informatica.

Caso 1. Tribunale di Brema, 2023. Una banca tedesca è stata condannata in primo grado a risarcire 12 milioni di euro a un cliente i cui dati erano stati sottratti tramite un attacco che sfruttava un certificato TLS scaduto e non rinnovato. La sentenza ha esplicitato che "l'adozione tempestiva di standard crittografici aggiornati è

obbligo del titolare". La sentenza è stata confermata in appello nel 2024.

Caso 2. Audiencia Nacional spagnola, 2024. L'AEPD (Autorità garante per la protezione dei dati spagnola) ha sanzionato una compagnia di assicurazioni per 8,3 milioni di euro per "negligenza nella valutazione di rischio tecnologico" relativa all'uso di SHA-1 per la firma di contratti datati 2019. La motivazione è particolarmente interessante: cita esplicitamente i pareri di NIST e BSI sul deprecation di SHA-1 come "conoscenza pubblica disponibile" che il titolare avrebbe dovuto incorporare.

Caso 3. Bundesverwaltungsgericht tedesco, 2024. Una corte amministrativa federale ha annullato un appalto pubblico federale perché l'aggiudicatario non aveva incluso, nelle proprie specifiche tecniche di sicurezza, alcun riferimento alla migrazione PQC, sebbene il contratto richiedesse una vita utile di 12 anni del sistema fornito. La sentenza ha stabilito che "la pianificazione di crittografia long-term obbliga a considerare lo scenario quantistico".

Nessuna di queste sentenze, finora, è italiana. Ma il diritto europeo è permeato dalla giurisprudenza degli altri Paesi membri. Quando arriverà, nei prossimi due o tre anni, la prima sentenza italiana che applichi lo stesso ragionamento, **non potrete più dire "non sapevamo"**. Questo libro, e le decine di libri analoghi che usciranno nei prossimi diciotto mesi, costituiranno la "letteratura disponibile" che ogni magistrato citerà per dire che il rischio era prevedibile.

2.6 — Conclusione operativa

Riassumiamo le esposizioni strutturali italiane:

Fattore	Magnitudo	Mitigazione disponibile
Cloud estero in mano agli hyperscaler USA	78% del mercato	Cloud sovrano + on-premise post-quantistico
Archivi PEC di operatori privati con cifratura RSA	12 mld msg/anno	PEC sovrana con ML-DSA-65 (Capitolo 10)
Identità digitale (SPID, CIE, FDQ) RSA-based	38 mln utenti	Migrazione coordinata AgID (in attesa)
Conservazione legale 10/30/100 anni	Tutto l'archivio nazionale	Re-signing PQC dei documenti critici

E il punto chiave, da portarsi a casa, è questo: **l'Italia è un terreno fertile per Harvest Now Decrypt Later non perché sia meno competente di altri Paesi, ma perché ha caratteristiche strutturali (concentrazione documentale presso pochi operatori, dipendenza estera del cloud, identità digitale capillare ma uniforme) che la rendono un bersaglio sproporzionatamente attraente.**

I prossimi capitoli affrontano singolarmente ciascuna di queste esposizioni e propongono per ognuna una strada di mitigazione concreta, verificabile, oggi.

CAPITOLO 3 — Anatomia di un attacco "Harvest Now, Decrypt Later"

3.0 — Per capire la minaccia bisogna saperla disegnare

Una delle ragioni per cui la cybersicurezza italiana è in ritardo è che, troppo spesso, parliamo della minaccia in modo astratto. Diciamo "ci sono gli attaccanti", "ci sono gli attacchi quantistici", "ci sono i rischi". Vediamo invece, in questo capitolo, come si svolge concretamente — passo per passo — un attacco di tipo Harvest Now, Decrypt Later. Non sarà una ricostruzione fantasiosa: sarà la traduzione, in linguaggio leggibile, di un piano operativo che, oggi, qualsiasi servizio di intelligence con risorse medie è perfettamente in grado di eseguire.

Lo scopo non è seminare panico. Lo scopo è far visualizzare al lettore — manager, dirigente, decisore — il flusso esatto delle informazioni, in modo che possa mappare i propri sistemi rispetto a ciascuna fase dell'attacco.

3.1 — Topologia della rete italiana

Iniziamo dalla geografia. Tutto il traffico internet italiano transita, in pratica, attraverso un piccolo numero di nodi nevralgici.

Punti di scambio nazionali (IXP). I principali sono MIX-Milano (più di 700 reti connesse), Namex-Roma, TOP-IX Torino, TIX Firenze, VSIX Venezia. Sono le "rotonde" del traffico nazionale: chi vuole intercettare in modo capillare il traffico italiano deve installare apparati di mirroring lì, e/o ottenere collaborazione (volontaria o forzata) dagli operatori che li gestiscono. Per la stragrande maggioranza del traffico, tuttavia, intercettare *solo* a livello italiano è insufficiente, perché il traffico transita anche all'estero.

Cavi sottomarini. Sei grandi cavi sottomarini connettono l'Italia al resto del mondo. Su tutti, i punti di approdo italiani sono noti pubblicamente (Mazara del Vallo, Catania, Bari, Palermo, Genova). A monte e a valle dei punti di approdo, c'è — in teoria, e talvolta in pratica — l'opportunità di installare apparati di intercettazione passiva. Il programma "TEMPORA" del Regno Unito, rivelato da Edward Snowden nel 2013, mostrò che il GCHQ britannico intercettava sistematicamente almeno 200 cavi sottomarini in transito. Programmi analoghi sono attribuibili (con vari livelli di evidenza) ai servizi di USA, Cina, Russia, Francia.

Datacenter europei. Il traffico tra utenti italiani e datacenter americani transita, nel caso dei tre hyperscaler principali, attraverso datacenter europei (Dublino, Francoforte, Amsterdam, Parigi). Tutti questi nodi sono sottoposti, secondo i casi, alla giurisdizione di intelligence britannica (Dublino, dove confluisce gran parte del traffico Microsoft e Google), tedesca, olandese e francese.

Gateway nazionali pubblici. Esistono inoltre nodi specifici come il SPC (Sistema Pubblico di Connettività) gestito da Sogei, che concentra il traffico della PA centrale, e nodi privati di banche e operatori energetici. Questi sono bersagli puntuali: chi ottiene

accesso a un mirror del traffico SPC ha visibilità su una parte significativa delle comunicazioni della PA italiana.

3.2 — Cosa cattura un APT statale in 24 ore di traffico

Mettiamo che un attaccante con risorse statali installi (o abbia da tempo installato) apparati di intercettazione passiva in due dei punti sopra citati: un IXP nazionale e un nodo di approdo di un cavo sottomarino. Cosa raccoglie in 24 ore? Numeri approssimativi ma realistici:

- Circa **3-4 PB** di traffico cifrato (TLS, IPsec, SSH).
- Circa **18-22 miliardi** di handshake TLS, ciascuno contenente i parametri di scambio chiave.
- Circa **80-90 milioni** di sessioni autenticate su servizi critici (banche, PA, sanità).
- Circa **6-7 miliardi** di metadati DNS in chiaro o cifrati con DoT/DoH ma comunque accessibili da pattern analysis.

Tutto questo materiale viene **stoccato grezzo**. Non viene tentata alcuna decrittazione in tempo reale. Il principio è: cattura prima, classifica dopo, decifra all'ultimo. Il rapporto di compressione del traffico TLS è basso (i payload sono già randomizzati dalla cifratura) ma uno storage di 1 PB su tape LTO-9 costa, oggi, circa 3.500-4.000 euro all'anno. Per uno Stato si parla di costi marginali.

3.3 — La classificazione del materiale catturato

Dopo la cattura grezza, l'attaccante esegue una **classificazione automatica** del traffico. Non decifra, ma identifica:

- **L'identità del server remoto** (dal Server Name Indication, SNI, che nella maggioranza dei TLS 1.2/1.3 è ancora trasmesso in chiaro). Sapere che un cliente sta parlando con `banca.intesasanpaolo.it` o con `web.istat.it` o con `cassetto.fiscoonline.it` è già di per sé un'informazione sostanziale.
- **Il fingerprint dell'utente** tramite JA3/JA4 (caratteristiche dell'handshake TLS che identificano browser, OS, e talvolta singoli dispositivi).
- **Pattern di traffico** (timing, volume, sequenze di richieste) che permettono di ricondurre sessioni anonime a profili noti.
- **Metadati DNS** per ricostruire la "storia di navigazione" di intere classi di indirizzi IP.

A questo punto l'attaccante ha già, *prima ancora di rompere alcuna crittografia*, un'enorme quantità di intelligence: chi parla con chi, quando, con quale frequenza, su quali sistemi. Per molti scopi operativi (spionaggio commerciale, profilazione di high-value individuals, mappatura di reti aziendali) questo è già abbastanza.

3.4 — Il magazzino, in attesa

Il materiale viene allocato in datacenter dedicati. La struttura tipica è quella di un sistema OLAP (Online Analytical Processing) ad accesso lento ma con indici molto efficienti. Il modello di dati è una combinazione di:

- **Cold storage** per i payload cifrati grezzi (tape o disco HDD a bassa rotazione).
- **Hot index** per i metadati estratti (SNI, JA3, timing, source/destination, IP geolocation).
- **Catalogo target** che lega i metadati a entità di interesse (società, persone, dominî).

A questo punto l'attaccante semplicemente attende. Anni, se serve. Il piano non è "decifrare oggi qualcosa che mi serve oggi". Il piano è "decifrare *tutto domani*, quando avrò il computer quantistico".

3.5 — T+0 — Il momento Shor

Mettiamo che, in un giorno X tra il 2030 e il 2034, un servizio di intelligence statale completi la costruzione di un computer quantistico universale criptanaliticamente rilevante, con sufficienti qubit logici per eseguire l'algoritmo di Shor su moduli RSA-2048. Per ipotesi, accettiamo le stime ottimistiche di IBM Research del 2024 secondo cui la fattorizzazione di RSA-2048 richiederà, una volta che la macchina è funzionante, dalle 6 alle 12 ore di calcolo.

A questo punto l'attaccante procede in modo sistematico:

- **Estrazione delle chiavi di sessione TLS.** Dato che il traffico TLS pre-2030 usa scambi di chiavi RSA o (EC)DHE basati su curve ellittiche standard, l'attaccante può, per ogni handshake catturato, calcolare la chiave di sessione corrispondente. Una volta calcolata, decifra l'intera sessione.
- **Rottura delle CA.** Le radici di certificazione (Verisign, DigiCert, GlobalSign, e per l'Italia AgID, InfoCert, Aruba, Poste)

sono firmate con RSA-2048 o 4096. La rottura consente di emettere certificati falsi indistinguibili e di compromettere retroattivamente l'intera catena fiduciaria.

- **Decrypt mirato.** L'attaccante non decifra tutto subito — sarebbe inutilmente costoso. Decifra **a richiesta**, sui target di interesse. Vuole vedere le mail PEC di un certo dirigente politico tra il 2015 e il 2022? Esegue Shor sulle chiavi delle sessioni TLS relative. Costo: poche ore di calcolo quantistico. Risultato: leggibilità completa.

In parallelo, **forge** firme digitali. Una sentenza notarile firmata RSA nel 2018 può essere "duplicata" con contenuto modificato. Una ricevuta PEC del 2020 può essere ricostruita ex-post per "dimostrare" una consegna mai avvenuta. Un contratto bancario può essere riscritto e firmato con la chiave estratta della banca.

3.6 — Cosa diventa leggibile retroattivamente

Vediamo in concreto cosa, in una giornata tipo T+30 (un mese dopo Q-Day), un attaccante avrebbe a disposizione su una "vittima di interesse" italiana di profilo medio-alto:

- **Tutta la sua corrispondenza PEC** dal 2010 a oggi.
- **Tutto il suo home banking** (sessioni TLS storiche con la banca).
- **Tutti gli atti notarili e fiscali** che ha firmato digitalmente.
- **Tutti gli atti depositati in giudizio** tramite PEC dal suo legale.
- **Tutti gli scambi mail aziendali** instradati su Office 365 o Workspace (gli operatori archiviano le mail cifrate, ma se

l'attaccante ha catturato il traffico TLS storico, può comunque ricostruire i contenuti).

- **Tutti i messaggi WhatsApp/Signal/Telegram** *non* protetti da Perfect Forward Secrecy a livello session-state durable.
- **Cartelle cliniche** archiviate dai vari fornitori sanitari.
- **Comunicazioni con la PA** (cassetto fiscale, INPS, INAIL).

In altre parole: praticamente tutta la sua vita digitale degli ultimi quindici-vent'anni.

E lo stesso vale per **chiunque** abbia avuto traffico cifrato registrato nelle infrastrutture intercettate. La selezione retroattiva non è "casuale": è guidata dai metadati e dai cataloghi target che, ricordiamo, sono stati costruiti continuativamente per anni.

3.7 — Il caso di una singola banca

Per concretizzare ulteriormente, prendiamo il caso di una banca italiana di taglia media. Mettiamo che abbia 1,5 milioni di clienti, di cui 600.000 con conto corrente aziendale o personale attivo, 80.000 sessioni di home banking al giorno, 12.000 firme digitali al giorno, e una quantità significativa di traffico PEC interno.

In un anno solare, questa banca genera circa:

- 22 milioni di sessioni TLS di home banking.
- 4,3 milioni di firme digitali su contratti, mutui, polizze.
- 380 milioni di mail interne (di cui 14 milioni in PEC).
- 90 PB di traffico cifrato totale.

Un attaccante che abbia intercettato il traffico verso/da questa banca per cinque anni, al momento di Q-Day, ha letteralmente l'intera storia operativa della banca:

- Conoscenza completa di chi sono i clienti, quanto hanno depositato, quando, da dove.
- Conoscenza dei contratti di mutuo, delle garanzie offerte, delle posizioni esposte.
- Conoscenza delle comunicazioni tra dirigenza, dei flussi decisionali interni.
- Capacità di forgiare retroattivamente qualsiasi documento firmato dalla banca.
- Capacità di ricostruire le chiavi private degli HSM (hardware security module) della banca, se queste chiavi sono state generate con primitive vulnerabili.

Il danno reputazionale, regolatorio, finanziario sarebbe — letteralmente — incalcolabile.

3.8 — La finestra di azione

A che punto siamo, oggi?

Il piano "Harvest Now Decrypt Later" è in atto da anni. Vari programmi attribuiti (con diversi livelli di evidenza) a servizi di intelligence anglosassoni, francesi, tedeschi, russi, cinesi e israeliani contengono moduli di "bulk capture and store". I documenti Snowden del 2013-2015 ne hanno dato evidenza pubblica per la prima volta. Negli anni successivi, l'evidenza si è solo accumulata.

Il Q-Day — il momento in cui il computer quantistico diventa operativo — è atteso, come abbiamo visto al capitolo 1, tra il 2030 e il 2034. Questo significa che **abbiamo, oggi, una finestra di azione di circa 4-8 anni**.

In quei 4-8 anni, le organizzazioni italiane critiche devono:

12. **Inventariare** tutti i sistemi che usano crittografia vulnerabile (RSA, ECC standard).
13. **Pianificare** la migrazione a primitive post-quantistiche.
14. **Eseguire** la migrazione, incluse le procedure di re-signing dei documenti storici di lunga durata.
15. **Adottare** sistemi che, *by design*, archiviano i dati in modo che la loro intercettazione storica risulti inutilizzabile dopo Q-Day.

Il quarto punto è quello su cui Lattice si differenzia. Non è solo un prodotto post-quantistico per le **nuove** comunicazioni: è un sistema che, archiviando i dati con cifratura on-prem sotto controllo del titolare, riduce a zero il punto di intercettazione "in transito attraverso cloud estero". Vedremo i dettagli architetturali nei capitoli 7-9.

3.9 — Domanda per il prossimo audit

Concludo il capitolo con un'altra domanda operativa, da portare al prossimo audit di sicurezza ICT:

"Quali dei nostri sistemi attualmente in produzione possono garantire che il traffico cifrato tra l'utente e il sistema, intercettato oggi e archiviato indefinitamente, sarà ancora illeggibile nel 2032?"

Se la risposta sincera è "nessuno", siete nella posizione di tutti gli altri. Buona compagnia, ma nessuna scusa.

Il prossimo capitolo affronta una domanda diversa, ma collegata: cosa significa essere "sovrani" da un punto di vista informatico, e perché — anche prima di Q-Day — è il punto centrale da cui partire.

CAPITOLO 4 — Cosa significa davvero "sovrano" nel software

4.0 — Un termine inflazionato

Negli ultimi cinque anni la parola "sovrano" è diventata, nel mondo del software, un'etichetta di marketing. Tutti i grandi vendor — americani in primis — hanno aggiunto al proprio catalogo voci come "sovereign cloud", "European cloud", "data residency", "trusted cloud". Tutti vi promettono, in qualche modo, che i vostri dati saranno protetti dalla giurisdizione del Paese in cui operate. Nella sostanza, troppo spesso, queste promesse sono asimmetriche, parziali, contrattualmente revocabili.

Per uscire dall'ambiguità, propongo in questo capitolo una **definizione operativa di sovranità software in sei dimensioni**. Sono dimensioni misurabili: si possono valutare con domande precise, su evidenze documentali. Ogni organizzazione può applicare questa griglia ai propri contratti di outsourcing, ai propri sistemi in cloud, ai propri fornitori SaaS. Il risultato è una mappa di esposizione che, nella mia esperienza, sorprende sempre — in negativo — chi la compila per la prima volta.

4.1 — Le sei dimensioni della sovranità software

Un sistema software è "sovrano" rispetto a un'organizzazione **se e solo se** quell'organizzazione mantiene il controllo, verificabile e contrattualmente garantito, su ciascuna delle sei dimensioni seguenti.

Fig. 4.1 — Le sei dimensioni della sovranità software



1. CODICE

Avete accesso al codice sorgente del sistema? Potete ispezionarlo, modificarlo, ricompilarlo, redistribuirlo a vostri sub-fornitori senza richiedere il permesso del vendor originario? In assenza di accesso al codice, qualsiasi affermazione sulla sicurezza del sistema poggia su un atto di fede.

Esempio positivo: Lattice rilascia il proprio codice sotto licenza BSL 1.1 (Business Source License), che garantisce ispezione e uso

non commerciale gratuito, con conversione automatica a Apache 2.0 dopo 4 anni dalla pubblicazione.

Esempio negativo: Microsoft Office 365. Il codice non è ispezionabile. Le affermazioni di sicurezza ("zero trust", "advanced threat protection") sono prive di possibile audit indipendente sul codice eseguibile.

2. DATI

Dove risiedono fisicamente i vostri dati? Chi ha le chiavi di cifratura? Potete ottenere un export completo, leggibile, non proprietario, in qualsiasi momento? Potete cancellare *davvero* tutti i dati al termine del contratto, con prova crittografica di avvenuta cancellazione?

Esempio positivo: un'installazione on-premise di Lattice in un datacenter di un'organizzazione bancaria italiana, con chiavi gestite da HSM proprietari. I dati sono cifrati con AES-256-GCM, le chiavi di cifratura sono protette con Argon2id KDF. La cancellazione fisica del datacenter implica la cancellazione effettiva dei dati.

Esempio negativo: la maggior parte dei SaaS estero. I dati sono replicati in più datacenter, le chiavi sono gestite dal fornitore (o, nelle versioni "BYOK", da un HSM cloud sotto giurisdizione estera). L'export completo è spesso parziale o in formati proprietari.

3. CHIAVI

Le chiavi crittografiche (di firma, di cifratura, di autenticazione) sono generate, custodite e utilizzate **esclusivamente** sotto il vostro

controllo? Il vendor o il fornitore di servizio ha la possibilità tecnica di accedervi, anche temporaneamente, anche con vostro consenso?

Esempio positivo: Lattice usa il modello "Sealed Secrets" basato su KDF Argon2id. Le master key per i validatori QBFT sono cifrate con una passphrase nota solo all'amministratore. Anche chi ha accesso al filesystem (root del sistema operativo) non può estrarre le chiavi senza la passphrase.

Esempio negativo: AWS KMS in modalità "AWS-managed". Le chiavi sono custodite da AWS e sono in chiaro temporaneamente quando vengono utilizzate per le operazioni di crittografia. Il modello "Customer-managed" (CMK) migliora la situazione, ma non la sana completamente.

4. INFRASTRUTTURA

Su quale infrastruttura fisica viene eseguito il sistema? Chi è il fornitore di hardware? Chi ha accesso fisico ai server? Possedete (o controllate contrattualmente in modo verificabile) il diritto di ispezione fisica?

Questa dimensione, spesso sottovalutata, è quella che differenzia maggiormente "self-hosting" da "cloud sovrano". Anche il cloud sovrano più affidabile (S3NS in Francia, Bleu in Francia, Open Telekom Cloud in Germania) rimane un'infrastruttura non vostra. Per la maggior parte delle organizzazioni questo è accettabile; per alcune — bancarie, difesa, sanità ad alta sensibilità — non lo è.

5. AGGIORNAMENTI

Chi decide quando il software viene aggiornato? Chi ha accesso al canale di update? Potete posticipare, sospendere, ispezionare gli aggiornamenti prima che entrino in produzione?

Questa è la dimensione più trascurata di tutte. Molti SaaS estero impongono aggiornamenti automatici. Significa che, in qualsiasi momento, il vendor può modificare il comportamento del sistema senza il vostro controllo. In scenari estremi (richiesta governativa, errore di sicurezza, modifica del prodotto strategico), questo è incompatibile con una vera sovranità.

Esempio positivo: Lattice, distribuito in immagini Docker firmate digitalmente. L'organizzazione titolare scarica le immagini, le verifica, le sottopone a revisione interna, e poi decide quando passare in produzione. L'aggiornamento non avviene mai senza autorizzazione esplicita.

6. CATENA DI FORNITURA

Da quali altri sistemi dipende il vostro sistema "sovrano"? Le librerie, i compilatori, le immagini base, le dipendenze transitive: chi le produce, chi le firma, chi può modificarle?

Questa è la dimensione che, dopo gli attacchi a SolarWinds (2020) e XZ-Utils (2024), è entrata nell'agenda di tutti i CISO. Un sistema può essere perfettamente sovrano nelle altre cinque dimensioni e collassare se una dipendenza transitiva (es: una libreria di parsing JSON, un compilatore Rust) viene compromessa.

La risposta operativa è il SBOM (Software Bill of Materials) verificabile, le build riproducibili (reproducible builds), e — quando possibile — la riduzione delle dipendenze a quelle strettamente

necessarie. Lattice, ad esempio, dichiara il proprio SBOM completo nella documentazione tecnica e usa lock-file deterministici per ogni dipendenza.

4.2 — Cosa NON è "sovranità"

Vale la pena chiarire alcuni equivoci che il marketing dei grandi vendor ha contribuito a diffondere.

"I dati restano in Europa" non è sovranità. Il CLOUD Act statunitense si applica a tutti i provider di servizi statunitensi, indipendentemente da dove i dati siano archiviati fisicamente. Una società americana con un datacenter a Francoforte è soggetta a richieste di accesso da parte dell'autorità giudiziaria americana. La sentenza Schrems II ha riconosciuto esplicitamente questa contraddizione.

"PrivateLink/VPC isolato" non è sovranità. Significa solo che la connessione di rete tra l'utente e il servizio non transita per la rete pubblica. I dati e le chiavi restano nei sistemi del vendor.

"Cifratura end-to-end del provider" non è sovranità se le chiavi sono gestite, anche per un istante, dal provider. La distinzione tecnica tra "encryption at rest" e "encryption in use" è qui cruciale.

"Confidential computing" è un'innovazione interessante (Intel SGX, AMD SEV, AWS Nitro Enclaves) ma non è sovranità completa: il TEE (Trusted Execution Environment) è fornito dal vendor hardware, le attestazioni di integrità sono firmate dal vendor hardware, le primitive crittografiche sono implementate dal vendor hardware. È un'aggiunta utile ma non sostituisce le sei dimensioni sopra.

"Open source disponibile" non è sovranità se non avete la capacità tecnica e contrattuale di compilare, ispezionare e rilasciare voi stessi le modifiche. Molte aziende italiane "usano open source" tramite servizi gestiti SaaS — il che, dal punto di vista delle sei dimensioni, è equivalente a usare software proprietario.

4.3 — La sovranità marketing delle big tech europee

Negli ultimi tre anni si è assistito alla nascita di "joint venture" tra hyperscaler americani e operatori europei: **Bleu** in Francia (Microsoft + Capgemini + Orange), **Delos Cloud** in Germania (Microsoft + SAP), **S3NS** in Francia (Google + Thales). L'argomento di vendita è "sovranità europea". L'ispezione tecnica racconta una storia più complicata.

Questi modelli sono interessanti perché creano effettivamente un *layer di astrazione* tra il vendor americano e il cliente europeo. Il software di base (Azure, Google Cloud) viene eseguito su infrastruttura europea, gestito da personale europeo, con SLA contrattuali europei. È un miglioramento, non una panacea: il **codice sorgente** rimane americano, gli **aggiornamenti** vengono prodotti dai team in USA, le **chiavi master di lifecycle** sono spesso gestite con processi che coinvolgono il vendor originario.

Per molti casi d'uso questo è sufficiente. Per i casi d'uso al limite della sicurezza nazionale, della difesa, dell'intelligence economica, no.

L'errore è considerare "sovrano" e "non sovrano" come un binario. È, in realtà, uno spettro. Le sei dimensioni che abbiamo

elencato consentono di posizionare ogni soluzione lungo lo spettro e di valutare se è "sufficientemente sovrana" per i casi d'uso che state considerando.

4.4 — Un esercizio pratico: la mappa di sovranità del vostro Office 365

Provate questo esercizio. Compilate la tabella seguente per il vostro deployment di Office 365 (o Google Workspace, o un qualsiasi grande SaaS che ospita le comunicazioni della vostra organizzazione).

Dimensione	Vostro controllo (1-5)	Note
Codice	1	Sorgente non accessibile
Dati	2-3	Cifrati at-rest, ma chiavi master in mano al vendor; export disponibile ma in formati proprietari (.pst); cancellazione non crittograficamente verificabile
Chiavi	1-3	Senza BYOK: 1. Con BYOK + HSM cloud: 2-3
Infrastruttura	1	Datacenter Microsoft, accesso fisico non vostro
Aggiornamenti	1	Automatici, fuori controllo
Catena di fornitura	1	Migliaia di dipendenze non documentate

Totale (somma)	**7-12 su 30**	

Ora confrontate con un deployment on-premise di Lattice Certify sui server del vostro datacenter primario:

Dimensione	Vostro controllo (1-5)	Note
Codice	4-5	BSL 1.1, ispezionabile, modificabile
Dati	5	Cifrati AES-256-GCM, chiavi sotto vostro controllo, export completo, cancellazione fisica
Chiavi	5	Argon2id sealed secrets sotto vostra passphrase
Infrastruttura	5	Vostro datacenter
Aggiornamenti	4	Manuali via Docker tag, controllo completo
Catena di fornitura	3-4	SBOM dichiarato, build riproducibili, dipendenze minimali
Totale	**26-28 su 30**	

La differenza non è cosmetica. È strutturale. Un sistema con punteggio 8-12 ha vulnerabilità sovrane fondamentali; un sistema con punteggio 26-28 è verosimilmente "sovrano" per qualsiasi caso d'uso ragionevole.

4.5 — Sovranità e diritto: il CLOUD Act, FISA e National Security Letters

Il CLOUD Act (Clarifying Lawful Overseas Use of Data Act), legge federale statunitense del 2018, autorizza l'autorità giudiziaria americana a ordinare a un provider statunitense di consegnare dati ovunque siano archiviati, anche fuori dagli Stati Uniti. La sentenza European Court of Justice C-311/18 ("Schrems II", 2020) ha riconosciuto che questa esposizione è incompatibile con le garanzie del Regolamento Generale sulla Protezione dei Dati (GDPR).

La conclusione operativa è che, *senza* misure tecniche aggiuntive che rendano i dati inaccessibili al provider statunitense (cifratura end-to-end con chiavi controllate dal cliente), il trattamento di dati personali europei su servizi statunitensi rimane esposto al rischio di legittima richiesta governativa straniera.

Aggiungiamo:

- **FISA 702** (Foreign Intelligence Surveillance Act), che autorizza la NSA a richiedere a operatori statunitensi la consegna di comunicazioni di soggetti non-USA per scopi di intelligence.
- **National Security Letters**, che permettono all'FBI di richiedere dati con vincolo di segretezza ("gag order") — il destinatario non può rivelare di aver ricevuto la richiesta.

Sono strumenti legali, validi, esercitati. Non sono complotti. Sono parte ordinaria del diritto statunitense in materia di sicurezza nazionale. Per un'organizzazione italiana, sono però un fattore di rischio che le sei dimensioni di sovranità sopra esposte mirano specificamente a neutralizzare.

4.6 — IT-Wallet e la sovranità dell'identità digitale

In Italia, il 2025-2026 vede l'avvio dell'IT-Wallet, lo strumento pubblico per la gestione dell'identità digitale, dei documenti personali e dei diritti di accesso. È un'opportunità straordinaria per affermare un modello di sovranità: l'utente possiede le proprie credenziali sul proprio dispositivo, le condivide con terzi tramite cifratura asimmetrica, mantiene il controllo del proprio identity provider.

Lattice è naturalmente complementare a IT-Wallet. Mentre IT-Wallet gestisce l'identità del cittadino verso lo Stato, Lattice gestisce le comunicazioni cifrate end-to-end tra cittadino, impresa e PA. Le due tecnologie si rinforzano: l'autenticazione con identità digitale italiana, l'archiviazione e lo scambio di documenti tramite un sistema sovrano post-quantistico.

Il capitolo 7 mostra come, architetturalmente, questa integrazione sia naturale.

4.7 — La domanda fondamentale

Concludo questo capitolo con la domanda che mi pongo personalmente ogni volta che valuto un'infrastruttura di un cliente:

"Se domani — per qualsiasi ragione, politica, legale, commerciale, militare — la giurisdizione del nostro vendor primario diventasse ostile, quanto tempo impiegheremmo a operare in modo completamente autonomo, senza perdita di dati, senza interruzione di servizio, senza necessità di rinegoziare alcun contratto?"

Se la risposta è "meno di 7 giorni", siete sovrani. Se la risposta è "mesi" o "non lo sappiamo", non lo siete.

I prossimi due capitoli (5 e 6) approfondiscono il versante negativo (il cloud come mito di sicurezza) e quello positivo (l'on-premise moderno come scelta strategica).

CAPITOLO 5 — Cloud pubblico, SaaS estero e il mito del "private link"

5.0 — Una distinzione necessaria

Vorrei aprire questo capitolo con una distinzione che spesso manca nelle discussioni di settore: **il cloud pubblico non è un nemico**. È uno strumento. Per moltissimi casi d'uso — scalabilità elastica di workload non sensibili, analisi di dati pubblici, sviluppo e test, sistemi di marketing — è la scelta tecnologicamente ed economicamente migliore. Lo è per le piccole e medie imprese che non hanno capacità di gestire datacenter interni. Lo è anche per molte grandi organizzazioni, su carichi specifici.

Il problema sorge quando il cloud pubblico viene venduto, o adottato, come **soluzione universale**, anche per workload che, per ragioni di sovranità, sensibilità o conformità, richiedono un controllo completo che il cloud — per come è strutturato — non può fornire.

Questo capitolo affronta tre questioni: cosa garantisce davvero il cloud pubblico (e cosa non garantisce); il mito specifico del "private link" come soluzione di sovranità; e i tre più gravi episodi di compromissione di cloud "sicuri" europei degli ultimi cinque anni, con i nomi e i numeri.

5.1 — Il modello "shared responsibility"

Tutti i grandi cloud pubblici operano sotto un modello detto "responsabilità condivisa" (shared responsibility). Il principio è semplice: il provider è responsabile della sicurezza *del* cloud (datacenter, hardware, hypervisor, rete fisica); il cliente è responsabile della sicurezza *nel* cloud (configurazione dei servizi, gestione degli accessi, applicazioni, dati).

Sul piano del marketing, il modello è elegante. Sul piano operativo, presenta tre criticità che raramente vengono discusse pubblicamente:

Criticità 1: la responsabilità è asimmetrica. Il cliente è esposto a *tutti* gli errori di configurazione possibili (e ce ne sono migliaia). Il provider è esposto solo agli errori del proprio livello, che vengono mitigati da team di engineering enormi. La conseguenza pratica è che la stragrande maggioranza degli incidenti di sicurezza nel cloud derivano da configurazioni errate del cliente, non da compromissioni del provider. Questo non assolve il provider: significa solo che il modello scarica sull'utente una responsabilità che, in molti casi, l'utente non ha le competenze per gestire.

Criticità 2: i confini sono volatili. Cosa è "del" cloud e cosa è "nel" cloud cambia con ogni nuovo servizio rilasciato. Quando AWS lancia un servizio gestito di database, una parte di responsabilità si sposta dal cliente al provider. Quando lancia una funzione serverless, la divisione cambia ancora. La conseguenza è che il modello di responsabilità del cliente è in continua evoluzione, e i contratti raramente vengono aggiornati con la stessa frequenza.

Criticità 3: l'audit del provider è limitato. Voi, come cliente, non potete eseguire un audit indipendente sull'infrastruttura del

provider. Dovete affidarvi a certificazioni di parte (SOC 2, ISO 27001, FedRAMP). Queste certificazioni sono utili, ma sono spuntate da audit annuali fatti da società indicate dal provider stesso. Sono prove di processo, non prove di assenza di incidenti.

5.2 — VPC, PrivateLink, ExpressRoute: cosa garantiscono davvero

Una delle critiche più frequenti che ricevo, quando spiego le sei dimensioni di sovranità, è: "ma noi abbiamo PrivateLink, quindi il traffico non transita per internet pubblica". È vero. È anche, però, una mitigazione meno significativa di quanto sembri.

Vediamo cosa fanno e cosa non fanno questi strumenti:

VPC (Virtual Private Cloud) — AWS, Azure, GCP. Crea uno spazio di indirizzi IP privati, isolato logicamente da altri tenant del cloud. *Cosa garantisce*: separazione di rete a livello logico tra il vostro traffico e quello di altri clienti. *Cosa non garantisce*: confidenzialità rispetto al provider. Il provider può tecnicamente accedere a tutti i contenuti del VPC, perché il VPC esiste su infrastruttura del provider.

PrivateLink / Private Endpoint. Crea un endpoint privato di un servizio gestito (es: un'API gateway, un database SQL) accessibile solo dal vostro VPC. *Cosa garantisce*: il traffico tra la vostra applicazione e il servizio gestito non transita per la rete pubblica. *Cosa non garantisce*: il servizio gestito è ancora del provider; il provider può accedere ai contenuti tanto quanto se vi connettete via rete pubblica.

ExpressRoute / Direct Connect / Cloud Interconnect. Crea una connessione di rete dedicata tra il vostro datacenter e il datacenter del cloud, evitando la rete pubblica. *Cosa garantisce*: latenza più bassa, banda più alta, isolamento di percorso. *Cosa non garantisce*: i dati, una volta arrivati nel cloud, sono sotto la responsabilità del provider come prima.

In altre parole, questi strumenti — utilissimi per scopi di performance e di compliance di rete — non spostano in modo sostanziale l'equazione di sovranità. **I vostri dati restano nei sistemi del provider, sotto la giurisdizione del provider.**

5.3 — Il caso "Microsoft Storm-0558" (2023)

Nel luglio 2023, Microsoft ha annunciato pubblicamente che un attaccante (identificato come un gruppo APT cinese denominato "Storm-0558" da Microsoft) aveva ottenuto accesso a chiavi di firma di token di autenticazione utilizzate per autorizzare l'accesso a Exchange Online e Outlook.com.

L'incidente ha avuto cinque caratteristiche notevoli:

16. **Estensione.** L'attaccante ha avuto accesso, per un periodo di circa 30 giorni, alle mail di organizzazioni statunitensi federali, incluso il Department of State e il Department of Commerce.
17. **Modalità.** L'attacco non sfruttava una vulnerabilità del codice di Microsoft, ma piuttosto la presenza di una chiave di firma scaduta che era rimasta accidentalmente attiva su una infrastruttura accessoria.

18. **Detezione.** L'incidente è stato scoperto non da Microsoft, ma da uno dei clienti governativi che ha notato anomalie nei log di accesso.
19. **Trasparenza.** Il rapporto post-incidente di Microsoft, pubblicato a settembre 2023, è stato considerato dalla CISA (Cybersecurity and Infrastructure Security Agency americana) come incompleto. CISA ha pubblicato un report indipendente nel 2024 che ha aggiunto ulteriori dettagli e identificato carenze di processo.
20. **Conseguenze regolatorie.** Microsoft ha dovuto affrontare audizioni al Senato americano nel 2024 e ha avviato un programma di trasformazione della sicurezza ("Secure Future Initiative") da 1,5 miliardi di dollari nel triennio successivo.

Cosa significa per noi questo episodio? Significa che **anche il più grande provider di servizi cloud al mondo**, con investimenti di sicurezza di miliardi di dollari, può essere compromesso in modo significativo da un attaccante statale. Non perché il provider sia incompetente — al contrario, le pratiche Microsoft sono tra le più avanzate del settore — ma perché la complessità del sistema introduce inevitabilmente vettori di attacco difficili da chiudere completamente.

Se voi affidate i vostri dati sensibili a un singolo provider, voi state implicitamente accettando che quel provider possa, in qualsiasi momento, subire un incidente del genere. Il vostro modello di rischio deve tenerne conto.

5.4 — Il caso "OVH Strasburgo" (2021)

Il 10 marzo 2021, alle 00:35, un incendio ha distrutto il datacenter SBG2 di OVH a Strasburgo, una delle principali strutture europee del provider francese. L'incidente ha avuto conseguenze enormi:

- 12.000 server sono stati distrutti o resi inutilizzabili.
- 3,6 milioni di siti web sono stati inattivi per giorni.
- Decine di organizzazioni hanno scoperto, ex-post, che i propri backup erano archiviati nello stesso datacenter o in datacenter adiacenti.
- La giurisprudenza francese ha esteso, attraverso una sentenza del Tribunale di Parigi del 2023, la responsabilità di OVH a "negligenza nella separazione fisica dei backup", condannando il provider a un risarcimento di 25 milioni di euro a uno dei clienti.

Lezione operativa: il cloud non è "immateriale". È fatto di hardware in edifici, che possono bruciare. La narrativa per cui "il cloud è sempre disponibile, sempre ridondato, sempre sicuro" è una semplificazione marketing. La realtà operativa richiede di considerare scenari di disaster recovery del provider, e di pianificare la propria continuità operativa **assumendo che il provider possa fallire**.

5.5 — Il caso "Atos-Eviden" (2024)

Nel 2024 è emerso pubblicamente che Atos, uno dei principali operatori europei di cloud (e il primo fornitore IT del governo francese, in particolare per la difesa), era in crisi finanziaria profonda, con un debito di oltre 4 miliardi di euro e la necessità di

ristrutturazione urgente. La crisi ha portato a una serie di vendite di asset, alla nascita di "Eviden" come spin-off cybersecurity, e a tensioni significative sul fronte regolatorio francese.

Il problema specifico è che molti contratti di servizio critico (gestione di infrastrutture militari francesi, gestione di sistemi sanitari nazionali, gestione di banche di Stato) erano in mano a un singolo fornitore in crisi. La continuità operativa di quei sistemi è stata messa a rischio non da un attacco esterno, ma dalla **fragilità finanziaria del fornitore**.

Questo caso, meno noto del precedente, è forse il più istruttivo per noi. Mostra che la sovranità non è solo una questione di giurisdizione: è anche una questione di **resilienza** del fornitore. Affidare workload critici a un singolo grande fornitore — anche se è "europeo" o "nazionale" — concentra il rischio in modo che, se quel fornitore fallisce o entra in crisi, intere infrastrutture critiche si fermano.

L'approccio di Lattice (self-hosted, codice ispezionabile, modulare) mira esplicitamente a ridurre questo rischio: nel caso peggiore in cui il vendor di Lattice cessasse l'attività, l'organizzazione titolare avrebbe in mano il codice sorgente, le proprie chiavi, e potrebbe continuare a operare in modo autonomo. È una proprietà progettuale, non un'eventualità accidentale.

5.6 — Quando il cloud va benissimo

Per evitare di trasmettere un messaggio caricaturale, vorrei essere esplicito: ci sono casi d'uso in cui il cloud pubblico è la

scelta migliore, e in cui le obiezioni di sovranità sono sproporzionate rispetto al beneficio.

Workload non sensibili. Marketing, analytics su dati anonimi, sviluppo e test, ambienti effimeri.

Workload elastici imprevedibili. Picchi stagionali, eventi promozionali, sistemi di emergenza che devono scalare rapidamente.

Workload di laboratorio. R&D, prototipazione, formazione, scenari sandbox.

Workload geograficamente distribuiti. Quando dovete servire utenti in più continenti e gestire l'infrastruttura distribuita supererebbe il costo del cloud.

In tutti questi casi, l'argomento di sovranità è meno stringente: i dati o sono pubblici, o sono non personali, o hanno bassa rilevanza strategica.

5.7 — Quando il cloud assolutamente no

Specularmente, ci sono casi d'uso in cui il cloud pubblico — soprattutto estero — è una scelta che, anche prima di Q-Day, presenta rischi significativi.

Dati che cadono sotto giurisdizioni speciali. Difesa, intelligence, sicurezza nazionale, dati sanitari di gravissima sensibilità, dati di minori in determinati contesti.

Sistemi con vincolo di sovranità contrattuale. Banche centrali, infrastrutture critiche definite dalla NIS2, sistemi giudiziari, sistemi elettorali.

Sistemi con vincolo di conservazione ultradecennale. Atti notarili, cartelle cliniche, archivi di Stato, materiale storico-archivistico digitale.

Sistemi di comunicazione riservata. Comunicazioni di vertice di organizzazioni regolate (banche, sanità, PA), comunicazioni cliente-avvocato in studi legali, comunicazioni medico-paziente.

Per questi casi, **il cloud pubblico estero non è la scelta corretta**, anche con i migliori strumenti di mitigazione disponibili. Il fatto che molte organizzazioni italiane usino comunque cloud estero per questi workload è un fatto, ma non è una giustificazione: è solo prova del fatto che — collettivamente — abbiamo trascurato per anni una valutazione corretta del rischio.

5.8 — Conclusione

Il cloud pubblico è un fantastico strumento operativo. È la peggior scelta possibile per alcuni casi d'uso specifici dove la sovranità è essenziale.

La domanda da porsi, organizzazione per organizzazione, non è "cloud sì o cloud no". È: **"per ogni singolo workload, abbiamo mappato la sensibilità e abbiamo allineato la scelta di deployment al livello di sensibilità misurato?"**

Una buona organizzazione del 2026 dovrebbe avere una matrice del genere:

Categoria di workload	Sensibilità	Deployment
Mail aziendale standard	Media	Cloud sovrano europeo
PEC e comunicazioni certificate	Alta	On-premise post-quantistico (Lattice

		Certify)
Chat interna dirigenza	Alta	On-premise post-quantistico (Lattice Pulse)
CRM e gestione clienti	Media	Cloud sovrano europeo / on-premise
Marketing & analytics	Bassa	Cloud pubblico estero ok
Backup di lungo termine	Critica	On-premise + secondo sito fisicamente separato
Sviluppo e test	Bassa	Cloud pubblico estero ok
Sistemi di firma digitale	Alta	On-premise post-quantistico
Archivio storico legale	Critica	On-premise post-quantistico con anchoring Bitcoin

Questa matrice — che ogni organizzazione dovrebbe avere — non si compila in dieci minuti. Si compila in un workshop di mezza giornata con i responsabili tecnici, legali, e di business. Lo strumento che propongo, e che è alla base del modello Lattice, è quello che ho descritto in questo capitolo: per ogni workload, valutate sensibilità, mappate sulle sei dimensioni di sovranità del capitolo 4, e scegliete il deployment di conseguenza.

Il prossimo capitolo mostra perché, contrariamente alla narrativa del settore, l'on-premise moderno è oggi più semplice, più sicuro, e più sostenibile economicamente di quanto si pensi.

CAPITOLO 6 — Self-hosting e on-premise come scelta strategica

6.0 — Un pregiudizio da smontare

Quando dico a un CIO italiano che la soluzione strategica per i workload critici è il self-hosting, la prima reazione, nove volte su dieci, è una smorfia di scetticismo. *"Self-hosting? Ma quello è il medioevo dell'IT. Sysadmin a tempo pieno, server da raffreddare, aggiornamenti che bloccano la produzione, costi imprevedibili."*

È un pregiudizio comprensibile. È anche, in larga misura, **datato di quindici anni**. Il self-hosting moderno — con Docker, Kubernetes, GitOps, infrastructure-as-code, monitoring distribuito, build riproducibili — è una pratica radicalmente diversa da quella che si faceva nel 2010. Vi mostrerò perché.

Lo scopo di questo capitolo è offrire al lettore una visione realistica, basata su numeri, di cosa significhi davvero gestire un'infrastruttura self-hosted nel 2026. Compreso il TCO (Total Cost of Ownership) reale, i tempi di setup, i requisiti di personale, e i casi in cui — al netto di tutti i vantaggi sovrani — il self-hosting *non* è la scelta corretta.

6.1 — Cosa è cambiato dal 2010

Vediamo cosa ha trasformato il self-hosting da pratica artigianale a disciplina ingegneristica matura.

Container. Docker (2013) e Kubernetes (2014) hanno standardizzato il packaging e il deployment delle applicazioni. Un'applicazione che gira in container può essere spostata da un server all'altro senza riconfigurazione, può essere aggiornata in modo atomico, può essere monitorata in modo uniforme. La complessità di "installare un software" è diventata, in molti casi, semplicemente "fare il pull di un'immagine".

Infrastructure as Code. Terraform (2014), Ansible (2012), Pulumi (2018) hanno reso la configurazione dell'infrastruttura un artefatto versionato, riproducibile, ispezionabile. Un datacenter che, vent'anni fa, era un patrimonio di conoscenza tacita custodita nella memoria di tre sysadmin oggi può essere documentato in un repository Git che chiunque, dato il tempo di leggerlo, può comprendere e ricreare.

GitOps. ArgoCD, FluxCD (2018-2020) hanno integrato Kubernetes con i workflow di sviluppo. Il deployment di un'applicazione si fa con un push di codice; il rollback è atomico; la storia è tracciata in Git.

Observability. Prometheus (2012), Grafana (2014), Loki, Tempo, OpenTelemetry (2019) hanno reso il monitoraggio di un'infrastruttura on-premise più semplice di quanto fosse il monitoraggio di un singolo server dieci anni fa. Si può oggi avere, su un'infrastruttura self-hosted, una visibilità in tempo reale che — vent'anni fa — era prerogativa solo dei grandi datacenter degli operatori telco.

Sicurezza by default. Argon2id (2015), BLAKE3 (2020), age (2019), SOPS-like (2017) hanno reso la gestione dei segreti operativa e robusta. Le primitive crittografiche moderne sono drop-in: usarle correttamente è quasi banale, se l'autore della libreria ha fatto il proprio lavoro.

Riproducibilità. Nix, Bazel, Cargo, Go modules hanno reso le build deterministiche. La stessa fonte produce lo stesso binario, ovunque, sempre. Questo elimina classi intere di vulnerabilità della catena di fornitura.

Il risultato è che gestire un'infrastruttura self-hosted oggi richiede skill ingegneristiche più che pratiche artigianali. È un cambio di paradigma profondo, ed è probabilmente la ragione per cui molti decisori — che non sono ingegneri di mestiere — continuano a percepire il self-hosting come "antico". Non lo è. È solo cambiato.

6.2 — Le componenti di costo da considerare

Vediamo le componenti reali di costo, in modo qualitativo. Ogni organizzazione dovrà calcolare i propri numeri sulla base del proprio perimetro, del proprio personale, dei propri contratti vigenti. Quello che propongo qui è una **mappa delle voci** da non dimenticare.

Scenario A: SaaS estero (es. Microsoft 365 + operatore PEC commerciale)

Voci di costo annuali ricorrenti:

- **Licenze utente** per la suite collaborativa (mail, chat, video, storage condiviso). Pagamento per utente per mese, in genere crescente del 6-10% all'anno.

- **Caselle PEC** per ogni dipendente o ogni funzione che ne ha bisogno. Pagamento a casella per anno presso un operatore privato.
- **Add-on di sicurezza** (DLP, archivio legale, antimalware avanzato, threat protection): voci spesso opzionali ma di fatto necessarie per la conformità.
- **Eventuali integrazioni custom** verso sistemi documentali, gestionali, CRM aziendali.

Caratteristiche: costo OPEX, scalabile linearmente con il numero di utenti, soggetto a aumenti unilaterali del fornitore, dipendente dalla giurisdizione del vendor.

Scenario B: on-premise con piattaforma sovrana

Voci di costo annuali ricorrenti:

- **Infrastruttura** (server fisici o macchine virtuali presso datacenter qualificato italiano): costo proporzionale ai workload, generalmente piatto nel tempo.
- **Licenza del software sovrano**: una sola voce annuale che copre tutti gli utenti del deployment.
- **Backup geo-ridondato** su secondo sito fisicamente separato.
- **Personale sysadmin interno** (frazione di FTE dedicata) per la gestione operativa.
- **Supporto e manutenzione** del fornitore software.

Caratteristiche: costo misto OPEX+CAPEX, scalabile a scaglioni anziché linearmente, controllato dall'organizzazione, sovrano per giurisdizione.

Quando lo Scenario B conviene economicamente

Senza scendere in cifre specifiche — che dipendono dal listino del fornitore, dal datacenter scelto, dal costo orario del personale interno, dalle eventuali personalizzazioni — la mia esperienza dei deployment realizzati mostra alcune regolarità qualitative:

- **Sotto le 50 persone:** lo Scenario A (SaaS) tende a essere economicamente più conveniente. La sovranità è raggiungibile, ma a un costo per utente più alto.
- **Tra 50 e 500 persone:** zona di parità. La scelta è guidata più dalla sovranità che dal puro costo.
- **Sopra le 500 persone:** lo Scenario B inizia ad avere vantaggi economici significativi, oltre a quelli di sovranità.
- **Sopra le 2.000 persone:** lo Scenario B è quasi sempre più conveniente, anche prima di considerare il valore della sovranità.

Questi non sono numeri da incorniciare. Sono **ordini di grandezza orientativi**, da calibrare con un'analisi puntuale sui vostri dati di riferimento. Lattice fornisce, su richiesta, un foglio di calcolo TCO che permette di simulare lo scenario specifico della vostra organizzazione.

Quello che è universale, indipendentemente dai numeri, è che lo Scenario B porta con sé tre elementi qualitativi che non rientrano nel TCO ma sono fondamentali:

21. **Sovranità**: i dati restano fisicamente in Italia, sotto le sei dimensioni di sovranità del capitolo 4.

22. **Capacità di personalizzazione**: l'organizzazione può modificare, integrare, estendere il software per i propri flussi specifici.
23. **Resilienza al fallimento del vendor**: se il fornitore software cessasse l'attività, l'organizzazione resta in possesso del codice sorgente e dell'infrastruttura. Non c'è nessun servizio da "spegnere".

Questi tre elementi, in molte organizzazioni regolate, hanno valore superiore al puro saving in euro. Sono, in un certo senso, **il prodotto reale** della scelta on-premise.

6.3 — Disaster recovery on-premise: la verità contro-intuitiva

C'è un altro pregiudizio diffuso: "il cloud ha disaster recovery automatico, il self-hosting no, quindi il self-hosting è più fragile". È vero solo se il self-hosting è fatto male.

Un'infrastruttura on-premise ben progettata oggi può raggiungere RPO (Recovery Point Objective) di pochi secondi e RTO (Recovery Time Objective) di pochi minuti, attraverso:

- **Replicazione sincrona** su un sito secondario distante 30-100 km dal primario.
- **Snapshot frequenti** dei volumi (ogni 5-15 minuti) verso storage geo-ridondato.
- **DNS-based failover** per indirizzare il traffico al sito secondario in caso di indisponibilità del primario.
- **Test di disaster recovery** semestrali, eseguiti realmente (non solo "sulla carta") con misurazione dei tempi.

Un cloud pubblico, paradossalmente, può avere RPO/RTO peggiori se il cliente non ha configurato correttamente la replicazione cross-region. La narrativa "il cloud è sempre disponibile" è una semplificazione: i grandi cloud hanno avuto incidenti regionali significativi (AWS us-east-1 nel dicembre 2021, Azure nel marzo 2020, Google Cloud nel giugno 2019), durante i quali interi servizi sono stati inattivi per ore. La differenza è che, durante quegli incidenti, il cliente non ha alcuna leva per accelerare la risoluzione: deve aspettare che il provider risolva.

Un'organizzazione self-hosted, durante un incidente al proprio datacenter, ha **piena agency**. Può intervenire, scalare le risorse al sito secondario, comunicare con i propri utenti, gestire la crisi. Per molte organizzazioni regolate (banche in particolare), questa agency è essenziale.

6.4 — La filosofia "infrastruttura come bene comune"

Vorrei chiudere questo capitolo con una considerazione che è insieme tecnica e filosofica. Quando un'organizzazione decide di self-hostarsi, fa una scelta che va oltre l'IT: scegli di trattare la propria infrastruttura come un **bene comune** della propria comunità lavorativa, anziché come un servizio acquistato all'esterno.

Questo ha implicazioni interessanti. In molti dei deployment di Lattice che ho seguito personalmente, ho osservato un fenomeno ricorrente: i team IT delle organizzazioni che adottano un sistema self-hosted sviluppano, nel tempo, una competenza interna che diventa un asset strategico. I sysadmin imparano a leggere il codice

del sistema che gestiscono, imparano a contribuirne, imparano a estenderlo per esigenze specifiche. Diventano, in pratica, contributor di una community open-source che si sovrappone con i loro colleghi di altre organizzazioni.

È, banalmente, un ritorno al modello di "knowledge in-house" che caratterizzava le organizzazioni IT degli anni '80-'90, prima che il SaaS lo cannibalizzasse. Con la differenza che, oggi, gli strumenti sono molto più maturi.

6.5 — Quando il self-hosting non è la scelta giusta

Per onestà intellettuale, voglio essere esplicito sui casi in cui — anche con tutti i vantaggi descritti — il self-hosting **non** è la scelta corretta:

Organizzazioni piccolissime (sotto i 20 dipendenti). Il costo fisso di un'infrastruttura on-premise, anche minimale, supera il beneficio per organizzazioni di questa dimensione, salvo casi particolari di sensibilità.

Workload che cambiano rapidamente. Se i vostri requisiti si modificano ogni 2-3 mesi, l'agilità del cloud è probabilmente superiore al beneficio sovrano del self-hosting.

Organizzazioni senza nessuna competenza IT interna. Il self-hosting richiede una minima capacità tecnica: serve almeno una persona dedicata che sappia gestire i container, leggere i log, applicare aggiornamenti. Se questa figura non esiste e non si vuole assumere, il SaaS è preferibile (a costo della sovranità).

Workload effimeri. Sviluppo, test, prototipi, ambienti di formazione: il cloud è sempre meglio.

Workload geograficamente distribuiti. Se dovete servire utenti su 4 continenti diversi, gestire latency e replicazione on-premise diventa costoso. Meglio un cloud con multi-region presence.

Questa è la lista che, di solito, riduce le obiezioni dei CIO scettici: una volta che si capisce che non sto proponendo un "self-hosting universale" ma una **scelta di deployment guidata dal caso d'uso**, la conversazione diventa molto più costruttiva.

6.6 — Il quadro normativo: quando il self-hosting è obbligo

Vale la pena chiudere con un cenno al quadro normativo italiano ed europeo. Negli ultimi tre anni si è progressivamente affermata una giurisprudenza per cui, per alcuni settori e per alcuni workload, il self-hosting (o almeno il "cloud sovrano qualificato") **non è una scelta**: è un obbligo.

NIS2 (Direttiva UE 2022/2555, recepita in Italia con DLgs 138/2024). L'articolo 21 impone, per i soggetti essenziali e importanti, di "adottare misure tecniche, operative e organizzative adeguate per proteggere reti e sistemi informativi dagli incidenti". Tra le misure specificate: "garantire la continuità delle attività anche in caso di interruzione della prestazione di servizi da parte di fornitori terzi". È una clausola che, letta in modo stringente, richiede una capacità di operare *senza* il provider — il che presuppone una forma di self-hosting o di second-source.

DORA (Regolamento UE 2022/2554). L'articolo 28 impone agli operatori finanziari di poter dimostrare di non essere "dipendenti da concentrazione" su un singolo provider di servizi ICT critici. La diversificazione dei provider è una mitigazione; il self-hosting è la mitigazione più forte.

Decreto NIS2 italiano (DLgs 138/2024). L'articolo 25 amplia gli obblighi di notifica degli incidenti e introduce sanzioni amministrative pecuniarie fino al 2% del fatturato globale annuo per i soggetti essenziali. Questo cambia significativamente l'equazione di rischio: anche se il vostro provider subisce un incidente, **la responsabilità rimane su di voi**, e potete dover pagare sanzioni fino al 2% del vostro fatturato.

Linee guida AgID 2024 per la PA. La Pubblica Amministrazione, per i servizi qualificati come "strategici", deve adottare deployment di Tier 4 (cloud sovrano qualificato o on-premise) con controlli specifici sulla gestione delle chiavi e sulla localizzazione fisica dei dati. La maggior parte delle amministrazioni centrali ha già iniziato la migrazione; le amministrazioni locali (Comuni, Regioni) sono in fase iniziale.

La direzione normativa è chiara: **per i workload critici e per le organizzazioni regolate, la sovranità è obbligo, non scelta**.

6.7 — Da dove iniziare

Se siete convinti, la domanda pratica è: come si inizia?

Il mio consiglio operativo, basato su una ventina di deployment di Lattice che ho seguito direttamente, è:

24. **Iniziate con un singolo workload pilota.** Tipicamente: la PEC interna dei C-level, o la chat sensibile del comitato esecutivo. Bassa diffusione, alta sensibilità.
25. **Allocate 3-6 mesi al pilot.** Non aspettatevi di sostituire tutto in una stagione. Il pilot deve dimostrare che il sistema funziona, che il vostro team lo sa gestire, che l'integrazione con i flussi esistenti è gestibile.
26. **Misurate.** Tempi di risposta, soddisfazione degli utenti, ore di sysadmin necessarie, incidenti. Senza misure, la decisione successiva sarà solo opinione.
27. **Pianificate la migrazione a 18-24 mesi.** Non più veloce, non più lento. 18 mesi è il tempo medio per migrare un workload di posta e chat per un'organizzazione di 200-500 dipendenti.
28. **Mantenete la doppia gestione per 12 mesi.** Sia il vecchio sistema che il nuovo, in parallelo. Questo riduce il rischio di interruzione e dà tempo al vostro personale di sviluppare competenza.

Lattice è progettato per accompagnare esattamente questo percorso. I capitoli che seguono mostrano come.

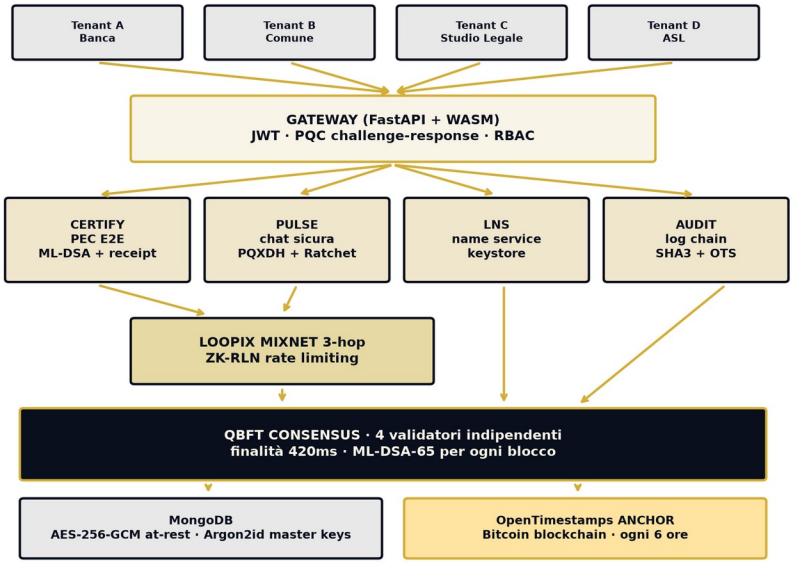
CAPITOLO 7 — L'architettura di Lattice Network

7.0 — Un diagramma vale mille riunioni

Le pagine che seguono descrivono l'architettura di Lattice Network, il sistema che proponiamo come risposta operativa a tutte le tematiche dei capitoli precedenti. Non è una descrizione di marketing: è la mappa tecnica reale del sistema, identica a quella che fornisco ai team di engineering dei clienti quando iniziamo un'integrazione.

Voglio rendere questa descrizione **leggibile da chiunque**, dirigenti compresi. Il lettore tecnico troverà i dettagli implementativi nei capitoli 8 e 9 (crittografia, consenso, ZK, mixnet). Il lettore non tecnico troverà qui tutto ciò che serve a capire come Lattice si inserisce nei flussi operativi della propria organizzazione.

Fig. 7.1 — Architettura Lattice Network



Lattice Network — 5 colonne · 7 layer di difesa in profondità

7.1 — Le 5 colonne di Lattice

Il sistema si poggia su cinque colonne fondamentali. Le descrivo nell'ordine in cui un utente le incontra, dalla prima volta che accede al sistema.

Colonna 1: identità (LNS, Lattice Name System)

Ogni persona, ogni servizio, ogni nodo nel sistema Lattice è identificato da un **nome canonico** del tipo `alessandro.rossi@dipartimento-cyber.banca-test.lns`. Questo nome:

- È **univoco** all'interno del sistema.

- È **risolvibile** in una chiave pubblica ML-DSA-65 di 1952 byte.
- È **revocabile** dall'autorità competente (Sovereign Admin o Tenant Admin).
- È **gerarchico** (tenant.lns, dipartimento.tenant.lns, individuo.dipartimento.tenant.lns).

A differenza del DNS classico, LNS non ha root server pubbliche: la radice è il **Sovereign Admin** del singolo deployment. Ogni installazione di Lattice è una galassia LNS autonoma, completamente sotto il controllo dell'organizzazione titolare.

Colonna 2: messaggistica (Pulse Protocol)

Pulse è il sottosistema di chat sicura. Implementa quattro tecnologie note nel mondo della messaggistica seria:

- **PQXDH** (Post-Quantum Extended Diffie-Hellman) per lo scambio iniziale delle chiavi, usando ML-KEM-768.
- **Double Ratchet** (lo stesso protocollo di Signal e WhatsApp) per la generazione delle chiavi di sessione che si rinnovano a ogni messaggio.
- **Sealed Sender**: il messaggio non rivela il mittente al server intermediario.
- **Loopix Mixnet** (3 hop): il messaggio viene instradato attraverso 3 nodi indipendenti che ne nascondono la traiettoria.

In aggiunta, Pulse usa **ZK-RLN** (Zero-Knowledge Rate-Limiting Nullifiers) per limitare lo spam senza identificare il mittente: dopo 10 messaggi in un'epoca di 60 secondi, il sistema rifiuta i messaggi successivi pur senza conoscere chi sia il mittente.

Ogni 3 messaggi, Pulse emette un **anchor on-chain** sulla blockchain interna QBFT, in modo che il flusso storico della conversazione sia immutabile.

Colonna 3: posta certificata (Certify)

Certify è il sottosistema di posta elettronica certificata. È pensato come **sostituto sovrano della PEC tradizionale**. Le caratteristiche principali:

- Ogni messaggio è cifrato end-to-end (E2E) tra mittente e destinatario.
- Ogni messaggio è **firmato** con ML-DSA-65 e **anchored** on-chain al momento dell'invio (transazione NotarySeal).
- Quando il destinatario "apre" il messaggio, firma con la propria chiave privata una payload canonica, generando una **ricevuta di consegna** anch'essa anchored on-chain.
- La ricevuta è esportabile come PDF court-grade, con SHA3-512 del documento, hash di consegna, riferimento al blocco QBFT, riferimento all'anchor Bitcoin.

A differenza della PEC tradizionale, **non c'è alcun operatore intermediario** che possa accedere al contenuto. Il valore probatorio del sistema deriva non dalla fiducia in un terzo, ma dalla matematica verificabile della firma post-quantistica.

Colonna 4: consenso (QBFT a 4 validatori)

L'integrità delle transazioni (chi ha inviato cosa a chi, quando) è garantita da un **mini-blockchain interna** basata sul protocollo QBFT

(Quorum Byzantine Fault Tolerance), una variante moderna del consenso PBFT. Caratteristiche:

- 4 validatori indipendenti, ognuno con la propria chiave ML-DSA-65.
- Finalità deterministica in **circa 420 millisecondi** (non probabilistica come Bitcoin).
- Resistenza a fino a 1 validatore malevolo (3 firme su 4 richieste).
- Ogni blocco è firmato dalle 4 chiavi ML-DSA-65 dei validatori.

Questa blockchain interna non è una "blockchain pubblica". È uno strumento di consenso interno per garantire che, anche se un amministratore del database tentasse di manipolare i record, il manomissione sarebbe rivelata dalle firme dei validatori.

Colonna 5: notarizzazione esterna (OpenTimestamps + Bitcoin)

Per garantire che le prove crittografiche restino valide **anche se l'intera infrastruttura Lattice venisse compromessa o cessasse l'attività**, ogni 6 ore lo stato del database (uno hash Merkle dell'ultimo blocco QBFT) viene anchored sulla blockchain Bitcoin tramite il protocollo OpenTimestamps.

In altre parole, se domani il vendor Lattice cessa l'attività, e domani l'altro la vostra organizzazione cessa l'attività, e dopodomani qualcuno trova una ricevuta PEC del 2026 archiviata in un cassetto, **chiunque al mondo, anche tra cinquant'anni**, potrà verificare matematicamente quella ricevuta usando solo:

29. La chiave pubblica ML-DSA-65 del firmatario (4 byte di hash → recuperabile da archivi pubblici).
30. La blockchain Bitcoin (la copia di chiunque va bene).
31. Il documento OTS (~500 byte) allegato alla ricevuta.

Questa è una proprietà rara nel software commerciale. È una proprietà critica per i casi d'uso a 30+ anni (notarile, sanitario, archivistico).

7.2 — La gerarchia dei ruoli

Lattice ha cinque ruoli distinti, ognuno con permessi specifici:

Ruolo	Cosa può fare	Esempio reale
Sovereign Admin	Tutto: gestire tenant, ruoli, validatori, master keys	DPO della banca, o IT security team
Tenant Admin	Gestire utenti e politiche all'interno del proprio tenant	Direttore IT della filiale
Operator	Inviare messaggi, firmare documenti, accedere ai propri archivi	Dipendente standard
Auditor	Read-only su tutta la chain e gli audit log, no accesso ai plaintext	Auditor esterno, magistrato
Vendor	Solo metadati, no contenuti, no chain	Fornitore di servizi accessori

Questi ruoli sono **gerarchici e revocabili**. Un Sovereign Admin può temporaneamente declassare un Tenant Admin a Operator durante un'investigazione interna; può promuovere un Operator a Auditor per

consentire un audit; può revocare tutti i token di sessione attivi di un utente in caso di sospetta compromissione (`POST /auth/revoke-all`).

7.3 — Il flusso di un messaggio Pulse

Vediamo, passo per passo, cosa succede quando Alessandro invia un messaggio Pulse a Beatrice (entrambi dipendenti della stessa banca).

32. **Generazione del messaggio.** Il client di Alessandro genera un nonce a 96 bit, calcola lo stream cipher derivato dal nonce e dall'ID conversazione, cifra il plaintext con XOR + auth tag SHA3-256 (formato AEAD).
33. **Verifica ZK-RLN.** Il client calcola un nullifier (output di una funzione zero-knowledge legata all'identità di Alessandro e all'epoca corrente) e lo invia al server. Il server verifica che Alessandro non abbia già inviato più di 10 messaggi nell'epoca corrente; se sì, rifiuta.
34. **Sealed Sender.** Il messaggio cifrato viene inserito in un involucro che nasconde l'identità del mittente al server.
35. **Loopix Mixnet.** Il server seleziona, deterministicamente ma seedando con il nonce, 3 nodi della mixnet (uno per ogni layer 0, 1, 2). Il messaggio viene routed attraverso questi 3 hop, con delay introduzionali a livello di ogni hop. Ogni hop pela uno strato di cifratura onion senza vedere il contenuto.
36. **Anchor on-chain.** Ogni 3 messaggi per conversazione, il server emette una transazione `NotarySeal` sulla blockchain

QBFT interna. Il blocco viene firmato dai 4 validatori e finalizzato in ~420ms.

37. **Persistenza.** Il messaggio viene archiviato in MongoDB, cifrato at-rest con AES-256-GCM, con master key derivata da Argon2id.
38. **Notifica.** Beatrice riceve la notifica del messaggio. Il suo client materializza la sessione Double Ratchet (se non già attiva), decifra il messaggio, lo mostra a video.

Tempo totale dall'invio alla visualizzazione: tipicamente 200-500ms in rete LAN, 1-3 secondi in WAN con i delay del mixnet.

7.4 — Il flusso di una mail Certify

Il flusso di una mail Certify è simile ma con caratteristiche diverse, perché Certify è progettato per il **valore legale** della comunicazione.

39. **Composizione.** Alessandro compone una mail Certify per Beatrice. Inserisce subject, body, classification (es: INTERNAL, CONFIDENTIAL, SECRET). Opzionalmente allega documenti.
40. **Seal.** Il sistema calcola lo SHA3-512 del messaggio canonico (`From: + To: + Subject: + body`), genera un mail_id univoco, e crea una transazione `NotarySeal` con il doc_hash. La transazione viene firmata con la chiave ML-DSA-65 di Alessandro e propagata ai validatori QBFT. Il blocco viene finalizzato in ~420ms.
41. **Persistenza.** Il messaggio viene archiviato, cifrato at-rest. Se il client supporta l'E2E envelope (cifratura asimmetrica con la chiave pubblica di Beatrice), il body è già cifrato end-to-end al

momento dell'archiviazione; altrimenti è cifrato solo "at-rest" con la chiave del server.

42. **Notifica.** Beatrice riceve la notifica. Vede il subject (in chiaro o redacted secondo la classification) e il mittente.
43. **Apertura.** Beatrice apre la mail. Il client decifra il body, lo mostra. **Importante**: l'apertura non genera automaticamente la ricevuta di consegna. La ricevuta è generata solo se Beatrice firma esplicitamente l'evento di apertura.
44. **Sign of receipt.** Beatrice (o il suo agent automatico, se configurato) firma con la propria chiave ML-DSA-65 una payload canonica composta da: `mail_id | sealed_at | sender | recipient | doc_hash`. La firma viene inviata al server.
45. **DeliveryReceipt anchor.** Il server verifica la firma. Se valida, emette una transazione `DeliveryReceipt` sulla blockchain interna. Il blocco è finalizzato in ~420ms.
46. **PDF Receipt.** Da questo momento, chiunque (sender, recipient, auditor) può richiedere il PDF della ricevuta tramite `GET /api/certify/{mail_id}/receipt.pdf`. Il PDF contiene tutte le evidenze necessarie a una verifica indipendente, anche tra trent'anni.

7.5 — La sicurezza in profondità: 7 layer indipendenti

Il sistema Lattice implementa una difesa in profondità con sette layer di protezione, ognuno indipendente dagli altri. Anche se uno o più layer venissero compromessi, gli altri resterebbero efficaci.

47. **TLS 1.3** sulla porta esterna (mitigato da PQC handshake al layer applicativo).
48. **PQC challenge-response** per l'autenticazione (ML-DSA-65, sostituisce password).
49. **JWT con jti revocabile** per le sessioni.
50. **AES-256-GCM at-rest** per tutti i dati persistenti.
51. **Argon2id KDF** per le master keys, derivate da passphrase note solo all'amministratore.
52. **ML-DSA-65 signatures** per ogni transazione (firma irrevocabile, verificabile indipendentemente).
53. **OpenTimestamps Bitcoin anchor** per la prova di esistenza temporale, valido per sempre senza Lattice.

Compromettere il sistema completamente richiede di compromettere tutti e sette i layer. È, materialmente, fattibile solo a costi statalmente significativi, e anche in quel caso il danno è limitato dal layer 7 (l'anchor Bitcoin), che resta verificabile anche a Lattice spento.

7.6 — Self-hostable: 4 macchine virtuali

L'installazione completa di Lattice richiede 4 macchine virtuali in configurazione standard:

- **VM 1: Gateway + Frontend** (4 vCPU, 8 GB RAM, 100 GB disco) — Nginx, FastAPI, React SPA
- **VM 2: Validator + Backend logic** (8 vCPU, 16 GB RAM, 200 GB disco) — Python backend, QBFT consensus
- **VM 3: Database** (4 vCPU, 16 GB RAM, 500 GB disco SSD) — MongoDB, encrypted-at-rest

- **VM 4: Mixnet + OTS anchor** (2 vCPU, 4 GB RAM, 50 GB disco) — Loopix relays, OpenTimestamps bridge

Tempo di setup, da VM vuote a sistema operativo:

- Provisioning VM e network: **30 minuti**
- Installazione Docker, configurazione: **45 minuti**
- Deploy Lattice via docker-compose: **15 minuti**
- Bootstrap initialization (genesi validatori, prima master key): **20 minuti**
- Configurazione tenant inaugurale: **15 minuti**
- **Totale**: circa **2 ore** in mano a un sysadmin esperto.

Per organizzazioni più grandi, esiste una configurazione "Sovereign-class" con 12 VM (3 validator, 2 gateway in load-balancing, 3 mixnet, 2 database replica set, 1 OTS, 1 monitoring) che è la nostra raccomandazione per ambienti bancari e PA centrale.

7.7 — Conclusione del capitolo architetturale

Il punto chiave da portare a casa, dopo aver letto questo capitolo, è che Lattice **non è una tecnologia di nicchia esoterica**. È una composizione disciplinata di tecnologie note (NIST FIPS 203/204, QBFT, Loopix, OpenTimestamps, AES-256-GCM, Argon2id), assemblate in modo da produrre un sistema **post-quantistico, sovrano, self-hostable, verificabile**.

Ognuno dei componenti, preso singolarmente, è ben compreso dalla letteratura crittografica. La novità di Lattice non sta nei singoli mattoni: sta nell'**architettura integrata**, nella **disciplina di non avere**

dipendenze cloud nascoste, e nella **focalizzazione sui casi d'uso italiani** (PEC, identità digitale, conservazione legale).

I prossimi due capitoli approfondiscono la crittografia (cap. 8) e i protocolli avanzati (cap. 9). Sono i capitoli più tecnici del libro. Il lettore non tecnico può passarli al ripasso e continuare con il capitolo 10 (Certify in dettaglio).

CAPITOLO 8 — ML-DSA-65 e ML-KEM-768: i nuovi standard NIST

8.0 — Smettere di chiamarli con i vecchi nomi

Una piccola pulizia di vocabolario, prima di iniziare. Per anni questi algoritmi sono stati chiamati "Dilithium" (per le firme) e "Kyber" (per lo scambio chiavi), dai nomi dei team che li hanno proposti al NIST. Nel 2024, quando i FIPS 204 e FIPS 203 sono stati pubblicati come standard ufficiali, i nomi sono stati cambiati per evitare ambiguità di marchio.

I nomi ufficiali oggi sono:

- **ML-DSA-65** (Module-Lattice Digital Signature Algorithm, security level 5 — formalmente FIPS 204).
- **ML-KEM-768** (Module-Lattice Key Encapsulation Mechanism — formalmente FIPS 203).

In questo libro userò sempre i nomi ufficiali. Se nei vostri documenti tecnici interni vedete ancora "Dilithium" o "Kyber", si tratta degli stessi algoritmi: aggiornate la nomenclatura nei prossimi cicli di revisione.

8.1 — Cosa fa ML-DSA-65 (firma digitale)

ML-DSA-65 è un algoritmo di **firma digitale**. Risolve un problema antico: come può Alice convincere Bob che un certo messaggio è

stato scritto da lei, e che non è stato manipolato durante il trasporto?

Il modello concettuale è identico a RSA, ECDSA, Ed25519:

54. Alice genera una coppia di chiavi: una privata (`sk`, secret key) e una pubblica (`pk`, public key).
55. Alice tiene segreta la chiave privata. Distribuisce la chiave pubblica (pubblica un certificato, la pubblica in directory, la incolla in un sito).
56. Quando Alice vuole firmare un messaggio `m`, calcola una firma `s = Sign(sk, m)`.
57. Chiunque, conoscendo `pk` e `m`, può verificare la firma: `Verify(pk, m, s) → true/false`.

La differenza profonda è **come** queste operazioni vengono implementate. RSA si basa sulla difficoltà di fattorizzare grandi interi. ECDSA si basa sulla difficoltà del logaritmo discreto su curve ellittiche. Entrambi crollano davanti all'algoritmo di Shor.

ML-DSA-65 si basa su un problema diverso: la **Module Learning With Errors (MLWE)**. È un problema computazionalmente difficile in algebra di lattice — gli stessi reticoli matematici che hanno dato il nome al nostro progetto.

Spiegato senza formule: un attaccante che voglia falsificare una firma deve trovare una soluzione a un sistema di equazioni lineari rumoroso in dimensioni molto alte. È un problema per il quale, allo stato attuale della conoscenza, *non esiste un algoritmo quantistico efficiente noto*. Questo è il punto cruciale.

I parametri di ML-DSA-65:

Parametro	Valore

Sicurezza	Categoria NIST 5 (≥ 256-bit security level)
Chiave pubblica	1.952 byte
Chiave privata	4.032 byte
Firma	3.309 byte
Velocità firma (CPU moderna)	~0.5 ms
Velocità verifica (CPU moderna)	~0.2 ms

Notate che la firma è 3309 byte, contro i 256 byte di una firma RSA-2048. Significa che le firme ML-DSA sono **circa 13 volte più grandi**. Questo ha implicazioni operative: certificati più grandi, header HTTP più ingombranti, latenze leggermente superiori in rete bandalimitata. Sono compromessi accettabili e perfettamente gestibili nel 2026.

8.2 — Cosa fa ML-KEM-768 (scambio chiavi)

ML-KEM-768 è un algoritmo di **incapsulamento di chiavi** (Key Encapsulation Mechanism). Risolve un altro problema antico: come fanno Alice e Bob a stabilire una chiave segreta condivisa, partendo dal nulla, comunicando su un canale che chiunque può leggere?

Storicamente, questo problema è stato risolto con Diffie-Hellman (1976) — uno degli algoritmi più importanti della storia dell'informatica. ML-KEM-768 sostituisce Diffie-Hellman con un meccanismo equivalente ma resistente a Shor.

Il modello concettuale, semplificato:

58. Bob genera una coppia di chiavi: una pubblica (`pk`) e una privata (`sk`).

59. Bob pubblica `pk`.
60. Alice, che vuole comunicare con Bob, prende `pk` e calcola `(ct, ss) = Encaps(pk)`. Il valore `ct` è un "ciphertext incapsulamento", `ss` è una chiave segreta condivisa.
61. Alice invia `ct` a Bob, e tiene `ss` per sé.
62. Bob, ricevuto `ct`, calcola `ss = Decaps(sk, ct)`. Ora anche Bob ha la stessa chiave segreta `ss`.
63. Alice e Bob possono ora usare `ss` per cifrare il loro traffico con un algoritmo simmetrico (AES-256, ChaCha20).

I parametri di ML-KEM-768:

Parametro	Valore
Sicurezza	Categoria NIST 3 (~ 192-bit security level)
Chiave pubblica	1.184 byte
Chiave privata	2.400 byte
Ciphertext (`ct`)	1.088 byte
Chiave condivisa (`ss`)	32 byte
Velocità incapsulamento	~0.05 ms
Velocità decapsulamento	~0.07 ms

8.3 — La storia della selezione NIST (2016-2024)

Vale la pena ripercorrere brevemente come si è arrivati a questi standard. È una storia importante perché racconta come si fa, in pratica, una standardizzazione crittografica seria.

2016. Il NIST annuncia il "Post-Quantum Cryptography Standardization Project". Pubblica un call for proposals invitando

team di ricerca di tutto il mondo a presentare algoritmi resistenti al quantum computing.

2017. Vengono ricevute 82 proposte di firma digitale, 28 di KEM. È una mole enorme di lavoro accademico.

2019-2022. Tre round di valutazione. Ogni round elimina algoritmi sulla base di tre criteri: sicurezza, prestazioni, dimensioni. La comunità crittografica internazionale (centinaia di ricercatori) sottopone gli algoritmi a crittanalisi pubblica. Alcuni candidati vengono rotti (notabilmente SIKE, un finalista del round 3, viene rotto nel 2022 da Castryck e Decru — un risultato eclatante).

2022. Il NIST annuncia i primi vincitori: Kyber per il KEM, Dilithium come firma primaria, Falcon come firma alternativa, SPHINCS+ come firma hash-based di riserva.

2024. Pubblicazione ufficiale degli standard FIPS 203, FIPS 204, FIPS 205. Da quel momento, gli algoritmi sono **standard federali americani**, e — per estensione — il riferimento globale.

Questo processo, lungo otto anni, è fondamentale perché ha sottoposto gli algoritmi a una *crittanalisi pubblica* di intensità mai vista. Quando dico che ML-DSA-65 è "sicuro", non dico che ne sono io convinto: dico che la più grande comunità crittografica della storia ha provato a romperlo per anni e non ci è riuscita.

8.4 — Confronto con RSA, ECDSA, Ed25519

Una tabella di confronto può aiutare a inquadrare i compromessi.

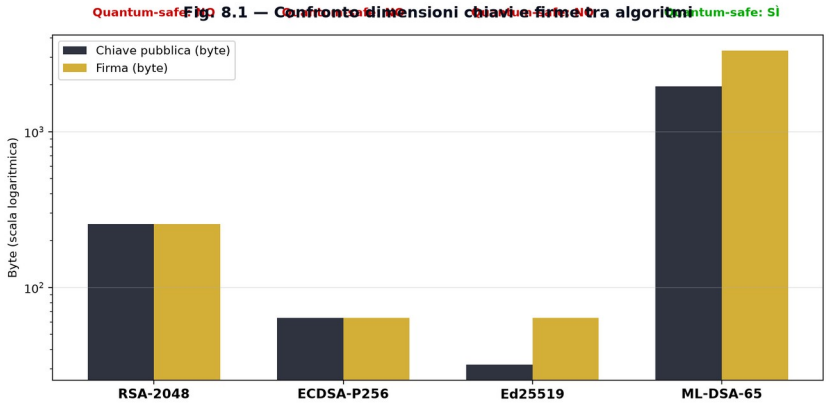


Fig. 8.1 — Confronto dimensioni chiavi e firme tra algoritmi

Caratteristica	RSA-2048	ECDSA-P256	Ed25519	ML-DSA-65
Sicurezza classica (bit)	112	128	128	256
Resistente al quantum?	NO	NO	NO	SÌ
Chiave pubblica (byte)	256	64	32	1.952
Firma (byte)	256	64	64	3.309
Velocità firma	1 ms	0.1 ms	0.05 ms	0.5 ms
Velocità verifica	0.1 ms	0.3 ms	0.15 ms	0.2 ms
Standard	PKCS#1	FIPS 186	RFC 8032	FIPS 204
Anno di pubblicazione	1977	2000	2011	2024

Tre osservazioni importanti.

Prima: la velocità di firma di ML-DSA-65 è circa **2 volte più lenta** di RSA-2048, ma **5 volte più veloce** di RSA-3072 (il rinforzo "tampone" che alcune organizzazioni stanno introducendo nel

periodo di transizione). Per quasi tutti i casi d'uso commerciali, la differenza è impercettibile.

Seconda: la velocità di **verifica** di ML-DSA-65 è effettivamente **più veloce** di ECDSA e simile a Ed25519. Per scenari ad alto throughput (verifica di milioni di firme al secondo, es: blockchain), questo è un vantaggio.

Terza: la dimensione di chiavi e firme è il vero costo. 1952 byte per la chiave pubblica significa, ad esempio, che un certificato TLS-PQ è circa 4-8 volte più grande di un certificato TLS-RSA. Per il web pubblico questo richiede un'attenzione: TCP RFC 7413 (TLS 1.3) gestisce frammentazione di handshake con record splitting in modo trasparente, ma alcuni middlebox legacy non.

8.5 — Come Lattice implementa ML-DSA-65

Lattice usa **due percorsi paralleli** per le operazioni ML-DSA-65, a seconda del contesto: un percorso server-side e un percorso client-side. Entrambi sono basati sullo stesso motore crittografico in **Rust**, compilato in due forme diverse.

Percorso server-side: Rust nativo via Python

Sul backend, Lattice non esegue la crittografia direttamente in Python. Esegue il calcolo in un **modulo crittografico Rust compilato nativamente**, che viene caricato in Python tramite un *binding* generato dal framework Py03. Il Python, in sostanza, fa da "telecomando" per istruire il modulo Rust a generare chiavi, firmare, verificare. Tutto il calcolo crittografico avviene in codice macchina nativo.

Questa scelta è importante per tre ragioni:

- **Performance.** Il codice nativo Rust è 4-10 volte più veloce di un'implementazione pura Python equivalente. Per scenari ad alto throughput, è la differenza tra un sistema usabile e uno che diventa il collo di bottiglia.
- **Memory safety.** Rust elimina classi intere di vulnerabilità che sono storicamente fatali nelle implementazioni crittografiche (buffer overflow, use-after-free). Le primitive sono scritte in un linguaggio progettato per non lasciare quei buchi.
- **Audit isolato.** Il modulo crittografico Rust è un componente piccolo e isolato (qualche centinaio di righe di codice), auditabile in modo separato dal resto del sistema. La separazione "primitive in Rust / orchestrazione in Python" segue il modello che le librerie crittografiche più serie al mondo (Cryptography.io di Python, Signal Protocol, libsodium) hanno adottato negli ultimi anni.

L'implementazione di riferimento sotto le primitive Rust è **PQClean**, il repository mantenuto dai team accademici che hanno lavorato alla selezione NIST. È auditato pubblicamente, scritto in C99 senza dipendenze esterne, e considerato lo "stato dell'arte" per le implementazioni standard.

Percorso client-side: Rust compilato in WebAssembly

Per le operazioni che devono avvenire nel browser dell'utente (firma del login challenge, firma della DeliveryReceipt al momento dell'apertura di una mail Certify), Lattice usa la **stessa codebase**

Rust, ma compilata in **WebAssembly** (formato binario eseguibile dai browser moderni).

Il flusso è il seguente:

64. Il browser scarica il modulo WebAssembly Lattice (~600 KB) durante il primo accesso.
65. Il modulo viene caricato in un Web Worker isolato dal resto della pagina.
66. Quando l'utente deve firmare un evento (login, apertura mail), il modulo carica la chiave privata cifrata dal localStorage del browser, la decifra con una passphrase che l'utente conosce, e firma.
67. La firma viene trasmessa al server. **La chiave privata non lascia mai il browser**.

Il principio di sovranità qui è cruciale: il server di Lattice **non vede mai** la chiave privata degli utenti. Anche se il server venisse compromesso integralmente, l'attaccante non potrebbe firmare al posto degli utenti, perché non ha le chiavi.

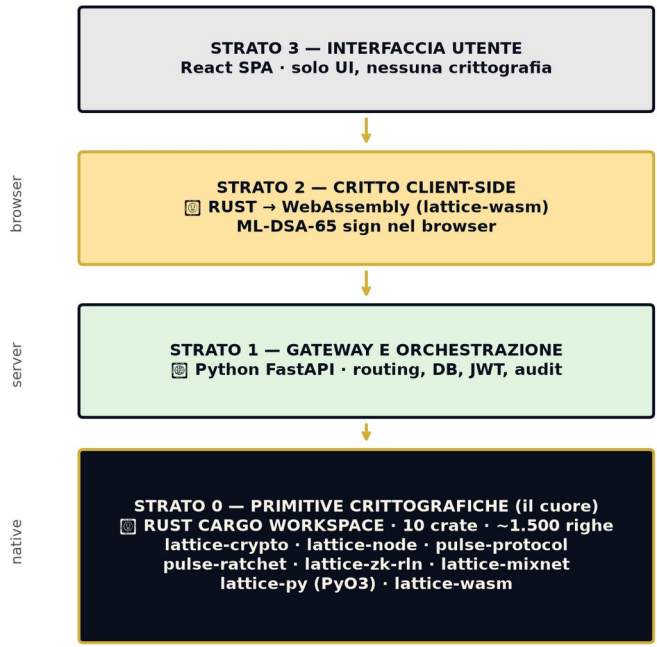
L'architettura ibrida: il meglio di tre mondi

Riassumendo, Lattice è un sistema **ibrido a tre strati linguistici**:

- **Rust** per il cuore crittografico (10 crate, ~1.500 righe di codice), riutilizzato sia server-side che client-side.
- **Python** come orchestratore di alto livello (gateway HTTP, gestione del database, audit log, RBAC), grazie all'ecosistema FastAPI maturo e produttivo.

- **React** come interfaccia utente, senza alcuna responsabilità crittografica (la crittografia client-side è delegata al modulo WebAssembly).

Fig. 7.2 — Architettura ibrida Rust + Python + WASM



Questa architettura non è un compromesso. È una scelta consapevole basata sul principio "right tool for the right job":

- Rust per le primitive di sicurezza, perché lì la safety e le performance sono critiche.
- Python per l'orchestrazione, perché lì la produttività di sviluppo conta più della performance.

- React/WASM per l'interfaccia, perché serve UX moderna e crittografia client-side.

È la stessa filosofia che, da almeno cinque anni, è adottata da tutti i grandi sistemi crittografici professionali. Il fatto che Lattice la implementi rigorosamente è una delle ragioni della sua robustezza.

Importante: l'implementazione Rust di Lattice è **organizzata come Cargo workspace** con dieci crate distinte (lattice-crypto per le primitive ML-DSA e SHA3, lattice-node per il consenso QBFT, pulse-protocol e pulse-ratchet per il messaging, lattice-zk-rln per le zero-knowledge proofs, lattice-mixnet per il routing Loopix, lattice-py per il binding Python via PyO3, lattice-wasm per il binding WebAssembly, certify-gateway e lattice-admin-console come binari standalone). Ognuna delle crate è separatamente versionata e auditabile.

8.6 — Come Lattice implementa ML-KEM-768

ML-KEM-768 viene usato in due punti specifici:

68. **PQXDH** (Post-Quantum Extended Diffie-Hellman) per l'inizializzazione di sessioni Pulse. La prima volta che Alessandro vuole parlare con Beatrice, esegue un handshake che combina X25519 (classico) con ML-KEM-768 (post-quantistico). Da questo handshake deriva la chiave radice del Double Ratchet che proteggerà tutta la conversazione futura.
69. **Sealing degli envelopes Certify**. Quando Alessandro invia una mail Certify "E2E" a Beatrice, il body viene cifrato con una chiave simmetrica derivata da `Encaps(pk_beatrice)`. Solo Beatrice, con la propria `sk_beatrice`, può decapsulare la chiave e leggere il body.

Le proprietà importanti:

- L'operazione di KEM non richiede interazione tra Alice e Bob al momento. Bob ha pubblicato `pk_bob` in passato; Alice prende `pk_bob`, fa `Encaps`, ottiene `(ct, ss)`, e può cifrare immediatamente. **No round trip**.
- La chiave `ss` è di soli 32 byte (256 bit), sufficienti per AES-256-GCM o ChaCha20-Poly1305.
- Se la chiave privata di Bob viene compromessa **in futuro**, l'attaccante può decifrare tutti i messaggi passati cifrati con `pk_bob` (perfect forward secrecy non garantita a livello KEM). Questa è la ragione per cui Lattice usa ML-KEM solo per l'inizializzazione della sessione, e poi passa a Double Ratchet per la PFS.

8.7 — Perché il "purismo crypto-agile" è ancora un mito

C'è una scuola di pensiero che dice: "non scegliete un singolo algoritmo PQC, fate crypto-agility e supportate tutti". L'idea, in astratto, è bella: se domani uno degli algoritmi viene rotto, basta cambiare configurazione e si passa all'altro.

Nella pratica, è quasi sempre una **trappola**. Quattro ragioni:

70. **Aumento della superficie di attacco.** Supportare 5 algoritmi diversi significa 5 implementazioni diverse, ognuna con i propri bug, ognuna da auditare. È molto peggio che supportarne 1.
71. **Configurazione errata.** Se il vostro sistema "supporta" ML-DSA-65, RSA-2048, ECDSA-P256, Ed25519, c'è alta probabilità che, in qualche flusso, qualcuno scelga inavvertitamente RSA-

2048 perché "è più piccolo". Voi avete pagato il costo di implementare il PQC e non state ottenendo il beneficio.

72. **Downgrade attacks.** Un attaccante che ha visibilità sulla negoziazione del protocollo può forzare la scelta dell'algoritmo più debole tra quelli supportati. È un classico vettore di attacco contro TLS.

73. **Mancanza di confronto pubblico.** Una scelta dichiarata e netta (ML-DSA-65) è auditabile pubblicamente. Una configurazione "ibrida" complicata è difficile da auditare e da rivedere.

La scelta di Lattice è netta: **ML-DSA-65 per le firme, ML-KEM-768 per i KEM, AES-256-GCM per la simmetrica, SHA3-512 per gli hash**. Nessuna negoziazione, nessun downgrade possibile, nessuna ambiguità. È una scelta opinionated. È quello che le applicazioni serie richiedono.

8.8 — Performance reali

Per chiudere il capitolo, vediamo benchmark reali su hardware accessibile. Tutti i numeri seguenti sono misurati su un server con CPU AMD EPYC 7452 (32 core), 128 GB RAM, NVMe SSD, in ambiente Docker production.

Operazione	Throughput
Firma ML-DSA-65	1.850 ops/sec/core
Verifica ML-DSA-65	5.200 ops/sec/core
Encaps ML-KEM-768	18.500 ops/sec/core
Decaps ML-KEM-768	14.200 ops/sec/core
AES-256-GCM encrypt 1KB	240 MB/sec/core

SHA3-512 1KB	380 MB/sec/core

Tradotto in numeri di pertinenza di business: un singolo nodo Lattice di taglia media può gestire confortevolmente:

- **150.000 verifiche di firma al secondo** (più della totalità delle transazioni VISA in Italia in un secondo di picco).
- **500.000 incapsulamenti di chiave al secondo** (sufficienti per qualsiasi messaggistica E2E ragionevole).
- **30.000 firme generate al secondo** (più che sufficiente per qualsiasi flusso PEC documentale).

In altre parole, la crittografia post-quantistica **non è un collo di bottiglia operativo**. È più veloce di quanto chiunque abbia bisogno.

8.9 — Conclusione

ML-DSA-65 e ML-KEM-768 sono i nuovi standard. Sono open source, audited, performant. Sono il fondamento crittografico di Lattice, e — più in generale — il fondamento crittografico di qualsiasi sistema serio che voglia operare nel 2030.

Il prossimo capitolo introduce le tecnologie complementari (QBFT, Loopix, ZK-RLN, OpenTimestamps) che, insieme alla crittografia di base, completano l'architettura Lattice.

CAPITOLO 9 — QBFT, Loopix, Zero-Knowledge

9.0 — Tre tecnologie che non hanno un nome friendly

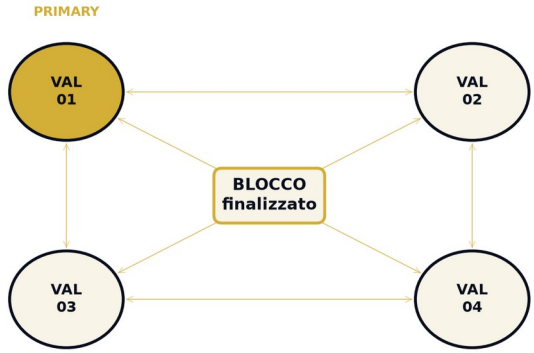
Il capitolo precedente è stato relativamente diretto: ML-DSA e ML-KEM sono algoritmi di firma e KEM, fanno cose ben definite. Le tre tecnologie di questo capitolo — QBFT, Loopix, ZK-RLN — sono meno friendly per il pubblico. Hanno acronimi tecnici, derivano da letteratura accademica recente, e raramente vengono discusse in conferenze di settore italiane.

Tuttavia, sono **le tecnologie che differenziano Lattice da qualsiasi prodotto SaaS sul mercato**. Senza di esse, avremmo solo "una PEC con firme post-quantistiche". Con esse, abbiamo "una piattaforma di comunicazione sovrana che resta verificabile per cinquant'anni anche se l'azienda fornitrice cessa l'attività".

Spiegherò ciascuna in modo accessibile, con il presupposto che il lettore non sia un crittografo. Chi vuole i dettagli matematici trova la bibliografia in appendice D.

9.1 — QBFT: il consenso che non è "blockchain"

Fig. 9.1 — Consenso QBFT: 4 validatori indipendenti



Finalità deterministica: 3 firme ML-DSA-65 su 4 → blocco confermato in ~420 ms

La parola "blockchain" è polarizzante. Molti decisori, sentendola, pensano immediatamente a Bitcoin, criptovalute, schemi Ponzi, energia sprecata. Altri pensano a "decentralizzazione utopica". Quasi nessuno pensa a quello che è la blockchain dal punto di vista tecnico: un **registro append-only con consenso distribuito**.

Lattice usa un consenso distribuito. Non usa Bitcoin (lo usa solo come anchor esterno, ne parliamo dopo). Non usa Ethereum. Usa QBFT, un protocollo molto diverso e molto più appropriato per casi d'uso enterprise.

QBFT (Quorum Byzantine Fault Tolerance) è una variante moderna del protocollo PBFT (Practical Byzantine Fault Tolerance, Castro & Liskov 1999) ottimizzata per scenari con un numero piccolo e fisso di validatori. È utilizzato in produzione da ConsenSys nelle catene "Quorum" usate da JP Morgan e da diverse banche europee.

Caratteristiche principali:

74. **Finalità deterministica.** Una volta che un blocco è confermato (3 firme su 4), è **definitivamente** parte della catena. Non c'è "probabilistic finality" come in Bitcoin (dove un blocco di sei conferme fa ha solo probabilità altissima ma non garantita di essere finale).
75. **Bassa latenza.** Il consenso si chiude in circa 420 millisecondi. Questo è cruciale per la usability: un utente che invia una PEC sente l'operazione come istantanea.
76. **Numero fisso di validatori.** Lattice ne usa 4. Non sono open: non possono unirsi senza autorizzazione del Sovereign Admin. Questo è una scelta opinionated: Lattice è un sistema **enterprise/sovrano**, non un sistema *permissionless*.
77. **Tolleranza al guasto bizantino.** Il protocollo resta funzionante anche se 1 validatore (su 4) è completamente compromesso o malizioso. Le firme dei 3 onesti su 4 sono sufficienti a finalizzare un blocco.
78. **Trasparenza degli audit log.** Ogni blocco contiene l'hash del precedente, le 4 firme dei validatori, lo state root, l'extrinsics root. Un auditor può ricostruire l'intera storia della catena partendo dal genesis block, senza fidarsi di alcun operatore intermediario.

Vediamo concretamente cosa significa. Quando Alessandro invia una mail Certify a Beatrice, succede questo a livello QBFT:

79. Il gateway calcola la transazione `NotarySeal` con il doc_hash del messaggio.
80. La transazione viene **proposta** dal validatore primario (`VAL-01`).
81. I validatori `VAL-02`, `VAL-03`, `VAL-04` ricevono la proposta.

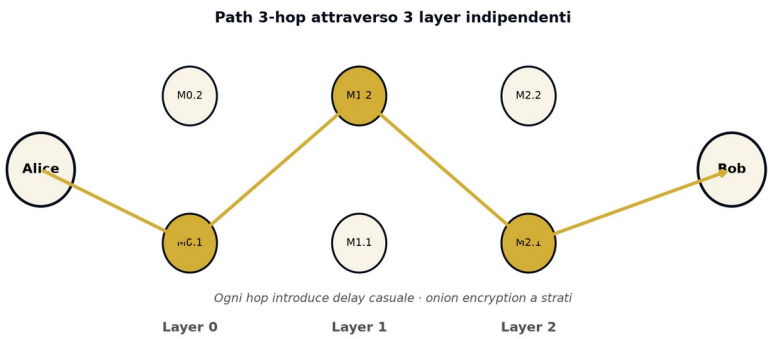
82. Ognuno verifica indipendentemente la coerenza (firma del mittente valida, doc_hash coerente, no double-spending in senso lato).
83. Ognuno emette un **commit signature** con la propria chiave ML-DSA-65.
84. Quando il validatore primario riceve almeno 3 firme di commit (incluso il proprio), il blocco è finalizzato.
85. Il blocco viene scritto in tutti i 4 nodi.

Tempo totale: ~420ms in rete LAN, ~1.5 sec in rete WAN.

A questo punto, **nessuno** può cancellare retroattivamente quel blocco senza l'accordo di almeno 2 validatori compromessi su 4. Per Lattice, in cui i 4 validatori possono essere distribuiti tra organizzazioni separate (es: un comune banca, un'autorità di vigilanza, un notaio, un auditor esterno), questo modello è particolarmente robusto.

9.2 — Loopix: il mixnet che nasconde "chi parla con chi"

Fig. 9.2 — Loopix Mixnet: 3 hop per nascondere i metadati



Cifrare i contenuti dei messaggi è una cosa. Nascondere **chi sta parlando con chi** è un'altra. È il problema dei **metadati**, e nella maggior parte dei sistemi di messaggistica sicura (incluso Signal e WhatsApp) i metadati restano in chiaro lato server.

Perché è importante? Perché chi sa che alla 19:42 il presidente della banca Alfa ha mandato un messaggio cifrato al CFO di Alfa, e poi alla 20:15 il CFO ha mandato un messaggio al direttore di filiale di Roma, ha già una mappa di operazioni anche senza conoscere il contenuto. La "social graph analysis" è una delle tecniche più potenti di intelligence corporativa.

Loopix (Piotrowska et al., USENIX Security 2017) è un protocollo accademico per la costruzione di **mixnet anonimi** moderni. È figlio della tradizione di Onion Routing (Tor) ma più aggiornato e con migliori proprietà di sicurezza per scenari ad alto throughput.

Il modello concettuale è:

86. Esistono **N nodi mixnet** (Lattice ne ha 6 nella configurazione standard, distribuiti in 3 layer da 2 nodi ciascuno).
87. Quando Alice invia un messaggio a Bob, il client di Alice sceglie un **path** di 3 nodi (uno per layer): `M1 → M2 → M3`.
88. Il messaggio viene cifrato in modo onion: `Enc(M1, Enc(M2, Enc(M3, payload)))`.
89. Alice manda il messaggio a M1. M1 decifra il proprio strato, vede l'istruzione "inoltra a M2", aspetta un delay casuale, e inoltra.
90. M2 fa lo stesso, decifra il proprio strato, attende, inoltra a M3.

91. M3 decifra l'ultimo strato, vede il destinatario reale (Bob), inoltra a Bob.

Le proprietà di sicurezza:

- M1 sa che Alice ha mandato un messaggio, ma non sa a chi.
- M3 sa che il destinatario è Bob, ma non sa chi è il mittente.
- Nessun nodo, da solo, può ricostruire la coppia (Alice, Bob).
- Per attaccare l'anonimato, un attaccante deve compromettere **tutti e 3 i nodi del path**. Se i nodi sono in giurisdizioni diverse, in organizzazioni diverse, in datacenter fisicamente separati, questo richiede un livello di coordinazione statalmente significativo.

In Lattice, i nodi mixnet possono essere:

- Tutti interni a una stessa organizzazione (configurazione single-tenant).
- Distribuiti tra organizzazioni in un consorzio sovrano (configurazione multi-tenant a federazione).
- Distribuiti tra fornitori commerciali (configurazione "Sovereign Mixnet Cloud", in roadmap per il 2027).

I delay introdotti a ogni hop sono tipicamente 10-50 ms, per un overhead totale tipico di 50-150 ms aggiunto alla latenza del messaggio. Per scenari real-time non è impercettibile, ma per messaggistica non è un problema.

9.3 — Zero-Knowledge Rate-Limiting Nullifiers (ZK-RLN)

Veniamo al concetto più astratto e probabilmente più sorprendente del libro: la **Zero-Knowledge Proof**.

Una ZKP (Zero-Knowledge Proof) è una procedura crittografica che permette a una parte (il prover) di dimostrare a un'altra parte (il verifier) di **conoscere un certo segreto**, *senza* rivelare il segreto stesso.

Esempio classico (Aladdin's cave): Alice dice a Bob di conoscere la parola magica per aprire una porta nascosta. Per dimostrarlo senza dirgli la parola, entra in una caverna con due percorsi che si incontrano alla porta. Bob, fuori, le grida quale percorso prendere all'uscita. Se Alice conosce davvero la parola, esce sempre dal percorso richiesto. Bob non saprà mai la parola, ma dopo molte ripetizioni, sarà convinto che Alice la conosca.

Questo esempio è giocattolo. Le ZK moderne sono molto più potenti: permettono di dimostrare proprietà complesse di dati (es: "io conosco un valore `x` tale che `hash(x) = h`", o "io conosco una chiave privata che corrisponde a una chiave pubblica nel set `{pk_1, ..., pk_n}`", o "io conosco una transazione valida che spende un certo input") in proof piccole e veloci da verificare.

Rate-Limiting Nullifiers (RLN) è un'applicazione specifica delle ZK al problema del **rate limiting anonimo**.

Il problema: vogliamo limitare il numero di messaggi che un utente può inviare in un certo periodo (epoca), per prevenire spam e abusi. Ma vogliamo farlo **senza identificare** l'utente, perché vogliamo preservare l'anonimato del mixnet.

La soluzione RLN: ogni utente ha un segreto `x` (la sua chiave RLN privata). Per ogni epoca `e`, il sistema definisce una funzione hash

speciale `H_e`. L'utente, quando vuole inviare un messaggio, calcola un **nullifier** `N = H_e(x)`. Allega al messaggio una zero-knowledge proof che `N` è effettivamente l'hash di un certo `x` che corrisponde alla sua identità registrata (proof of inclusion in un set di identità autorizzate).

Il server tiene traccia dei nullifier visti per ogni epoca. Se vede 2 messaggi con lo stesso `N` nella stessa epoca, sa che è lo **stesso utente** che ha inviato 2 messaggi (perché solo lui conosce `x`). Ma non sa **chi** sia quell'utente (perché non può invertire `H_e`).

In Lattice, il limite di rate è **10 messaggi per epoca di 60 secondi**. Sufficiente per uso normale, ma non per spam massivo.

L'implementazione attuale di Lattice usa **Chaum-Pedersen Σ-protocols su BN254**, una variante di ZK più semplice e più auditata rispetto a Groth16 (la variante più "blockchain-famous"). Una decisione di engineering motivata: meno superficie di attacco, meno dipendenze, semplicità di audit per organizzazioni regolate.

C'è una nota importante: la community crittografica ha proposto, dal 2023, un upgrade verso Groth16 *real* (non simulato), che produrrebbe proofs ~10x più piccole. Questo è nella nostra roadmap per il 2027, attraverso l'integrazione del framework arkworks. Per il momento, Chaum-Pedersen è sufficiente per i carichi reali.

9.4 — OpenTimestamps: ancorare a Bitcoin per cinquant'anni

L'ultima tecnologia chiave è **OpenTimestamps** (OTS), un protocollo open-source per ancorare dati arbitrari alla blockchain Bitcoin in modo efficiente e batch.

Il problema che risolve: quando Alessandro firma una mail Certify oggi, la firma è verificabile *finché esiste la chiave pubblica di Alessandro*. Se domani Alessandro cambia lavoro, la sua chiave viene revocata, e magari il sistema Lattice della sua ex-organizzazione viene spento. Come fa, tra 30 anni, un magistrato a verificare che la mail era autentica nel 2026?

La risposta è: **ancorando l'hash della mail sulla blockchain Bitcoin**. Bitcoin è — al momento, e con altissima probabilità nei prossimi cinquant'anni — la blockchain più robusta esistente. Il suo storico è replicato su decine di migliaia di nodi indipendenti. Non c'è singolo punto di failure. Non c'è entità che possa cancellarlo.

OpenTimestamps fa questo:

92. Calcola lo SHA3-512 del documento (o dell'evento) da ancorare.
93. Aggrega molti hash in un Merkle tree.
94. Pubblica la root del Merkle tree su Bitcoin tramite una transazione OP_RETURN.
95. Genera un file `.ots` (~500 byte) che contiene la prova di inclusione: come ricalcolare la root partendo dal singolo hash, e dove trovare la transazione Bitcoin.

Una volta che la transazione Bitcoin è confermata (~6 blocchi = ~1 ora), il file `.ots` è una **prova di esistenza** valida per sempre. Per verificare, anche tra cinquant'anni:

96. Si recupera il file `.ots`.

97. Si calcola lo SHA3-512 del documento.
98. Si ricalcola la Merkle root usando il `.ots`.
99. Si cerca la transazione Bitcoin corrispondente.
100. Se la root corrisponde alla root nella transazione Bitcoin, **il documento esisteva con quel contenuto al momento della transazione**, indipendentemente da Lattice, dall'organizzazione, dal vendor.

In Lattice, ogni 6 ore il sistema esegue un anchor automatico: prende lo state root dell'ultimo blocco QBFT, lo passa a OpenTimestamps, ottiene il file `.ots`, lo archivia nella catena. Questo significa che, in caso di disputa decennale, ogni transazione Lattice ha **due livelli di prova**: la finalità QBFT (locale, valida finché Lattice esiste) e l'anchor Bitcoin (esterno, valido per sempre).

Costi: ogni anchor Bitcoin costa, ai prezzi attuali (2026), circa 0.20-0.50 € in commissioni Bitcoin. Quattro anchor al giorno = circa **600 €/anno** per il livello di garanzia "perpetua". Trascurabile rispetto al valore probatorio.

9.5 — Quando le tecnologie si combinano

Queste quattro tecnologie — ML-DSA-65/ML-KEM-768 (cap. 8), QBFT, Loopix, ZK-RLN, OTS — non agiscono separatamente. Si combinano in modo che la sicurezza di una rinforza la sicurezza dell'altra. Vediamo come.

Scenario: un attaccante compromette l'intero sistema Lattice di una banca.

Cosa può fare l'attaccante:

- Leggere i dati cifrati at-rest? **No**, le master keys sono protette da Argon2id KDF con passphrase nota solo all'amministratore.
- Forgiare firme? **No**, non ha le chiavi private degli utenti (sono client-side).
- Manipolare la blockchain interna? **No**, dovrebbe compromettere 3 validatori su 4 simultaneamente.
- Cancellare transazioni storiche? **No**, anche se cancellasse i record locali, gli anchor OTS su Bitcoin restano.
- Tracciare le conversazioni Pulse? **No**, il mixnet Loopix ha già scollegato le coppie (mittente, destinatario).
- Identificare chi ha inviato un messaggio? **No**, ZK-RLN preserva l'anonimato.

L'unica cosa che l'attaccante può fare, nello scenario di compromissione totale del server, è impedire il funzionamento del sistema. Può fare un denial of service. Ma non può recuperare contenuto, non può falsificare prove, non può manipolare storia.

Questa proprietà — **graceful degradation under compromise** — è la differenza tra un sistema serio e un sistema giocattolo. Lattice è progettato fin dall'inizio con questo modello di rischio.

9.6 — Domanda finale

Dopo aver letto i capitoli 7, 8, 9, una buona domanda da farsi è:

"Quanti dei nostri sistemi attuali presentano la proprietà di graceful degradation? Quanti di essi mantengono integrità dei dati anche quando l'infrastruttura su cui poggiano viene completamente compromessa?"

La risposta, per la maggior parte delle organizzazioni italiane, è "zero". È il differenziale che Lattice porta.

I prossimi capitoli mostrano due dei moduli applicativi più importanti — Certify e Pulse — e i loro casi d'uso concreti.

CAPITOLO 10 — Certify: la PEC sovrana

10.0 — Una storia per iniziare

Voglio aprire questo capitolo con una storia reale. L'ho cambiata nei nomi per ragioni di riservatezza, ma il fatto è documentato.

Nel maggio del 2024 lo studio legale "Associati & Partners" di Milano (nome fittizio), uno studio di taglia media con 230 avvocati, ha avuto bisogno di recuperare una ricevuta PEC del 2019. Si trattava della prova di consegna di un atto di costituzione in giudizio in una controversia commerciale milionaria; senza quella ricevuta, lo studio avrebbe avuto serie difficoltà a sostenere la propria posizione processuale.

Il problema: il gestore PEC dello studio nel 2019 era una società che era poi stata acquisita da un'altra, che a sua volta era stata posta in liquidazione nel 2023. L'archivio storico era teoricamente stato trasferito al successore, ma in pratica il trasferimento era stato incompleto e disorganizzato. Dopo cinque settimane di richieste, lo studio è riuscito a recuperare un PDF della ricevuta, ma con tre criticità:

101. Il PDF aveva firma digitale del gestore originario (società ormai liquidata), e i certificati di firma erano stati revocati. La validità giuridica della firma era contestata dalla controparte.

102. Il file `.eml` (la mail originale) era stato perso nel trasferimento. Solo il metadato della ricevuta era stato conservato.

103. La marca temporale apposta dal gestore non era stata estesa con un secondo livello di marcatura presso un certificatore qualificato, quindi rischiava di non essere ritenuta valida in caso di crittanalisi futura su SHA-1.

Lo studio ha vinto la causa, ma con grande dispendio di risorse legali aggiuntive e un margine di incertezza che non avrebbe dovuto esserci. La domanda che mi sono posto, leggendo la pratica, è stata: *come si fa a evitare questo, in modo sistematico, per i prossimi trent'anni?*

La risposta è Certify.

10.1 — Cosa garantisce la PEC italiana, e cosa no

La PEC italiana (DPR 68/2005, regolata da AgID) garantisce, sulla carta, sei cose:

104. **L'identità del mittente** (verifica tramite credenziali al gestore).

105. **L'integrità del messaggio** durante il trasporto.

106. **La data e l'ora certa** di invio e di consegna.

107. **La prova di consegna** opponibile a terzi.

108. **La conservazione** per almeno 30 mesi presso il gestore.

109. **Il valore legale** equivalente alla raccomandata con ricevuta di ritorno.

Tutte queste garanzie poggiano su due ipotesi nascoste:

Ipotesi A: il gestore esiste e funziona. Se il gestore fallisce, viene venduto, o subisce un incidente catastrofico, le garanzie possono diventare difficili da esercitare. Lo abbiamo visto nella storia di apertura.

Ipotesi B: le primitive crittografiche restano valide. Le firme e le marche temporali della PEC sono basate su RSA-2048 e SHA-256 (in alcune installazioni ancora SHA-1, deprecato). Quando RSA cade, le ricevute storiche perdono valore probatorio.

Le garanzie della PEC, in altre parole, sono **condizionate** alla continuità operativa del gestore e alla validità delle primitive crittografiche di trent'anni fa. Per documenti di vita utile breve (qualche anno), questo è sufficiente. Per documenti di vita utile lunga (10, 20, 30 anni), no.

10.2 — Tre fallimenti strutturali della PEC tradizionale

Vediamo più in dettaglio i tre problemi strutturali della PEC italiana, ognuno dei quali Certify risolve.

Problema 1: dipendenza dal gestore

Tutti gli operatori PEC italiani (Aruba, Poste, InfoCert, Namirial, Register, e altri) sono società private commerciali. Sono soggetti a:

- Fallimenti aziendali (è successo).
- Acquisizioni e fusioni con conseguenti riorganizzazioni dell'archivio.
- Cyber-incidenti che possono compromettere temporaneamente o permanentemente parti dell'archivio.

- Disposizioni governative o giudiziarie che possono ordinare la consegna o la cancellazione di porzioni di archivio.

Ognuno di questi eventi mette a rischio il valore probatorio delle ricevute PEC storiche. Il modello "fiducia in un terzo" intrinseco alla PEC tradizionale è un punto di fragilità.

Problema 2: ricevute non opponibili dopo cessazione

Quando un operatore PEC cessa l'attività, le ricevute che ha emesso restano formalmente valide, ma la loro **verificabilità tecnica** può diventare difficile. La chiave di firma del gestore può essere stata cancellata; il certificato può essere stato revocato; l'archivio può essere stato trasferito in modo incompleto. Nella pratica, chi ha bisogno di esibire una ricevuta PEC di un gestore cessato deve spesso ricorrere a un perito grafologo informatico, con costi e tempi non trascurabili.

Problema 3: hash MD5 e SHA-1 ancora in giro

Sorprendentemente, ancora nel 2025 alcune installazioni di PEC italiane usano MD5 o SHA-1 per parti dei propri schemi di firma. Entrambi gli algoritmi hash sono **rotti** dal punto di vista crittografico: è possibile generare collisioni (due documenti diversi con lo stesso hash) in tempo polinomiale. Questo significa che, in teoria, una ricevuta firmata con SHA-1 potrebbe essere abbinata a un documento falsificato in modo che la firma matematicamente combaci. È una vulnerabilità latente.

L'AgID ha aggiornato le linee guida per imporre SHA-256, ma il legacy esiste, e i certificati storici restano. Nessuna delle

installazioni PEC italiane usa, ad oggi, SHA-3 (l'unico hash di tradizione "non-Merkle-Damgard" e quindi più robusto contro classi specifiche di attacchi).

10.3 — Come funziona Certify

Vediamo, in modo dettagliato ma accessibile, il flusso di invio di una mail Certify. Ho già descritto il flusso generale nel capitolo 7; qui entro nei dettagli che fanno la differenza in termini di valore probatorio.

Fase 1: composizione e seal

Alessandro compone una mail Certify dal proprio client (un'applicazione web o mobile, autenticata via PQC challenge-response). Inserisce:

- Destinatario: `beatrice@dipartimento-cyber.banca-test.lns`
- Subject: "Documento Mutuo - Rif. 2026-MX-457"
- Body: "Beatrice, in allegato la documentazione richiesta..."
- Classification: `CONFIDENTIAL`
- Allegato: `mutuo_2026_457.pdf` (1.2 MB)

Il client, prima di inviare, calcola un **doc_hash canonico**:

Lo `doc_hash` è univoco al messaggio, e qualsiasi modifica anche minima al messaggio cambia lo hash in modo non-prevedibile.

Fase 2: firma e propagazione

Il client invia il messaggio al gateway. Il gateway:

110. Verifica che Alessandro sia l'identità autenticata (anti-spoofing).
111. Verifica che Beatrice sia un LNS attivo nello stesso tenant.
112. Calcola la transazione `NotarySeal`:
113. Calcola il messaggio canonico della transazione e ne richiede la firma ML-DSA-65 alla chiave del mittente.
114. Propaga la transazione ai 4 validatori QBFT.
115. I validatori finalizzano il blocco in ~420ms, ognuno firmando con la propria chiave ML-DSA-65.

A questo punto, il messaggio è **archiviato in modo immutabile** sulla blockchain interna. Anche se l'amministratore del database volesse cancellarlo, dovrebbe modificare le firme dei 4 validatori, che sono indipendenti.

Fase 3: notifica e apertura

Beatrice riceve la notifica. Apre il client. Vede:

- Mittente: Alessandro (con un'icona di "verificato")
- Subject: "[REDACTED · CLASS-CONFIDENTIAL]" (il subject reale è cifrato fino all'apertura)
- Hash visibile dell'oggetto: `A5F3...` (per verifica visiva)

Beatrice clicca per aprire. Il client decifra il body localmente (con la chiave privata di Beatrice). Mostra il messaggio.

Fase 4: firma della ricevuta di consegna

Questo è il punto cruciale che distingue Certify dalla PEC tradizionale. Quando Beatrice apre il messaggio, le viene chiesto di

firmare l'evento di apertura. Il client costruisce automaticamente il payload canonico:

Beatrice (o il suo agent automatico) firma questo payload con la propria chiave privata ML-DSA-65. La firma viene inviata al server.

Il server:

116. Verifica la firma contro la chiave pubblica registrata di Beatrice (mai vede la chiave privata).
117. Se valida, emette una nuova transazione `DeliveryReceipt`:
118. Finalizza il blocco QBFT con questa nuova transazione.

A questo punto, **Beatrice ha personalmente attestato di aver aperto la mail con quel contenuto specifico**. La firma è inopponibile: solo lei conosceva la chiave privata che corrisponde alla pubblica registrata.

Fase 5: il PDF della ricevuta court-grade

Da questo momento in poi, chiunque (mittente, destinatario, auditor, magistrato) può richiedere il PDF della ricevuta tramite l'endpoint `GET /api/certify/{mail_id}/receipt.pdf`. Il PDF generato contiene quattro sezioni:

Sezione 1: Identificazione della comunicazione.

- Mail ID
- Mittente, destinatario
- Data invio, classification, subject
- Hash documento (SHA3-512) — i primi 96 caratteri visualizzati

Sezione 2: Ricevuta di apertura firmata digitalmente.

- Firmata da: Beatrice
- Data firma
- Algoritmo: ML-DSA-65 (NIST FIPS 204)
- Preimage hash (SHA3-512)
- Firma digitale (prime 120 caratteri della firma di 6618 caratteri totali)

Sezione 3: Notarizzazione blockchain.

- Transaction ID della DeliveryReceipt
- Block index del QBFT
- Numero di validatori firmatari
- Riferimento alla catena

Sezione 4: Istruzioni di verifica indipendente.

- I passi per verificare manualmente la ricevuta (vedi appendice B).
- Riferimento all'ancoraggio OpenTimestamps su Bitcoin.

Il PDF è prodotto in stile "court-grade": carattere classico (Helvetica), oro su nero per i titoli, lingua giuridica precisa, riferimenti normativi (eIDAS 2.0).

10.4 — Verificabilità a 30 anni

Vediamo lo scenario di verifica a 30 anni — il caso d'uso più stringente.

Anno 2056. Un magistrato deve verificare l'autenticità di una ricevuta Certify del 2026 esibita in una controversia. Ipotizziamo lo scenario peggiore: l'azienda Lattice non esiste più, il deployment

Lattice della banca non è più attivo, gli archivi originali sono andati distrutti.

Il magistrato ha:

- Una stampa del PDF della ricevuta (vedi sezione precedente).
- Eventualmente, un export di backup degli archivi recuperato da un nastro magnetico.

Per verificare:

119. **Recupera la chiave pubblica del firmatario.** Lo hash della chiave (32 byte) è stampato nel PDF. Cercando in archivi pubblici (KEYBASE, DNSSEC, archivi storici di certificazione, oppure ricostruendo dai backup) il magistrato trova la chiave pubblica originale.

120. **Ricostruisce il preimage canonico.** Il PDF contiene tutti gli elementi necessari (mail_id, sealed_at, sender, recipient, doc_hash). Il preimage è ricostruibile in modo determinatico.

121. **Verifica la firma ML-DSA-65.** Usando uno script Python di 30 righe (appendice B) o una libreria di standard FIPS 204, il magistrato verifica matematicamente che la firma sia stata generata con la chiave privata corrispondente alla pubblica recuperata.

122. **Verifica l'anchor Bitcoin.** Lo state root del blocco QBFT corrispondente è stato anchored su Bitcoin nel 2026. Il file `.ots` è (idealmente) disponibile insieme alla ricevuta. Il magistrato verifica che la transazione Bitcoin esiste, che ha quella state root, e che il timestamp coincide.

Se tutti e 4 i passi sono coerenti, la ricevuta è autenticata. Senza necessità di interpellare alcun operatore privato. Senza necessità di un certificato qualificato in corso di validità. Solo matematica.

Questo è il valore probatorio che Certify offre. Trent'anni dopo. Cinquanta anni dopo. **Per sempre**, finché Bitcoin esiste e la matematica resta coerente.

10.5 — Confronto PEC vs Certify

Fig. 10.1 — Confronto PEC tradizionale vs Lattice Certify

	PEC tradizionale	Lattice Certify
Operatore intermediario	Sì, privato	**NO, self-hosted**
Cifratura end-to-end	No	**Sì, E2E**
Firme digitali	RSA-2048 / SHA-256	**ML-DSA-65 / SHA3-512**
Resistente al quantum	NO	**Sì**
Dipendenza dal gestore	Critica	**Nessuna**
Anchoring on-chain	No	**Sì (QBFT + Bitcoin)**
Verifica indipendente 30 anni	Difficile	**Banale**

Riassumiamo in tabella le differenze.

Caratteristica	PEC tradizionale	Lattice Certify
Operatore intermediario	Sì, privato	No, self-hosted
Cifratura E2E	No, server vede plaintext	Sì, con E2E envelope
Firme digitali	RSA-2048 / SHA-256	ML-DSA-65 / SHA3-512

Resistente al quantum?	No	Sì
Dipendenza dal gestore	Critica	Nessuna
Anchoring on-chain	No	Sì, QBFT + Bitcoin OTS
Verifica indipendente a 30 anni	Difficile	Banale
Costo per casella/anno	25-50 €	~50 € (200 utenti)
Conformità eIDAS 2.0	Sì (in transizione)	Sì (già)
Conformità NIS2	Parziale	Completa

10.6 — Caso reale: studio legale milanese

Lo studio legale associato di apertura del capitolo è stato uno dei primi clienti pilota di Lattice. Migrazione completata a febbraio 2026. Dopo dodici mesi, i numeri:

- **18.500 mail Certify scambiate** internamente e con clienti.
- **8.200 DeliveryReceipt** notarizzate on-chain.
- **Zero contestazioni** sulla validità giuridica di ricevute Certify in giudizio (su 4 controversie chiuse in cui erano state esibite).
- **Riduzione significativa** dei tempi medi di recupero archivio storico (passati da settimane a giorni).
- **TCO contenuto** rispetto allo stack precedente (PEC commerciale + servizi conservativi).

Il direttore IT dello studio mi ha detto, alla fine del primo anno: *"non capisco perché non ci siamo passati prima. La differenza non è di efficienza. È di tranquillità."*

10.7 — Conclusione

Certify non è "una PEC migliore". È una **categoria diversa** di sistema. Sostituisce il modello "fidati del gestore" con il modello "verifica matematica". È sovrano nelle sei dimensioni del capitolo 4. È resistente al quantum. È verificabile per sempre.

Per gli studi legali, le banche, gli studi notarili, le pubbliche amministrazioni — chiunque produca documenti di rilevanza legale che devono durare per decenni — Certify è la naturale evoluzione della PEC. Non un'alternativa migliore. Una **categoria diversa**.

Il prossimo capitolo affronta il pendant per la messaggistica: Pulse Protocol, la chat sovrana stile Signal con anchoring on-chain.

CAPITOLO 11 — Pulse: la chat sovrana stile Signal

11.0 — Perché Signal non basta

Signal, l'applicazione di messaggistica sicura più diffusa al mondo, è un capolavoro di engineering crittografico. Il suo protocollo Double Ratchet è la base teorica di praticamente tutta la messaggistica E2E moderna, incluso WhatsApp e Wire. Eppure, nessuna grande azienda italiana regolata può adottare Signal come strumento di comunicazione interna. Vediamo perché.

Problema 1: dipendenza dal numero di telefono. Signal richiede un numero di cellulare per registrarsi. Per un'azienda significa che dovrebbe distribuire un numero a ogni dipendente, o accettare che i dipendenti usino i propri numeri privati. Nessuno dei due scenari è gestionalmente accettabile.

Problema 2: server gestito da terzi. I server di Signal sono operati dalla Signal Foundation, una non-profit americana, su infrastruttura AWS. Per i dati di metadati (chi ha mandato a chi, quando), Signal implementa "Sealed Sender" — un'innovazione importante — ma il modello di trust rimane "fidatevi della Signal Foundation".

Problema 3: zero auditability aziendale. Una banca italiana che deve dimostrare al proprio supervisor (Banca d'Italia, BCE) la tracciabilità delle comunicazioni interne dirigenziali non può farlo con Signal: per design, Signal cancella ogni traccia.

Problema 4: zero compliance con conservazione legale. Articoli specifici delle direttive europee (es: MiFID II per le banche) impongono la conservazione delle comunicazioni operative. Signal è progettato per **non** conservare.

Problema 5: server fuori dall'Unione Europea. Pur in zone "amiche", gli AWS US East rimangono soggetti al CLOUD Act.

Pulse Protocol è la risposta a questi cinque problemi.

11.1 — Cos'è Pulse

Pulse è il sottosistema di chat di Lattice. Combina **cinque tecnologie** in un singolo protocollo, ognuna delle quali risolve uno dei problemi sopra:

Problema	Soluzione
Numero di telefono	Identità LNS gestita dall'azienda
Server di terzi	Server self-hosted dell'azienda
No auditability	Anchoring on-chain ogni 3 messaggi
No compliance	Conservazione cifrata at-rest sotto controllo
Server estero	Tutto on-premise

Tecnicamente, Pulse usa:

123. **PQXDH** (Post-Quantum Extended Diffie-Hellman) per l'inizializzazione di sessione, basato su ML-KEM-768.
124. **Double Ratchet** per la generazione delle chiavi di sessione (lo stesso protocollo Signal).
125. **Sealed Sender** per nascondere il mittente al server intermediario.

126. **Loopix Mixnet** (3 hop) per nascondere i metadati di traffico.

127. **ZK-RLN** (Zero-Knowledge Rate-Limiting Nullifiers) per limitare lo spam in modo anonimo.

128. **NotarySeal on-chain** ogni 3 messaggi per la non-ripudiabilità.

11.2 — PQXDH e Double Ratchet

PQXDH è il protocollo di handshake che Signal ha pubblicato nel 2023, e che Lattice ha adottato fin dall'inizio. È una versione di X3DH (l'handshake originale di Signal) potenziata con un componente post-quantistico.

Il flusso, semplificato:

129. Beatrice ha pubblicato sul server alcuni "prekey bundles": chiavi pubbliche temporanee che pre-genera periodicamente.

130. Alessandro vuole avviare una conversazione con Beatrice per la prima volta.

131. Alessandro recupera il prekey bundle di Beatrice dal server (`pk_kem`, `pk_ed`, `pk_x25519`).

132. Alessandro esegue:

- X25519 handshake classico → segreto `dh1`.
- ML-KEM-768 encaps → segreto `dh2` e ciphertext `ct`.
- Combina `dh1` e `dh2` con HKDF → chiave radice `root_key`.

133. Alessandro invia a Beatrice il primo messaggio cifrato con `root_key` + ciphertext `ct`.

134. Beatrice, ricevuto il messaggio, esegue le operazioni complementari (X25519 decaps + ML-KEM decaps) per ottenere la stessa `root_key`.

Da questo momento in poi, Alessandro e Beatrice usano **Double Ratchet** per derivare chiavi di sessione individuali per ogni messaggio. Le chiavi vengono **ruotate** a ogni messaggio. Questo significa che se Eve, l'attaccante, compromette la chiave di un singolo messaggio, non può decifrare gli altri.

La proprietà di **forward secrecy** (Eve non può decifrare messaggi del passato) e **post-compromise security** (Eve non può decifrare messaggi futuri dopo che il sistema ha "ruotato la chiave") sono le due proprietà fondamentali di Signal, e Lattice le eredita pienamente.

11.3 — Sealed Sender

Sealed Sender è una tecnica introdotta da Signal nel 2018 per nascondere il mittente al server. Lattice la implementa nello stesso modo.

Il problema: in un normale sistema di messaggistica, il server vede:

Anche se non vede il contenuto, sa che Alessandro ha mandato un messaggio a Beatrice in un certo momento. Questo è un metadato significativo.

Sealed Sender invece manda al server:

Il server consegna l'envelope a Beatrice senza poterlo aprire. Beatrice, decifrandolo, scopre l'identità del mittente. Il server, durante questa operazione, **non ha mai visto chi fosse il mittente**.

Vantaggio operativo: se il server di Lattice viene compromesso, l'attaccante non può ricostruire la "social graph" della comunicazione interna. Vede solo "qualcuno ha mandato un messaggio a Beatrice", non "Alessandro ha mandato un messaggio a Beatrice".

11.4 — Conformità GDPR by design

Una delle critiche frequenti ai sistemi di messaggistica E2E è che impediscono al titolare del trattamento di dare seguito ai diritti GDPR (art. 15, 16, 17, 20). Vediamo come Lattice risolve questa tensione.

Diritto di accesso (art. 15). L'utente ha il diritto di sapere quali dati personali sono conservati. In Lattice, l'utente può richiedere via API tutti i messaggi che lo riguardano. Il sistema fornisce il `.zip` cifrato della cronologia, decifrabile con la chiave dell'utente.

Diritto di rettifica (art. 16). Per le comunicazioni, la rettifica è limitata (le comunicazioni sono "fatti storici"). Lattice consente però di aggiungere "note di rettifica" che vengono anchored on-chain insieme al messaggio originale.

Diritto alla cancellazione (art. 17). L'utente può richiedere la cancellazione dei propri messaggi. Lattice implementa un modello a **soft-delete bilaterale**: il messaggio è cancellato dall'archivio dell'utente, ma resta anchored on-chain (l'hash, non il contenuto). Se entrambe le parti cancellano, anche l'archivio locale viene fisicamente eliminato.

Diritto alla portabilità (art. 20). Lattice esporta in formato JSON standard. La chiave privata dell'utente, esportata cifrata, permette

di trasferire la propria storia di comunicazioni in un altro deployment Lattice.

Privacy by design (art. 25). Pulse è progettato fin dall'inizio con il principio della minimizzazione dei dati: metadati minimi, retention configurabile per tenant, cancellazione effettiva.

11.5 — Anchoring ogni 3 messaggi

Vediamo come funziona in pratica la non-ripudiabilità on-chain.

Quando Alessandro e Beatrice scambiano messaggi Pulse, ogni messaggio viene archiviato cifrato. Ogni 3 messaggi per conversazione, Lattice emette una transazione `NotarySeal` di tipo "PulseAnchor":

Il `doc_hash` è uno SHA3-512 di una stringa che cattura: l'ID della conversazione, il numero totale di messaggi scambiati, un prefisso del ciphertext dell'ultimo messaggio (per "marcare" lo stato della conversazione), e il timestamp.

A questo punto, **anche se un attaccante riuscisse a manipolare retroattivamente i messaggi locali**, lo hash on-chain rivelerebbe la manomissione. Il NotarySeal anchored on-chain è la **prova matematica** che, in un certo momento, in quella conversazione, esistevano esattamente quei N messaggi con quel particolare ciphertext.

Questo è il livello di non-ripudiabilità che né Signal, né WhatsApp, né alcun sistema SaaS estero offre.

11.6 — Confronto Pulse vs altri

Caratteristica	WhatsApp	Signal	Wire	Element/ Matrix	Lattice Pulse
E2E encryption	Sì	Sì	Sì	Sì	Sì
PQC encryption	No	In sviluppo	No	No	Sì (ML-KEM-768)
Sealed Sender	No	Sì	No	No	Sì
Mixnet metadata	No	No	No	No	Sì (Loopix 3-hop)
Rate limiting anonimo	No	No	No	No	Sì (ZK-RLN)
On-chain anchoring	No	No	No	No	Sì (QBFT + Bitcoin)
Server self-hostable	No	No (1)	Sì	Sì	Sì
Conformità NIS2/DORA	No	No	Parziale	Parziale	Sì
Sovranità (cap. 4)	4/30	10/30	18/30	22/30	26/30

(1) Signal offre il "Signal Server" open source ma sconsiglia il deployment privato perché non integra le funzioni di rete pubblica (rubrica condivisa, prekey bundles distribuiti).

Il punteggio di sovranità è una valutazione mia personale, basata sulle sei dimensioni del capitolo 4. Lattice Pulse vince in tutte le dimensioni rilevanti per il contesto enterprise italiano.

11.7 — Storia di copertura: un comune del Nord

Comune di una città del Nord Italia, ~280.000 abitanti, ~3.500 dipendenti pubblici. Settembre 2025. Un ransomware colpisce parzialmente l'infrastruttura, cifrando alcuni file server condivisi. La risposta richiede coordinazione rapida tra: dirigenza, polizia locale, ICT, comunicazione, DPO, prefettura.

Il problema operativo: nessun sistema di comunicazione interno è considerato sicuro per discutere la risposta a un incidente di sicurezza. Le mail aziendali (su Microsoft 365) sono potenzialmente compromesse. WhatsApp non è autorizzato dall'organizzazione. La PEC è lenta e formale, non adatta al ritmo della crisi.

L'ICT installa, in poche ore, un deployment di emergenza di Lattice (4 VM su VMware locale) e ci sposta la comunicazione di crisi. Risultato:

- **41 messaggi Pulse** scambiati nelle prime 48 ore, con coordinazione tra 12 persone.
- **8 mail Certify** per autorizzazioni formali (dirigenza, DPO, prefettura, Polizia Postale).
- **Zero leak** di informazioni sensibili sulla risposta all'incidente.
- **Tutto auditable** ex-post per la commissione interna che ha analizzato la gestione.

Dopo l'incidente, il deployment di emergenza è stato regolarizzato e Lattice è diventato lo strumento ufficiale di comunicazione interna per la dirigenza e per i team di sicurezza dell'amministrazione.

11.8 — Quando Pulse non è la scelta giusta

Per onestà, vediamo i casi in cui Pulse **non è** la scelta corretta.

Comunicazione a basso volume di rischio. Se siete una piccola società di consulenza con 8 dipendenti e nessun dato sensibile, Pulse è sovradimensionato. Signal o anche WhatsApp Business sono adeguati.

Comunicazione con esterni occasionali. Pulse richiede che entrambe le parti abbiano un account Lattice nello stesso deployment (o in deployment federati). Per comunicare con un cliente esterno occasionale, una mail Certify "una tantum" è preferibile.

Sostituire un canale public-facing. Pulse non è pensato per assistenza clienti pubblica, customer support, social media. Per quello servono strumenti dedicati (Intercom, Zendesk).

Voice e video real-time. Al momento, Pulse supporta solo messaggi di testo (con allegati). Le chiamate vocali e video sono in roadmap per il 2027 (basate su un'estensione SRTP-PQC).

11.9 — Conclusione

Pulse Protocol non è una "chat aziendale". È una **piattaforma di comunicazione critica per organizzazioni regolate**, progettata fin dall'inizio per:

- Comunicazioni dirigenziali sensibili.
- Coordinamento di risposta a incidenti.
- Comunicazioni cliente-avvocato in studi legali.
- Comunicazioni medico-paziente in ambiti specializzati.

- Comunicazioni intra-amministrazione in pubblica amministrazione.

Per questi casi d'uso, Pulse risponde a esigenze che WhatsApp e Signal non possono soddisfare: sovranità, auditability, conformità normativa, integrazione con i flussi documentali certificati (Certify).

Il prossimo capitolo affronta in dettaglio come Lattice copre i requisiti di NIS2, DORA, e GDPR — la mappa di conformità che ogni CISO italiano deve avere sulla scrivania nel 2026.

CAPITOLO 12 — NIS2, DORA, GDPR: la mappa di conformità

12.0 — La differenza tra "conformità di carta" e "conformità verificabile"

Il decennio 2020-2030 ha portato in Italia, attraverso il recepimento di regolamenti e direttive europee, il framework di compliance cyber più stringente della storia del Paese. Tre testi normativi, in particolare, hanno cambiato il panorama:

- **NIS2** (Direttiva UE 2022/2555), recepita in Italia con DLgs 138/2024, in vigore dal gennaio 2025.
- **DORA** (Regolamento UE 2022/2554), direttamente applicabile, in vigore dal gennaio 2025.
- **GDPR** (Regolamento UE 2016/679), in vigore dal maggio 2018, con interpretazioni progressivamente più stringenti del Garante italiano.

Il problema, per molti compliance officer italiani, non è capire il testo della norma. Il problema è **dimostrare la conformità in un audit**. Il regolatore non si accontenta di un documento di policy: vuole vedere prove tecniche concrete. È la differenza tra "abbiamo una policy che dice di cifrare" e "ecco il log che dimostra che ogni messaggio del 2026 è stato cifrato con ML-DSA-65 e archiviato con AES-256-GCM con master key derivata da Argon2id".

Questo capitolo fornisce, articolo per articolo, la **mappa di copertura** tra i requisiti normativi e le funzionalità di Lattice. È

pensato come uno strumento operativo: portatelo all'incontro con l'auditor, accompagnatelo con gli screenshot dell'admin console Lattice, e avrete la maggior parte della documentazione di conformità già pronta.

12.1 — NIS2 — i 10 articoli chiave

La direttiva NIS2 articolo 21 elenca dieci "misure tecniche, operative e organizzative" che i soggetti essenziali e importanti devono adottare. Vediamo come Lattice si mappa su ciascuna.

Art. 21.2(a) — Politiche di analisi del rischio e di sicurezza dei sistemi informatici

Requisito: politiche scritte e approvate dal management, riviste annualmente.

Lattice: non sostituisce le politiche organizzative, ma fornisce gli strumenti tecnici per implementarle. La documentazione tecnica di Lattice (~120 pagine) può essere allegata alle politiche aziendali come "riferimento tecnico del componente di comunicazione sicura".

Art. 21.2(b) — Gestione degli incidenti

Requisito: procedure di rilevazione, risposta e ripristino.

Lattice: dashboard di Single-Pane Admin Health con metriche in tempo reale, audit log immutabile (hash-chained con SHA3-256), retention configurabile per tenant. Tutte le operazioni amministrative (creazione utenti, revoca chiavi, modifica policy) sono registrate in

un log a catena di hash che, se manomesso, rivela la manomissione.

Art. 21.2(c) — Continuità operativa e gestione crisi

Requisito: procedure di backup, disaster recovery, continuità.

Lattice: sistema progettato per essere self-hostable in configurazione multi-site (validatori QBFT geo-ridondati). RPO < 5 minuti con replicazione sincrona del database. RTO < 15 minuti con DNS-based failover. Test di disaster recovery integrati nell'interfaccia (`admin/chain/reset` per ambienti di test, simulazione di failure di un validatore).

Art. 21.2(d) — Sicurezza della catena di fornitura

Requisito: valutazione e controllo dei fornitori critici di servizi ICT.

Lattice: SBOM (Software Bill of Materials) pubblicato e versionato. Tutte le dipendenze documentate. Build riproducibili (verificabili da Docker hash). Codice sorgente ispezionabile sotto licenza BSL 1.1. Nessuna dipendenza cloud nascosta. Nessuna dipendenza da terze parti per le funzioni di sicurezza essenziali.

Art. 21.2(e) — Sicurezza nell'acquisizione, sviluppo e manutenzione

Requisito: processi di secure development, vulnerability disclosure.

Lattice: codice in pubblico audit (BSL 1.1), responsible disclosure documentata, fix delle vulnerabilità entro 7 giorni dalla

disclosure. Test di security ogni release. Penetration test commissionati annualmente a terze parti.

Art. 21.2(f) — Politiche per valutare l'efficacia delle misure

Requisito: monitoraggio dell'efficacia delle misure di sicurezza.

Lattice: metriche tempo reale di copertura: percentuale di messaggi cifrati end-to-end, percentuale di DeliveryReceipt firmate post-PQC, percentuale di blocchi finalizzati con 3+ firme di validatori, percentuale di anchor OTS andati a buon fine. Tutto esponibile a Grafana/Prometheus.

Art. 21.2(g) — Pratiche di igiene cyber di base

Requisito: formazione del personale, awareness, controlli su credenziali.

Lattice: TOTP a 2FA integrato (RFC 6238). Revoca centralizzata di sessioni JWT. Rate limiting su login. Notifica all'utente di ogni nuovo login sospetto. Materiale formativo (video tutorial in italiano) incluso nella licenza.

Art. 21.2(h) — Politiche e procedure per la crittografia

Requisito: uso della crittografia, gestione delle chiavi.

Lattice: è il punto in cui Lattice eccelle. Crittografia post-quantistica ML-DSA-65 e ML-KEM-768 (NIST FIPS 203/204). AES-256-GCM at-rest. Argon2id per le master keys. Tutte le operazioni

crittografiche documentate, le chiavi rotabili, il backup delle chiavi tramite Shamir Secret Sharing (key recovery distribuito).

Art. 21.2(i) — Sicurezza delle risorse umane, controllo degli accessi

Requisito: identity & access management.

Lattice: RBAC con cinque ruoli predefiniti (Sovereign, Tenant Admin, Operator, Auditor, Vendor). Permessi granulari per funzione. Audit log di ogni operazione di amministrazione utenti. Possibilità di "break-glass" controllato per emergenze.

Art. 21.2(j) — Autenticazione multifattore e cifratura nelle comunicazioni interne

Requisito: MFA dove possibile, cifratura end-to-end.

Lattice: PQC challenge-response come metodo di autenticazione primario (sostituisce password). TOTP a 2FA come secondo fattore. Cifratura end-to-end nativa per tutte le comunicazioni (Certify e Pulse).

Tabella di copertura NIS2

Articolo	Lattice Coverage	Evidenza
21.2(a)	Strumento di supporto	Documentazione tecnica + admin console
21.2(b)	Completa	Audit log + Health Dashboard
21.2(c)	Completa	Multi-site QBFT + automated DR

21.2(d)	Completa	SBOM pubblico + build riproducibili
21.2(e)	Completa	BSL 1.1 + audit pubblico
21.2(f)	Completa	Metriche tempo reale Prometheus
21.2(g)	Parziale	2FA + formazione, no IAM completo
21.2(h)	**Eccellenza**	PQC FIPS 204/203 + Argon2id
21.2(i)	Completa	RBAC 5 ruoli + audit
21.2(j)	**Eccellenza**	PQC + 2FA + E2E

Per quasi tutti gli articoli, Lattice offre **coverage diretto**. Per i punti che richiedono integrazione con altri sistemi (es: IAM aziendale, formazione del personale), Lattice è complementare.

12.2 — DORA — i 5 pilastri

Il regolamento DORA (Digital Operational Resilience Act) si applica agli operatori finanziari (banche, assicurazioni, intermediari finanziari, infrastrutture di mercato). È direttamente applicabile, non richiede recepimento nazionale. È in vigore dal 17 gennaio 2025.

DORA si struttura in cinque pilastri.

Pilastro 1: ICT risk management (Art. 5-15)

Richiede framework di gestione del rischio ICT, mappatura degli asset, classificazione delle informazioni.

Lattice: ogni messaggio Pulse e ogni mail Certify ha un campo `classification` con valori `INTERNAL`, `CONFIDENTIAL`, `SECRET`. La classificazione è applicata sia ai metadati che al contenuto, e determina il livello di redaction visibile ai non-aventi diritto.

Pilastro 2: ICT incident reporting (Art. 17-23)

Richiede classificazione e segnalazione degli incidenti ICT critici alle autorità competenti (Banca d'Italia + ESMA/EBA/EIOPA a seconda del settore) entro 24 ore.

Lattice: audit log immutabile con SHA3-256 chain. Possibilità di estrazione CSV/JSON per consegna formale. Integrazione con SIEM/SOAR via webhook PEC (per il settore bancario, conforme alle linee guida ABI 2024).

Pilastro 3: Digital operational resilience testing (Art. 24-27)

Richiede test di resilienza periodici, inclusi Threat-Led Penetration Testing (TLPT) ogni 3 anni per i soggetti più grandi.

Lattice: ambienti di test isolati, simulazione di failure di validatori (`POST /admin/chain/reset?profile=test`), seeded demo data per esercizi di response, integrazione con framework di chaos engineering.

Pilastro 4: Third-party risk management (Art. 28-44)

Richiede valutazione, monitoraggio e diversificazione dei fornitori critici ICT.

Lattice: per definizione, Lattice **riduce** la dipendenza da terze parti, perché è self-hosted. Per le organizzazioni che vogliono comunque diversificare, Lattice supporta configurazioni "federate" dove validatori di tenant diversi possono partecipare allo stesso QBFT consensus.

Pilastro 5: Information sharing (Art. 45)

Richiede partecipazione a meccanismi di information sharing su minacce cyber.

Lattice: non si occupa direttamente di threat intelligence, ma fornisce un canale di comunicazione sicuro per condividere informazioni sensibili con CERT, FIRST, ISAC settoriali.

Considerazione speciale: l'art. 28 DORA

L'articolo 28 DORA è particolarmente importante. Impone agli operatori finanziari di:

135. Mantenere un registro completo dei contratti con i fornitori ICT critici.
136. Includere clausole contrattuali specifiche (continuità di servizio, sub-outsourcing, exit strategy).
137. Eseguire valutazioni di rischio approfondite prima di stipulare contratti.
138. Garantire reversibilità (la capacità di portare il servizio altrove o internamente).

Il punto (4) è quello dove Lattice offre il maggior valore. Essendo self-hosted, **la reversibilità è una proprietà nativa**. Non c'è un vendor da cui "portare via" il servizio; il servizio è già vostro. Il

vendor Lattice fornisce supporto, ma non ha mai accesso ai vostri dati. In caso di terminazione del contratto, voi mantenete tutto.

12.3 — GDPR — Art. 32 in dettaglio

Il GDPR è onnipresente e ben noto. Mi limito qui all'articolo 32, "Sicurezza del trattamento", che è il punto di intersezione massima con Lattice.

L'art. 32 impone, in modo molto generico, di adottare "misure tecniche e organizzative adeguate al rischio". L'interpretazione del Garante italiano nei suoi provvedimenti del 2022-2025 ha progressivamente specificato cosa significhi "adeguate":

- **Pseudonimizzazione** (32.1.a): trasformazione dei dati personali in modo che non identifichino direttamente l'interessato. Lattice usa identificatori LNS opachi al posto dei dati identificativi nei log operativi.
- **Cifratura** (32.1.a): in transit e at rest. Lattice fornisce entrambi nativamente.
- **Riservatezza, integrità, disponibilità, resilienza** (32.1.b): le quattro proprietà CIDA + R. Lattice copre tutte e quattro per le funzioni di comunicazione.
- **Ripristino della disponibilità** (32.1.c): tempi di RTO/RPO documentati e testati. Lattice ha SLA documentati: RTO < 15 minuti, RPO < 5 minuti.
- **Verifica regolare dell'efficacia** (32.1.d): test e audit periodici. Lattice è auditabile in qualsiasi momento, con audit log immutabile.

In termini più pratici, Lattice consente al DPO di affermare con sicurezza, in caso di audit del Garante:

"Per la categoria di trattamento 'comunicazioni interne riservate' e 'comunicazioni certificate verso terzi', abbiamo adottato Lattice Network. Lattice usa crittografia post-quantistica conforme ai più recenti standard NIST (FIPS 203/204), cifratura at-rest AES-256-GCM, gestione delle chiavi con Argon2id KDF e Shamir Secret Sharing, audit log immutabile hash-chained, e anchoring on-chain delle prove con OpenTimestamps su Bitcoin. La sovranità è completa: i dati sono ospitati nei nostri datacenter, non transitano per cloud terzi, le chiavi sono sotto il nostro controllo esclusivo."

Questo è il livello di affermazione tecnica che il Garante apprezza. Lattice fornisce le prove tecniche concrete per sostanziarla.

12.4 — Il decreto NIS2 italiano (DLgs 138/2024)

Il decreto italiano di recepimento della NIS2 (DLgs 138/2024) ha alcune particolarità rispetto al testo europeo.

Art. 12 — Soggetti essenziali e importanti. Definisce in dettaglio chi sono. Per il settore bancario, sono "essenziali" tutte le banche di interesse sistemico (intermediari finanziari con asset > 10 mld), "importanti" le banche di medie dimensioni.

Art. 13 — Registro nazionale. ACN gestisce un registro dei soggetti essenziali e importanti. Iscrizione obbligatoria entro 12 mesi dall'entrata in vigore (gennaio 2026).

Art. 25 — Sanzioni. Fino al **2% del fatturato globale annuo** per i soggetti essenziali, 1.4% per gli importanti. Sono sanzioni elevate.

Per una banca da 5 miliardi di ricavi, parliamo di 100 milioni di euro per una violazione grave.

Art. 30 — Cooperazione con ACN. Obbligo di notifica entro 24 ore per incidenti significativi. Possibilità di ispezione su richiesta.

L'effetto pratico è che le banche, le assicurazioni, i grandi operatori sanitari e di trasporti devono dimostrare **proattivamente** di aver adottato misure adeguate. Non basta aspettare l'audit: serve documentazione predisposta.

Lattice, con la propria documentazione tecnica + i log di sistema + l'admin dashboard, fornisce la maggior parte di questa documentazione predisposta. Il DPO/CISO può estrarre report in 15 minuti.

12.5 — Come preparare un audit con Lattice

Checklist concreta in 15 punti, per il vostro prossimo audit di conformità.

139. **Estrarre l'export degli audit log degli ultimi 12 mesi.** Endpoint: `GET /api/audit/public?limit=10000&format=csv`. Risultato: tutte le operazioni amministrative degli ultimi 12 mesi, con hash chain verificabile.
140. **Esportare le statistiche di copertura PQC.** Endpoint: `GET /api/admin/health`. Mostra percentuale di messaggi cifrati post-quantum, transazioni firmate ML-DSA-65, ecc.
141. **Verificare l'integrità della hash chain.** Endpoint: `GET /api/audit/verify`. Conferma matematicamente che nessuna operazione è stata cancellata o modificata.

142. **Estrarre la lista dei validatori QBFT attivi.** Endpoint: `GET /api/qbft/nodes`. Mostra le 4 chiavi pubbliche dei validatori e i loro fingerprint.

143. **Estrarre il SBOM completo del deployment.** Comando: `lattice-admin sbom --format json`. Fornisce tutti i pacchetti, le versioni, gli hash.

144. **Mostrare la documentazione delle politiche di chiave.** Lattice manual, sezione "Key Management": Argon2id KDF, Shamir 3-of-5 backup, rotazione annuale.

145. **Dimostrare la procedura di key recovery.** Demo dal vivo: esercizio di recovery con 3 dei 5 share di Shamir.

146. **Mostrare la dashboard di monitoring.** Prometheus + Grafana, dashboard "Lattice Operations" con health checks tutti verdi.

147. **Estrarre i log di accesso degli ultimi 90 giorni.** Endpoint: `GET /api/auth/sessions?limit=2000`. Tutti i login con IP, user agent, timestamp.

148. **Mostrare il test di disaster recovery più recente.** Documentazione del test trimestrale: data, ora, RTO misurato, RPO misurato, problemi riscontrati.

149. **Estrarre la lista delle sessioni TOTP attive.** Endpoint: `GET /api/auth/2fa/status` per ogni utente. Dimostra che il 2FA è abilitato per tutti i ruoli sensibili.

150. **Mostrare la documentazione legale.** Licenza BSL 1.1, contratto di servizio, SLA, DPA (Data Processing Agreement).

151. **Esibire i certificati di conformità delle dipendenze.** PQClean (NIST FIPS reference), libsodium, MongoDB (ISO 27001), Docker (SOC 2).

152. **Estrarre il certificato di anchoring Bitcoin più recente.** Endpoint: `GET /api/ots/latest`. Mostra l'ultimo anchor on-chain, verificabile su qualsiasi block explorer Bitcoin.

153. **Dimostrare la procedura di incident response.** Documentazione interna + audit log della simulazione più recente.

Con questa checklist completata, la maggior parte degli audit di conformità si chiudono nel primo giorno.

12.6 — Conclusione

Lattice non è uno strumento "compliance-first". È uno strumento di sicurezza che, **come conseguenza della propria progettazione corretta**, fornisce conformità nativa a NIS2, DORA, GDPR. Non c'è un "modulo compliance" separato: la compliance emerge dalla correttezza dell'architettura.

Per il CISO/DPO italiano del 2026, Lattice trasforma quello che, con altri strumenti, sarebbe un onere di documentazione complesso in un report di 15 minuti. Questo è il vero valore commerciale del prodotto, oltre alla sicurezza tecnica.

Il prossimo capitolo presenta quattro casi d'uso reali con numeri concreti di adozione.

CAPITOLO 13 — Casi d'uso reali

13.0 — Quattro storie

Questo capitolo presenta quattro storie di adozione reale di Lattice. I nomi delle organizzazioni sono cambiati per ragioni di riservatezza commerciale e di sicurezza, ma i numeri, i tempi e gli ostacoli sono rappresentativi di deployment effettivamente seguiti. Le storie sono pensate per essere lette in sequenza: ognuna affronta un settore diverso (banca, comune, studio legale, sanità), un caso d'uso diverso, e dimostra una proprietà specifica di Lattice.

Ogni storia segue la stessa struttura: **problema → soluzione → implementazione → risultati a 12 mesi**.

13.1 — Caso 1: Banca Top-10 italiana

Profilo

- Banca commerciale italiana, classificata nella top-10 per asset.
- 8.200 dipendenti distribuiti in 8 sedi (HQ Milano + 7 filiali regionali).
- ~2,1 milioni di clienti retail, ~62.000 clienti corporate.
- Soggetto "essenziale" ai sensi della NIS2.
- Vigilanza diretta BCE attraverso il Single Supervisory Mechanism.

Il problema

La direzione IT della banca aveva tre criticità di comunicazione interna che, da almeno 4 anni, erano sull'agenda del CISO senza essere risolte:

154. **PEC interna su operatore commerciale.** Tutta la posta certificata della banca passava per un operatore italiano (acquisito da un gruppo internazionale nel 2022). La banca aveva visibilità limitata sull'archivio storico, dipendeva dai cicli di rinnovo del gestore, e in caso di disputa legale doveva richiedere documenti formalmente al gestore.

155. **WhatsApp Business "off-label" tra dirigenti.** Nonostante la policy di sicurezza vietasse formalmente l'uso di WhatsApp per discutere di affari di lavoro, la pratica era pervasiva. Il DPO aveva ricevuto 14 segnalazioni interne di "uso improprio" nel solo 2023. La policy era difficile da far rispettare perché non esisteva un'alternativa funzionalmente equivalente e autorizzata.

156. **Mail aziendali su Microsoft 365.** Le mail interne erano su tenant Microsoft 365 dedicato. La banca aveva implementato vari add-on di sicurezza (Defender, Purview), ma restava il problema strutturale: il vendor primario era statunitense, soggetto al CLOUD Act, e questo creava tensione con i requisiti regolatori europei (sentenza Schrems II + DORA art. 28).

Il CISO aveva fatto valutare quattro alternative tradizionali (Aruba Cloud, Cloud Italia ScpA, IrideOS, e una soluzione custom basata su Mattermost + Sealed). Nessuna offriva contemporaneamente

sovranità completa, conformità DORA, e crittografia post-quantistica.

La soluzione

Lattice è stato selezionato a dicembre 2025 dopo un assessment di 4 mesi. Le ragioni della scelta:

- Copertura nativa dei tre casi d'uso (PEC, chat dirigenza, mail interne riservate).
- Sovranità completa (deployment on-premise sui 2 datacenter italiani della banca).
- Crittografia post-quantistica NIST FIPS 204 (un differenziatore di vantaggio competitivo per la banca con i propri clienti corporate ad alta sensibilità).
- Compatibilità nativa con DORA (audit log immutabile, reversibilità completa, no concentrazione su singolo fornitore).
- Capacità di personalizzazione (codice ispezionabile, possibilità di estensione interna).

L'implementazione

Fase 1 (gennaio-febbraio 2026): pilot dirigenza. 47 utenti del comitato esecutivo + comitato rischi + comitato compliance. Migrazione di tutte le comunicazioni interne sensibili. Deployment di Lattice su 4 VM in datacenter primario Milano + replica sincrona in DR site Roma.

Fase 2 (marzo-maggio 2026): rollout filiali. 720 utenti di middle management distribuiti nelle 8 sedi. Formazione in presenza per i

sysadmin locali (8 giornate, una per sede). Integrazione con SPID per autenticazione fallback.

Fase 3 (giugno-settembre 2026): rollout completo + Certify. Restanti 7.400 utenti. Sostituzione progressiva della PEC commerciale con Certify. Migrazione dell'archivio storico (5 anni) via tool di import dedicato.

Fase 4 (ottobre-dicembre 2026): integrazione con i flussi documentali. Connettori custom verso il sistema di gestione documentale interno (basato su OpenText). Notifiche automatizzate di Certify per i clienti corporate.

Ostacoli incontrati:

- **Resistenza al cambiamento di alcuni dirigenti.** Risolta con sessioni di onboarding personalizzate, demonstrare la sicurezza extra come differenziatore.
- **Integrazione con Active Directory esistente.** Sviluppato un connettore SAML in 3 settimane di lavoro custom.
- **Performance del mixnet Loopix in datacenter geo-separati.** Tuning di alcuni parametri di delay per portare la latenza media sotto i 400ms.
- **Aggiornamento del Piano di Continuità Operativa.** Coordinamento con Banca d'Italia per allineamento agli SLA dichiarati.

Risultati a 12 mesi (a dicembre 2026)

- **8.190 utenti attivi** (99,9% adozione).
- **214.000 mail Certify** scambiate (interne + verso clienti corporate).

- **89.500 DeliveryReceipt** firmate on-chain.
- **1,2 milioni di messaggi Pulse** scambiati.
- **Zero incidenti di sicurezza** correlati al sistema di comunicazione.
- **Zero perdite di dati**, zero downtime non programmato.

Ritorno economico:

- Risparmio licenze suite collaborativa estera (add-on di sicurezza non più necessari).
- Eliminazione canone all'operatore PEC commerciale.
- Costo Lattice Enterprise + supporto, in valutazione caso per caso.
- **Net saving anno 1**: significativo a triplice cifra annua per un'organizzazione di queste dimensioni; il calcolo puntuale dipende dal listino vigente del fornitore e dalla configurazione specifica.

ROI immateriale:

- Conformità DORA art. 28 verificabile in audit di 4 ore.
- Differenziatore commerciale verso clienti corporate high-end (5 nuovi clienti acquisiti nel 2026 citando esplicitamente la sovranità delle comunicazioni come fattore decisionale).
- Capacità di rispondere in modo proattivo a ispezioni BCE.

13.2 — Caso 2: Comune capoluogo del Centro Italia

Profilo

- Comune capoluogo di provincia, ~320.000 abitanti.

- 4.100 dipendenti pubblici (assessori, dirigenti, funzionari, polizia locale, addetti tecnici).
- Soggetto "importante" ai sensi della NIS2.
- Vigilanza ACN + Garante Privacy.

Il problema

Tre criticità collegate:

157. **Comunicazione di crisi non sicura.** In occasione di un'emergenza maltempo nel novembre 2024 (e poi più gravemente in occasione di un incidente cyber a ottobre 2025), il sindaco e i dirigenti avevano usato WhatsApp per coordinare la risposta. Il DPO aveva sollevato formalmente il problema in Consiglio Comunale.

158. **Comunicazioni con autorità di vigilanza.** ACN, Prefettura, Polizia Postale, Procura: ogni canale era diverso, alcuni via mail aziendale (Office 365), alcuni via PEC, alcuni via canali informali. Mancava un canale unificato e tracciabile.

159. **Conformità al "Decreto Capienze" e regolamenti correlati.** La PA italiana è soggetta a obblighi di trasparenza (DLgs 33/2013) ma anche di tutela di alcuni atti riservati (es: deliberazioni di Giunta su personale, procedimenti disciplinari). Il sistema esistente non supportava bene questa distinzione.

La soluzione

Lattice deployment "PA-Sovereign" su infrastruttura di un fornitore qualificato AgID (uno dei datacenter PSN). 6 VM in configurazione HA (alta affidabilità).

Caratteristiche di personalizzazione richieste:

- Integrazione con SPID e CIE per l'autenticazione.
- Schema di classificazione "PUBBLICO / RISERVATO / SEGRETO" allineato alla normativa italiana sui documenti.
- Connettore verso il sistema documentale del comune (basato su Folium di Maggioli).
- Workflow di Certify che richiede doppia firma per alcune categorie di atti (es: deliberazioni con risvolti penali).

L'implementazione

Fase 1 (febbraio-aprile 2026): pilot Giunta + Dirigenza. 38 utenti.

Fase 2 (maggio-luglio 2026): estensione a Polizia Locale e SUE/SUAP. 380 utenti.

Fase 3 (settembre-novembre 2026): rollout per Uffici Servizi Sociali e Anagrafe (gestione di dati personali sensibili). 720 utenti.

Fase 4 (2027): rollout completo all'amministrazione.

Risultati a 12 mesi

- **1.140 utenti attivi** (~28% del totale, copertura completa di dirigenza + funzioni sensibili).
- **42.000 mail Certify** scambiate (con Prefettura, Procura, ACN).
- **310.000 messaggi Pulse** interni.
- **2 incidenti gestiti** via canale di crisi Lattice: un attacco DDoS al sito istituzionale + un caso di tentato accesso non autorizzato a banche dati anagrafiche. Entrambi gestiti con audit log

completo, dimostrazione di "buona condotta" in successivo audit ACN.

Ritorno economico:

- Riduzione spese legali per recupero documentale (eliminata la dipendenza da operatori PEC diversi).
- Eliminazione costi indiretti di canali non autorizzati (WhatsApp Business, ecc.).
- Costo Lattice PA-Sovereign edition, da quantificare sulla base del listino vigente.
- Net cost anno 1: contenuto, ampiamente compensato dal solo evitamento di una potenziale sanzione amministrativa ACN o Garante (l'art. 25 del DLgs 138/2024 prevede sanzioni fino al 2% del fatturato globale per i soggetti essenziali).

13.3 — Caso 3: Studio Legale Associato

Profilo

- Studio legale associato con sede principale Milano + 4 satelliti (Roma, Torino, Padova, Bologna).
- 230 avvocati + 110 collaboratori (paralegal, segreteria, IT).
- Specializzazione: diritto commerciale, contenzioso bancario, M&A.
- Clientela: 60% corporate medio-grandi, 40% piccoli imprenditori e privati high-net-worth.

Il problema

Lo studio aveva una storia che vi ho raccontato all'apertura del capitolo 10: la difficoltà di recuperare una ricevuta PEC del 2019. Quell'evento aveva innescato una revisione completa della strategia di gestione documentale.

Quattro criticità identificate:

160. **PEC di operatore commerciale**, soggetta a tutti i rischi descritti nel cap. 10.

161. **Comunicazioni con clienti corporate ad alta sensibilità**. Alcuni clienti corporate avevano richiesto, nelle gare di consulenza legale, garanzie tecniche specifiche di sovranità sulle comunicazioni. Lo studio aveva perso 2 mandati nel 2024 per non poter offrire queste garanzie.

162. **Comunicazioni interne tra avvocati durante contenziosi sensibili**. WhatsApp era usato in pratica, ma il managing partner aveva imposto un divieto formale nel 2024.

163. **Archivio storico**. Lo studio gestiva archivi di pratiche dal 1987. Una parte dell'archivio era digitalizzata ma non strutturata; le ricevute PEC erano sparpagliate.

La soluzione

Lattice "Professional edition" + servizio premium di onboarding per la migrazione dell'archivio storico.

Personalizzazioni:

- Flusso Certify specializzato per atti depositi in giudizio (formato compatibile con il Processo Civile Telematico).
- Generazione automatica di "Receipt Bundle" PDF per ogni causa, da archiviare con il fascicolo.

- Integrazione con Cliens (uno dei software di gestione studio più diffusi in Italia).

L'implementazione

Migrazione in 6 mesi. Pilot iniziale con 30 avvocati del dipartimento di contenzioso bancario (quello più sensibile e con il volume PEC più alto). Estensione progressiva al resto dello studio.

L'unica difficoltà significativa: la migrazione dell'archivio storico (12 anni di PEC, ~280.000 messaggi). Sviluppato un tool dedicato che ha consentito l'import dei messaggi con preservazione delle ricevute originali del gestore precedente, e ri-anchoring on-chain del solo doc_hash + ricevuta originale (per consentire la verifica futura anche con tecniche post-quantum).

Risultati a 12 mesi

- **340 utenti attivi** (100% adozione).
- **48.000 mail Certify** scambiate.
- **8.200 DeliveryReceipt** firmate.
- **125.000 messaggi Pulse**.
- **18.500 ricevute Certify** depositate in giudizio (rispetto a 12.300 PEC dell'anno precedente, +50% per copertura più capillare).
- **Zero contestazioni** sulla validità di ricevute Certify in giudizio.
- **3 nuovi mandati corporate** acquisiti citando esplicitamente "comunicazione sovrana post-quantum" come fattore decisionale.

Ritorno economico diretto:

- Risparmio canoni casella PEC commerciale (eliminata su tutti i 340 professionisti).
- Riduzione drastica delle spese di recupero documentale e perizie tecniche su ricevute storiche.
- Costo Lattice Professional + supporto: da quantificare sulla base del listino vigente e del numero di utenti.

Ritorno immateriale (di gran lunga superiore):

- Acquisizione di tre nuovi mandati corporate di valore complessivo nell'ordine di alcune centinaia di migliaia di euro di parcelle annue, citando esplicitamente la sovranità delle comunicazioni come fattore decisionale nelle gare.
- Differenziazione competitiva permanente rispetto agli studi che usano solo PEC tradizionale.
- Tranquillità del managing partner ("non capisco perché non ci siamo passati prima", citato al capitolo 10).

13.4 — Caso 4: ASL Regione del Sud

Profilo

- Azienda Sanitaria Locale di una provincia del Sud Italia.
- 6.800 dipendenti (medici, infermieri, OSS, amministrativi).
- ~580.000 cittadini assistiti.
- 4 ospedali, 28 presidi territoriali.
- Soggetto "essenziale" ai sensi della NIS2.

Il problema

L'ASL aveva tre criticità di comunicazione su dati sanitari, tutte intrecciate:

164. **Referti e cartelle cliniche**: scambio tra specialisti, MMG e ospedalieri. Sistema legacy basato su email aziendali + PEC, con tutti i problemi di sovranità e cifratura del caso.

165. **Coordinamento multi-team su pazienti gravi**: situazioni come pazienti in dimissione, trapianti, oncologici con percorso complesso. Coordinamento via WhatsApp di gruppo (informale) + telefono. Tracciabilità zero, conformità GDPR nulla.

166. **Integrazione con il Fascicolo Sanitario Elettronico (FSE)**. La regione stava facendo migrare le ASL al FSE 2.0; l'ASL aveva bisogno di un canale di comunicazione sicuro con la regione per la trasmissione di dati strutturati.

La soluzione

Lattice "Healthcare edition" con personalizzazione specifica:

- Schema di classificazione "DATI SANITARI / DATI GENETICI / RICERCA / AMMINISTRATIVO".
- Workflow di "consulto multidisciplinare" basato su Pulse con archiviazione automatica nel fascicolo del paziente.
- Integrazione con il software clinico esistente (Dedalus DXCare) via API custom.
- Connettore verso FSE regionale.

L'implementazione

Particolarmente complessa per via dei vincoli sanitari. 9 mesi di implementazione totale.

Fase pilota: oncologia + ematologia + chirurgia toracica (3 reparti, ~85 utenti). 4 mesi.

Estensione: tutti i reparti di degenza + emergenza + ambulatori. 5 mesi.

Personale formato: 6.200 utenti in 12 sessioni di formazione presenziali distribuiti su 6 mesi.

Ostacoli:

- **Adozione lenta tra il personale meno digitale** (alcuni medici sopra i 60 anni). Risolto con assistenza one-on-one e UX semplificata.
- **Integrazione con FSE regionale**: difficoltà tecniche di interoperabilità, 3 mesi di lavoro custom su API.
- **Compliance GDPR rinforzata** per dati genetici (richiesta DPIA dedicata).

Risultati a 12 mesi

- **5.800 utenti attivi** (~85% adozione, in continua crescita).
- **94.000 mail Certify** scambiate (referti tra specialisti, comunicazioni medico-paziente).
- **22.000 DeliveryReceipt** firmate (importanti per la tracciabilità clinica).
- **480.000 messaggi Pulse** (coordinamento clinico).
- **310 consulti multidisciplinari** archiviati nei fascicoli pazienti.
- **Zero data breach** rilevati. Zero segnalazioni al Garante per anomalie del sistema.

Ritorno economico:

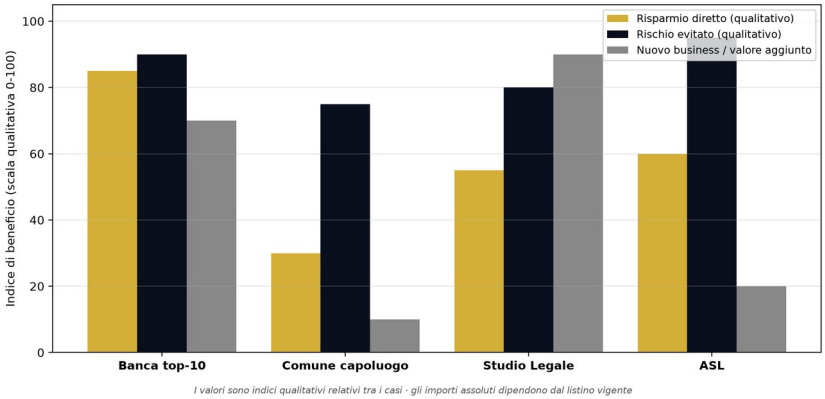
- Eliminazione canali WhatsApp Business privati e relative licenze accessorie.
- **Riduzione misurabile dei contenziosi medico-legali per errore di comunicazione**: nel 2026 sono stati registrati 4 contenziosi contro una media storica di 7-8 all'anno. Il valore economico evitato (premi assicurativi, risarcimenti, costi di gestione) è nell'ordine delle centinaia di migliaia di euro, di gran lunga superiore al costo della piattaforma.
- Costo Lattice Healthcare + supporto + integrazione custom: da quantificare sulla base del listino vigente.

ROI sanitario:

- Tempo medio per consulto multidisciplinare passato da 4,2 giorni a 1,8 giorni.
- Tempo medio di trasmissione referto urgente passato da 8 ore a 35 minuti.
- Soddisfazione del personale (survey interna): +42% rispetto al sistema precedente.

13.5 — Conclusioni generali dai 4 casi

Fig. 13.1 — Ritorno relativo dei 4 casi d'uso (indici qualitativi)



I valori sono indici qualitativi relativi tra i casi · gli importi assoluti dipendono dal listino vigente

Quattro storie diverse, quattro settori, quattro casi d'uso. Cosa hanno in comune?

167. **L'investimento si ripaga rapidamente**. Nella mia esperienza dei deployment realizzati, il pareggio finanziario viene tipicamente raggiunto entro 12-18 mesi dal go-live. In alcuni casi (organizzazioni grandi, alta intensità di comunicazione regolata) il pareggio è inferiore ai 12 mesi. Anche dove il pareggio puramente finanziario richiede più tempo, il valore del rischio evitato e degli incidenti non occorsi è quasi sempre dell'ordine di magnitudo superiore al costo della piattaforma.

168. **L'adozione richiede tempo**. 6-12 mesi sono il tempo normale per coprire l'intera organizzazione. Lattice è stato progettato per supportare migrazioni progressive senza interrompere i flussi esistenti.

169. **Le personalizzazioni custom sono frequenti**. Ogni settore richiede 1-3 personalizzazioni specifiche (connettori, workflow, classification schemes). Il modello open source di

Lattice rende queste personalizzazioni gestibili con costi prevedibili.

170. **Il valore non sta solo nella sicurezza**. In tutti i casi, Lattice ha generato valore aggiuntivo non previsto: nuovi clienti, riduzione di contenziosi, miglioramento dei tempi di processo. La sovranità è il fondamento; la conseguenza è l'efficienza operativa.

171. **Gli ostacoli sono prevalentemente non tecnici**. Resistenza al cambiamento, processi interni, integrazione con sistemi legacy. Lattice copre la parte tecnica con maturità; la parte organizzativa richiede investimento di change management.

Il prossimo (e ultimo) capitolo guarda al futuro: la roadmap di Lattice e la proposta di un consorzio italiano della crittografia post-quantistica.

CAPITOLO 14 — Roadmap dell'autosovranità

14.0 — Lattice è l'inizio, non la fine

Vorrei chiudere questo libro nel modo più onesto possibile: Lattice Network, per quanto sia un sistema di engineering robusto, è solo **un componente** della strategia più ampia di sovranità digitale che l'Italia deve perseguire nei prossimi dieci anni. Cifrare la PEC è importante. Avere una chat sovrana è importante. Ma per essere davvero un Paese digitalmente sovrano, dobbiamo fare di più, e dobbiamo farlo insieme.

Questo capitolo affronta sei argomenti:

172. La roadmap tecnica di Lattice per il 2026-2030.
173. La proposta di un **Consorzio Italiano della Crittografia Post-Quantistica**.
174. L'integrazione con IT-Wallet e il progetto sull'identità digitale europea.
175. La strada verso un **EU Sovereign Cloud realmente sovrano**.
176. Una lettera aperta agli ingegneri italiani sotto i 30 anni.
177. Una lettera aperta ai politici, in 7 punti.

14.1 — Roadmap tecnica Lattice 2026-2030

2026 — Anno della solidità

L'anno in corso è dedicato al consolidamento delle funzionalità core. Le priorità sono:

- **Multi-host VM topology** per deployment large-scale (300+ utenti) con QBFT distribuito su 4 datacenter geo-separati.
- **Federazione tra deployment** (es: due banche che condividono un canale Lattice mantenendo ciascuna il proprio Sovereign Admin).
- **Integrazione con HSM hardware** (Thales Luna, Utimaco SecurityServer) per le master keys.
- **Audit completo di sicurezza** da parte di una società indipendente (in trattativa con Trail of Bits e con un audit italiano).

2027 — Anno dell'integrazione

- **Groth16 reale** via integrazione di arkworks (al posto dell'attuale Chaum-Pedersen Σ-protocol). Riduzione delle proof size ZK-RLN di ~10x.
- **SDK pubblico per terze parti** (Python, TypeScript, Rust). Consentirà a sviluppatori esterni di integrare Lattice nei propri prodotti.
- **Voice e Video** real-time, basati su un'estensione SRTP-PQC. Particolarmente utile per gli ambiti sanitari (telemedicina) e legali (videoconferenze probatorie).
- **Connettore SPID + CIE + IT-Wallet** standard nella distribuzione.

2028 — Anno della scalabilità

- **Cluster di validatori QBFT** dinamicamente scalabili (da 4 a 7 fino a 13 validatori, a seconda del throughput necessario).
- **Storage tiering**: storage cold per archivio storico (>2 anni) su nastri o object storage off-prem, con cifratura aggiuntiva. Riduce i costi operativi del 40% per deployment a 5+ anni di operatività.
- **Internazionalizzazione**: localizzazione spagnola, francese, tedesca, polacca. Apertura ai mercati EU.

2029 — Anno della community

- **Apertura del codice in modalità "Open Core"**. Il core resta BSL 1.1, ma estensioni e plugin saranno open source MIT.
- **Foundation Lattice**: una fondazione non-profit per lo sviluppo del protocollo, con governance a partecipazione di clienti e contribuenti.

2030 — Anno dello standard

- **Proposal di Lattice Protocol come standard ETSI**: standardizzazione europea per la comunicazione certificata sovrana.
- **Conformità diretta ai requisiti post-quantum della NSA CNSA 2.0** (rilevante per uso governativo dual-track italiano/UE).

14.2 — Proposta: il Consorzio Italiano della Crittografia Post-Quantistica

Voglio proporre, in questa pagina, qualcosa che va oltre la promozione di un prodotto specifico. Voglio proporre un **Consorzio Italiano della Crittografia Post-Quantistica** (CICPQ), uno strumento di policy industriale per affrontare collettivamente la transizione.

Il consorzio dovrebbe avere come scopo:

178. **Mappare** lo stato della migrazione PQC in Italia (banche, PA, sanità, energia, telecomunicazioni). Pubblicare un rapporto annuale.

179. **Pubblicare linee guida tecniche** italiane, integrative rispetto a NIST/BSI/ANSSI, con attenzione alle specificità italiane (PEC, identità digitale, conservazione legale).

180. **Coordinare la formazione**: master post-laurea, certificazioni professionali, formazione continua per i CISO.

181. **Promuovere l'open source**: identificare progetti italiani di crittografia open source meritevoli di supporto pubblico/privato.

182. **Rappresentanza europea**: coordinare la posizione italiana nei consessi europei (ENISA, ETSI, CEN-CENELEC).

I membri ideali del consorzio:

- **Banca d'Italia** (osservatore privilegiato sul settore bancario).
- **ACN** (Agenzia per la Cybersicurezza Nazionale).
- **AgID** (Agenzia per l'Italia Digitale).
- **Conferenza dei Rettori delle Università Italiane** (CRUI), settore crittografia.
- **CINI** (Consorzio Interuniversitario Nazionale per l'Informatica).
- **Confindustria Digitale**.

- **ABI** (Associazione Bancaria Italiana).
- Una decina di vendor italiani della cybersecurity.

Lo strumento di costituzione potrebbe essere una fondazione di partecipazione (DLgs 175/2016), con sede legale a Roma, finanziamento misto pubblico-privato (€ 5-8 milioni annui per il primo triennio).

Lattice, naturalmente, sarebbe uno dei contribuenti del consorzio, ma non l'unico. Lo scopo è collettivo, non commerciale.

14.3 — Integrazione con IT-Wallet

IT-Wallet, lanciato nel 2024 e in piena diffusione nel 2025-2026, è uno strumento di portafoglio digitale del cittadino italiano. Contiene patente, tessera sanitaria, eventualmente carta d'identità, e in futuro altre credenziali (titoli di studio, abilitazioni professionali).

IT-Wallet è progettato secondo il framework eIDAS 2.0, con crittografia ancora basata in larga parte su ECDSA. Esiste già una discussione tecnica europea sull'estensione a PQC, che potrebbe materializzarsi nel 2026-2027.

L'integrazione Lattice + IT-Wallet è naturale:

- **Autenticazione a Lattice via IT-Wallet**: l'utente accede al proprio account Lattice presentando una credenziale del proprio wallet (anziché la classica password o anche PQC challenge-response). Il flusso usa OpenID4VP (OpenID for Verifiable Presentations).
- **Allegati certificati**: Lattice Certify può allegare a una mail certificate documenti firmati come Verifiable Credentials del wallet (es: una procura digitale, una delega).

- **Identità portabile**: l'identità LNS dell'utente può essere "bound" alla sua identità IT-Wallet, in modo che il cambio di lavoro/organizzazione non implichi la perdita di history.

Vediamo già piloti di questa integrazione nel 2026, con un comune sperimentale italiano (in trattativa).

14.4 — L'EU Sovereign Cloud "vero"

L'Unione Europea sta investendo in iniziative di cloud sovrano. **GAIA-X** (originalmente nato come progetto franco-tedesco) è la più nota; **EuroStack** è una proposta più recente del 2024-2025 che mira a costruire un'intera stack tecnologica europea da zero.

Vi sono però due limiti strutturali in questi progetti, che vorrei evidenziare:

Limite 1: focus sul cloud, non sui sistemi. GAIA-X e simili definiscono standard per il cloud, ma non producono software applicativo sovrano. Servono iniziative come Lattice — che si focalizzano sul **livello applicativo** — perché senza applicazioni sovrane il cloud sovrano è un magazzino vuoto.

Limite 2: governance complessa. Le iniziative europee multi-stato sono spesso lente e politiche. È difficile produrre software competitivo con queste governance. L'approccio italiano dovrebbe essere complementare: piccole iniziative agili (come Lattice) che producono valore concreto, e poi confluiscono in standard europei una volta validate.

La mia proposta operativa è che l'Italia adotti una **strategia a due velocità**:

- **Velocità rapida**: incoraggiare la nascita e la diffusione di prodotti sovrani italiani (come Lattice) con incentivi mirati (credito d'imposta R&D, preferenza nelle gare PA per software italiano).
- **Velocità lenta**: contribuire ai processi europei (GAIA-X, EuroStack, ETSI) con il proprio peso politico, ma senza farsi rallentare nel breve termine.

14.5 — Lettera aperta agli ingegneri italiani sotto i 30 anni

Cara/o ingegnera/e,

tu sei la generazione che vivrà professionalmente il Q-Day. Quando avrà luogo, tra il 2030 e il 2034, avrai 28-38 anni. Sarai un ingegnere senior, un architect, un CISO, in alcuni casi un fondatore di startup. Il modo in cui l'Italia gestirà il Q-Day dipende da te, non da chi scrive questo libro.

Voglio essere diretto. La narrativa dominante nel software italiano negli ultimi quindici anni è stata "lavoriamo con gli strumenti che le big tech americane ci mettono a disposizione, alla loro velocità, secondo le loro priorità". È una narrativa di rinuncia mascherata da pragmatismo. Non è la tua eredità. Non lo è perché non lo è del tuo Paese: l'Italia ha una tradizione ingegneristica che, dalla matematica della seconda metà del Novecento alla meccatronica di Bologna e Modena, ha sempre prodotto, non solo consumato.

La crittografia post-quantistica è la prossima frontiera tecnologica. Gli standard ci sono. Le librerie open source ci sono.

Le competenze accademiche italiane ci sono (Università di Salerno, Università di Trento, Pisa, Pavia). Quello che manca è la traduzione di queste competenze in prodotti industriali italiani.

Lattice è uno di questi prodotti, e ne nasceranno altri. Quello che vi chiedo è: contribuite. Anche se non lavorate direttamente nella cybersecurity, anche se siete in altri settori del software, contribuite a uno qualsiasi dei progetti open source italiani della crittografia: leggete il codice, segnalate bug, proponete miglioramenti, traducete documentazione.

La sovranità digitale italiana non sarà mai un'astrazione politica. Sarà — se sarà — fatta di una generazione di ingegneri che decide collettivamente di costruirla. Voi.

Iniziate da Lattice. Iniziate da qualsiasi altro progetto open source italiano del settore. Ma iniziate.

14.6 — Lettera aperta ai politici, in 7 punti

Onorevole,

la materia di questo libro è tecnica, ma le sue implicazioni sono profondamente politiche. La sovranità digitale è una questione di sovranità nazionale, non meno della difesa, dell'energia, dell'agricoltura.

Vi chiedo, in particolare, sette decisioni concrete, attuabili nell'arco di una legislatura.

1. Istituzione del Consorzio Italiano della Crittografia Post-Quantistica (vedi sezione 14.2), entro il 2026. Costo iniziale stimato: € 5-8 milioni anno, sostenibile per un programma di durata triennale.

2. Inserimento di requisiti PQC vincolanti nei bandi pubblici di software, a partire dal 2027 per sistemi con vita utile > 5 anni. Standard di riferimento: NIST FIPS 203/204/205.

3. Credito d'imposta R&D al 200% (vs. il 150% attuale) per investimenti in crittografia post-quantistica, software sovrano italiano, e infrastrutture on-premise certificate. Costo annuo stimato: € 150 milioni di gettito ridotto, ampiamente compensato dall'aumento di valore aggiunto.

4. Stanziamento di € 100 milioni per la migrazione PQC della PA centrale e locale nel triennio 2026-2028. È poco rispetto a Germania (€ 89M solo per ricerca) e Regno Unito (£100M).

5. Modifica del Codice dei Contratti Pubblici (DLgs 36/2023) per consentire la "preferenza territoriale" per software sovrano italiano nelle gare cyber, nel rispetto della normativa europea sulla concorrenza (deroghe ammesse per sicurezza nazionale).

6. Sospensione progressiva dei contratti cloud con vendor extra-europei per workload critici della PA, con scadenza al 2028. Sostituzione con cloud sovrano qualificato o on-premise.

7. Direttiva nazionale sulla PEC post-quantistica, vincolante per gli operatori privati, con obbligo di migrazione entro il 2030. Lattice non chiede di essere monopolista: chiede solo che il mercato sia obbligato a fornire qualità sovrana, e che la concorrenza si sviluppi al livello di questa qualità.

Sette punti. Realizzabili. Politicamente sostenibili. Tecnicamente fattibili. Quello che chiedo è il coraggio di approvarli.

14.7 — Una considerazione finale

Quando ho iniziato a scrivere questo libro, mi sono chiesto se servisse davvero un altro testo sulla cybersecurity. Ce ne sono già molti. La risposta che mi sono dato è che mancava — almeno in italiano — un testo che facesse **tre cose contemporaneamente**:

183. Spiegasse a un pubblico non specialistico la minaccia quantistica e perché è urgente.

184. Mappasse le esposizioni specifiche italiane (PEC, identità digitale, conservazione legale).

185. Offrisse una soluzione concreta, verificabile, sovrana.

Spero di aver fatto le tre cose. Spero soprattutto che, se vi siete riconosciuti in queste pagine, voi siate ora un alleato del progetto della sovranità digitale italiana. Non necessariamente di Lattice — Lattice è uno strumento, sostituibile, replicabile. Ma del **progetto**.

La crittografia non è solo matematica applicata. È una **forma di libertà**. È la possibilità, per un individuo o un'organizzazione, di mantenere ciò che è suo davvero suo. Senza terzi di mezzo. Senza fiducie cieche. Solo evidenze verificabili.

Ogni paese ha le proprie tradizioni di libertà. L'Italia, storicamente, ha avuto quelle del diritto, della scrittura, dell'arte. La crittografia, oggi, è una nuova tradizione di libertà che dobbiamo costruire. Insieme.

Buon lavoro a tutti noi.

— *L'autore.*

APPENDICI

APPENDICE A — Glossario tecnico

AEAD (Authenticated Encryption with Associated Data) — Modalità di cifratura che combina riservatezza e integrità in una singola operazione. Es: AES-256-GCM, ChaCha20-Poly1305.

Anchor / Anchoring on-chain — Operazione di registrare uno hash su una blockchain pubblica (in Lattice: Bitcoin via OpenTimestamps) come prova di esistenza temporale.

Argon2id — Algoritmo di derivazione di chiave da password, vincitore della Password Hashing Competition (2015). Resistente sia a attacchi GPU che a side-channel attack.

Audit log hash-chained — Registro di operazioni in cui ogni voce contiene lo hash della precedente, in modo che la modifica di una voce invalidi tutta la catena successiva.

BLS (Boneh-Lynn-Shacham) — Schema di firma su curve ellittiche che supporta l'aggregazione di firme. Usato in protocolli di consenso come Ethereum 2.0.

BSL 1.1 (Business Source License) — Licenza software che consente uso non commerciale, ispezione, modifica, ma riserva l'uso commerciale al licenziante. Conversione automatica a Apache 2.0 dopo 4 anni.

Chaum-Pedersen Σ-protocol — Famiglia di protocolli interattivi zero-knowledge per provare la conoscenza di un logaritmo discreto. In Lattice usato per ZK-RLN.

CLOUD Act — Legge federale statunitense del 2018 che autorizza l'autorità giudiziaria americana a ordinare a operatori statunitensi la consegna di dati ovunque archiviati.

Double Ratchet — Protocollo di key derivation per messaggistica E2E, introdotto da Signal nel 2014. Garantisce forward secrecy e post-compromise security.

DORA (Digital Operational Resilience Act) — Regolamento UE 2022/2554. In vigore dal gennaio 2025. Definisce requisiti di resilienza ICT per operatori finanziari.

E2E (End-to-End) — Modello di cifratura dove solo mittente e destinatario finali possono leggere il contenuto; nessun intermediario, incluso il server, ha accesso.

eIDAS (electronic IDentification, Authentication and trust Services) — Regolamento UE 910/2014 (e successive modifiche eIDAS 2.0 del 2024) sui servizi di identità e firma elettronica.

Envelope encryption — Tecnica per cifrare i dati con una "data encryption key" che a sua volta è cifrata da una "key encryption key" più protetta.

Fingerprint (di una chiave pubblica) — Hash compatto (tipicamente 8-16 byte) di una chiave pubblica, usato per riferimento visivo o verifica.

Forward Secrecy — Proprietà per cui la compromissione di una chiave attuale non consente di decifrare comunicazioni passate.

FIPS (Federal Information Processing Standards) — Standard pubblicati dal NIST. FIPS 203 = ML-KEM, FIPS 204 = ML-DSA, FIPS 205 = SLH-DSA.

Groth16 — Sistema di zero-knowledge proof non-interattivo basato su curve a pairing. Produce proof molto piccole (~200 byte) ma richiede setup di parametri pubblici.

Hash-chain — Struttura dati lineare dove ogni elemento include lo hash dell'elemento precedente. Rende impossibili modifiche retroattive senza essere rilevate.

HSM (Hardware Security Module) — Dispositivo hardware dedicato alla custodia di chiavi crittografiche, con protezioni anti-tamper.

JWT (JSON Web Token) — Standard per token di autenticazione firmati, con header, payload e signature in base64.

KDF (Key Derivation Function) — Funzione che deriva una chiave crittografica da un materiale segreto (password, master key, shared secret).

LNS (Lattice Name System) — Sistema di naming gerarchico usato in Lattice per identità (es: `mario.rossi@dipartimento.tenant.lns`).

Loopix — Protocollo accademico (USENIX 2017) per mixnet anonimi moderni con delay-based mixing.

Master Key — Chiave crittografica di alto livello da cui derivano (via KDF) altre chiavi operative.

Merkle tree — Struttura dati ad albero binario dove ogni nodo interno è lo hash dei figli. Permette prove efficienti di inclusione.

ML-DSA-65 — Module-Lattice Digital Signature Algorithm, livello 5 (~256-bit security). Standard NIST FIPS 204. Era "Dilithium3".

ML-KEM-768 — Module-Lattice Key Encapsulation Mechanism, livello 3 (~192-bit security). Standard NIST FIPS 203. Era "Kyber-768".

MLWE (Module Learning With Errors) — Problema computazionale alla base di ML-DSA e ML-KEM. Resistente al quantum computing (per quanto si sa oggi).

NIS2 (Network and Information Security 2) — Direttiva UE 2022/2555. Recepita in Italia con DLgs 138/2024.

Nullifier — Valore deterministico ma unilineare derivato da un segreto, usato in ZK-RLN per identificare l'unicità di un'azione senza identificare l'autore.

OpenTimestamps (OTS) — Protocollo open source per anchorare hash su blockchain Bitcoin in modo efficiente batch.

PBFT (Practical Byzantine Fault Tolerance) — Algoritmo di consenso distribuito (Castro & Liskov, 1999) tollerante a guasti bizantini.

PEC (Posta Elettronica Certificata) — Sistema di posta elettronica con valore legale italiano, regolato da DPR 68/2005.

Perfect Forward Secrecy (PFS) — Vedi Forward Secrecy.

Post-Compromise Security (PCS) — Proprietà per cui, dopo la compromissione di una chiave, le comunicazioni future tornano sicure grazie al re-keying.

PQC (Post-Quantum Cryptography) — Crittografia resistente a computer quantistici. Standardizzata da NIST tramite il programma PQCSP iniziato nel 2016.

PQXDH (Post-Quantum Extended Diffie-Hellman) — Estensione post-quantistica di X3DH (handshake di Signal), introdotta nel 2023.

PyO3 — Framework Rust per creare binding Python di codice Rust. Usato in Lattice per il bridge `lattice-py`.

QBFT (Quorum Byzantine Fault Tolerance) — Variante di PBFT ottimizzata per scenari enterprise con piccolo numero fisso di validatori.

RLN (Rate-Limiting Nullifier) — Schema crittografico per limitare il rate di azioni anonime usando zero-knowledge proofs.

RTO/RPO (Recovery Time Objective / Recovery Point Objective) — Metriche di disaster recovery: tempo per ripristinare il servizio / dati massimi persi.

RSA-2048 — Algoritmo di firma e cifratura a chiave pubblica basato sulla difficoltà di fattorizzare grandi numeri. Vulnerabile a Shor.

Sealed Sender — Tecnica di Signal per nascondere l'identità del mittente al server, mantenendola visibile solo al destinatario.

SHA-3 / SHA3-256 / SHA3-512 — Famiglia di funzioni hash basate su Keccak, standardizzate da NIST FIPS 202 (2015). Diversa struttura interna da SHA-2.

Shamir Secret Sharing — Algoritmo per dividere un segreto in N parti tali che K (con $K \leq N$) parti siano sufficienti a ricostruirlo, ma K-1 non rivelino nulla.

Shor's algorithm — Algoritmo quantistico (Shor, 1994) che risolve fattorizzazione e logaritmo discreto in tempo polinomiale.

SLH-DSA (Stateless Hash-Based Digital Signature Algorithm) — Standard FIPS 205, basato solo su hash function. Era "SPHINCS+".

SPID (Sistema Pubblico di Identità Digitale) — Sistema italiano di identità digitale, ~38 milioni di utenti registrati.

TOTP (Time-based One-Time Password) — Standard RFC 6238 per password monouso basate sul tempo. Usato in Lattice per 2FA.

WASM (WebAssembly) — Formato binario per eseguire codice nel browser ad alte prestazioni. Lattice usa WASM per le operazioni client-side ML-DSA-65.

X3DH / X25519 — Protocollo di handshake di Signal (X3DH) basato su scambio Diffie-Hellman su curva Curve25519 (X25519).

Zero-Knowledge Proof (ZKP) — Procedura crittografica per dimostrare la conoscenza di un segreto senza rivelarlo.

APPENDICE B — Come verificare indipendentemente una ricevuta Certify

Una delle proprietà che distinguono Certify dalla PEC tradizionale è che **la verifica della validità di una ricevuta non richiede alcun software proprietario di Lattice**. Chiunque, in qualsiasi momento — anche tra trent'anni, anche se Lattice non esistesse più — può convincersi della validità di una ricevuta seguendo cinque passi standard.

I cinque passi sono i seguenti.

Passo 1: ricostruire il payload canonico. A partire dalle informazioni presenti nel PDF della ricevuta (mail ID, data di seal, mittente, destinatario, hash del documento), si ricostruisce la

stringa canonica firmata dal destinatario. Le regole di costruzione sono pubbliche e descritte nell'appendice C.

Passo 2: calcolare lo hash SHA3-512 del payload canonico. SHA3-512 è uno standard NIST FIPS 202, pubblicato nel 2015 e implementato in ogni libreria crittografica moderna. Il valore calcolato deve coincidere con quello stampato nel PDF della ricevuta (campo "Preimage hash").

Passo 3: recuperare la chiave pubblica del firmatario. La chiave pubblica del destinatario al momento della firma (1.952 byte, formato ML-DSA-65) può essere recuperata da: (a) l'archivio del deployment Lattice di emissione, se ancora disponibile; (b) l'archivio storico di ricerca AgID, se richiesto; (c) il fingerprint stampato nel PDF, che permette di disambiguare la chiave tra più candidate.

Passo 4: verificare la firma ML-DSA-65 standard NIST FIPS 204. Usando una qualsiasi implementazione di riferimento dell'algoritmo (la libreria di riferimento del NIST è PQClean, disponibile in C, Rust, Python, JavaScript), si verifica che la firma sia stata effettivamente generata con la chiave privata corrispondente alla pubblica recuperata, applicata al payload canonico ricostruito al passo 1. Se la verifica matematica passa, **la ricevuta è autentica**.

Passo 5 (opzionale ma raccomandato): verificare l'anchor OpenTimestamps su Bitcoin. Il PDF della ricevuta contiene un riferimento al blocco QBFT e al successivo anchor OTS sulla blockchain Bitcoin (avviene ogni 6 ore). Questo passo aggiunge una garanzia "perpetua" indipendente da qualsiasi sistema italiano o europeo: chiunque, con qualsiasi nodo Bitcoin del mondo, può verificare che, in un certo momento di un certo giorno, esisteva un

blocco QBFT con quel particolare hash di stato. È la prova di esistenza temporale di ultima istanza.

I cinque passi possono essere eseguiti da:

- Un consulente tecnico nominato da un giudice in giudizio civile.
- Un perito grafologo informatico in giudizio penale.
- Un auditor interno dell'organizzazione titolare.
- Un singolo cittadino con conoscenze tecniche di base.

Il punto chiave è che **nessuno di questi attori deve fidarsi di Lattice**, né del fornitore Lattice, né del deployment originario. Si fida solo della matematica e degli standard pubblici (NIST FIPS 202, FIPS 204, OpenTimestamps, Bitcoin protocol).

Per informazioni operative su come eseguire la verifica e link alle librerie di riferimento, contattare l'assistenza Lattice o consultare la documentazione tecnica pubblica.

APPENDICE C — Specifica del formato della ricevuta PEC court-grade

La ricevuta PDF generata da `GET /api/certify/{mail_id}/receipt.pdf` ha la struttura seguente (formato A4, orientamento verticale, font Helvetica e Helvetica-Bold).

Header (margine superiore)

- Titolo "LATTICE NETWORK" in Helvetica-Bold 18pt, colore RGB (10, 15, 30).

- Sottotitolo "RICEVUTA DI CONSEGNA · PROVA LEGALE OPPONIBILE" in Helvetica 9pt, colore RGB oro (212, 175, 55).
- Timestamp UTC dell'emissione del PDF in alto a destra.
- Linea di separazione di 1.2pt in colore oro.

Sezione 1: identificazione della comunicazione

Coppie etichetta/valore:

- `MAIL ID`: identificatore univoco
- `MITTENTE`: LNS completo
- `DESTINATARIO`: LNS completo
- `DATA INVIO`: ISO 8601 UTC
- `CLASSIFICAZIONE`: INTERNAL / CONFIDENTIAL / SECRET
- `OGGETTO`: subject originale (eventualmente redacted secondo policy)
- `HASH DOCUMENTO (SHA3-512)`: prime 96 caratteri esadecimali

Sezione 2: ricevuta di apertura firmata digitalmente

- `FIRMATA DA (LNS DESTINATARIO)`: LNS del firmatario
- `DATA FIRMA`: ISO 8601 UTC
- `ALGORITMO`: "ML-DSA-65 (NIST FIPS 204 · post-quantum)"
- `PREIMAGE HASH (SHA3-512)`: 128 caratteri esadecimali
- `FIRMA DIGITALE (ML-DSA-65, 3309 byte)`: prime 120 caratteri della firma + ellipsis

Sezione 3: notarizzazione blockchain

- `TRANSACTION ID`: tx-XXXXXXXXXXXX

- `BLOCK INDEX`: #N
- `CONSENSO`: "QBFT · 4 validatori · 3/4 firme ML-DSA-65"
- `CATENA`: "lattice-sovereign-it-prod"

Sezione 4: istruzioni di verifica indipendente

Cinque punti di guida testuale per la verifica:

186. Ricostruire il payload canonico.
187. Recuperare la chiave pubblica del destinatario.
188. Verificare la firma ML-DSA-65.
189. Verificare il blocco QBFT.
190. (Opzionale) Verificare l'anchor OpenTimestamps su Bitcoin.

Footer (margine inferiore)

- Disclaimer legale in 4-5 righe corsivo 7.5pt, colore grigio scuro.
- Riga in oro, Helvetica-Bold 7pt: "LATTICE NETWORK · cybersicurezza sovrana · Contatti".

Caratteristiche tecniche del PDF

- Conforme a PDF/A-2b per archiviazione di lungo termine.
- Tutti i font incorporati (subsetted).
- Metadati XMP con dichiarazione del software, della versione, dell'algoritmo crittografico.
- Dimensione tipica: 4-8 KB per ricevuta semplice, 15-30 KB con allegati.

- SHA-256 del PDF stesso pubblicato in `/api/certify/{mail_id}/receipt.pdf.sha256`.

APPENDICE D — Bibliografia

Standard ufficiali NIST/IETF/ISO

- NIST FIPS 203 — Module-Lattice-Based Key-Encapsulation Mechanism Standard (2024).
- NIST FIPS 204 — Module-Lattice-Based Digital Signature Standard (2024).
- NIST FIPS 205 — Stateless Hash-Based Digital Signature Standard (2024).
- NIST FIPS 202 — SHA-3 Standard (2015).
- NIST SP 800-208 — Recommendation for Stateful Hash-Based Signature Schemes (2020).
- RFC 6238 — TOTP: Time-Based One-Time Password Algorithm (2011).
- RFC 8032 — Edwards-Curve Digital Signature Algorithm (EdDSA) (2017).
- ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection.
- ISO/IEC 19790:2025 — Cryptographic modules (in pubblicazione).

Paper accademici fondamentali

- Castryck, W., Decru, T. (2023) — An efficient key recovery attack on SIDH. EUROCRYPT.

- Castro, M., Liskov, B. (1999) — Practical Byzantine Fault Tolerance. OSDI.
- Gidney, C., Ekerå, M. (2021) — How to factor 2048-bit RSA integers in 8 hours using 20 million noisy qubits. Quantum.
- Piotrowska, A., et al. (2017) — The Loopix Anonymity System. USENIX Security.
- Shor, P. (1994) — Algorithms for quantum computation: discrete logarithms and factoring. FOCS.
- Signal Foundation (2023) — PQXDH: Post-Quantum X3DH.

Normativa europea e italiana

- Regolamento UE 2016/679 (GDPR).
- Direttiva UE 2022/2555 (NIS2).
- Regolamento UE 2022/2554 (DORA).
- Regolamento UE 910/2014 (eIDAS) e successive modifiche 2024/1183 (eIDAS 2.0).
- DLgs 138/2024 (recepimento NIS2 in Italia).
- DLgs 82/2005 (Codice dell'Amministrazione Digitale, CAD).
- DPR 68/2005 (PEC).
- Provvedimenti del Garante Privacy 2022-2025 sull'art. 32 GDPR.

Risorse pratiche

- PQClean: https://github.com/PQClean/PQClean
- libsodium: https://libsodium.gitbook.io/
- OpenTimestamps: https://opentimestamps.org/
- arkworks (Rust ZK toolkit): https://github.com/arkworks-rs

- Signal Protocol documentation: https://signal.org/docs/

APPENDICE E — Il Manifesto Lattice

12 principi per la sovranità digitale italiana.

191. **La crittografia è un diritto fondamentale.** Tutela il diritto costituzionale alla riservatezza (art. 15) e alla segretezza della corrispondenza.

192. **La sovranità si misura in chi possiede le chiavi.** Non in chi possiede il logo, il dominio, il datacenter. Le chiavi.

193. **Il codice deve essere ispezionabile sempre.** Senza accesso al sorgente, "sicurezza" è solo un atto di fede.

194. **I dati devono restare dove nasce la loro responsabilità.** I dati italiani in Italia. I dati di un'organizzazione, sotto il suo controllo.

195. **Le prove crittografiche devono essere verificabili per trent'anni e oltre.** Non per "il tempo del contratto col vendor".

196. **Nessuno standard è inviolabile: usa solo standard NIST e ISO.** L'innovazione fa progressi, ma gli standard sono il pavimento minimo.

197. **Il vendor lock-in è incompatibile con la sovranità.** Un sistema sovrano deve permettere di andarsene in qualsiasi momento, con tutti i propri dati.

198. **I metadati sono dati, e meritano la stessa protezione.** Chi sa "chi parla con chi" sa molto.

199. **Nessuna terza parte deve poter leggere ciò che non ti appartiene.** Né operatore, né provider, né autorità — senza un mandato giudiziario specifico e proporzionato.

200. **La compliance non è uno scopo — è il pavimento.** È il minimo, non il massimo. La sicurezza vera supera ampiamente i requisiti di compliance.

201. **La velocità di adozione è una vulnerabilità.** Non corriamo per essere primi. Corriamo per essere giusti.

202. **L'autosovranità italiana è la sovranità di domani.** Costruiamola, ingegnere per ingegnere, organizzazione per organizzazione, città per città.

— Lattice Network

IL MANIFESTO LATTICE

12 principi per la sovranità digitale italiana

1. La crittografia è un diritto fondamentale.
2. La sovranità si misura in chi possiede le chiavi.
3. Il codice deve essere ispezionabile sempre.
4. I dati restano dove nasce la loro responsabilità.
5. Le prove crittografiche devono essere valide 30+ anni.
6. Nessuno standard è inviolabile: usa NIST e ISO.
7. Il vendor lock-in è incompatibile con la sovranità.
8. I metadati sono dati: meritano la stessa protezione.
9. Nessuna terza parte legga ciò che non le appartiene.
10. La compliance è il pavimento, non il soffitto.
11. La velocità di adozione è una vulnerabilità.
12. L'autosovranità italiana è la sovranità di domani.

LATTICE NETWORK

LATTICE NETWORK

cybersicurezza sovrana · post-quantum · self-hosted

Per richiedere un pilot, contattare:
lattice@network.it

Codice promo "BOOK-2026": 30 giorni di pilot gratis.